

Introduction to Cyber Resilience Act (CRA)



Please introduce yourself ...

- your name
- department
- expectation for the training session.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU
Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples



Training Content

1. Cyber Resilience Act (CRA) Background, Purpose and Scope

2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Motivation: Examples for Existing Security Issues

German parents told to destroy Cayla dolls over hacking fears

© 17 February 2017



GETTY IMAGES
The My Friend Cayla doll has been shown in the past to be hackable

An official watchdog in Germany has told parents to destroy a talking doll called Cayla because its smart technology can reveal personal data.

The warning was issued by the Federal Network Agency (Bundesnetzagentur), which oversees telecommunications.

Researchers say hackers can use an insecure bluetooth device embedded in the toy to listen and talk to the child playing with it.

- German parents told to destroy Cayla dolls over hacking fears - BBC News

Bitsight Identifies Thousands of Security Cameras Openly Accessible on the Internet

June 10, 2025

Tags: **Bitsight Research**



Written by **João Cruz**
Principal Security Research Scientist

Welcome to 2025, where thousands of internet-connected cameras meant to protect us are actually putting us at risk. In our latest research at Bitsight TRACE, we found over 40,000 exposed cameras streaming live on the internet. No passwords. No protections. Just out there. [We first raised the alarm in 2023](#), and based on this latest study, the situation hasn't gotten any better.

These cameras –intended for security or convenience –have inadvertently become public windows into sensitive spaces, often without their owners' knowledge. No matter the reason why one individual or organization needs this kind of device, the fact that anyone can buy one, plug it in, and start streaming with minimal setup is likely why this is still an ongoing threat.



Share: [f](#) [X](#) [in](#)

On this page

Key takeaways

Where are all these cameras? Everywhere.

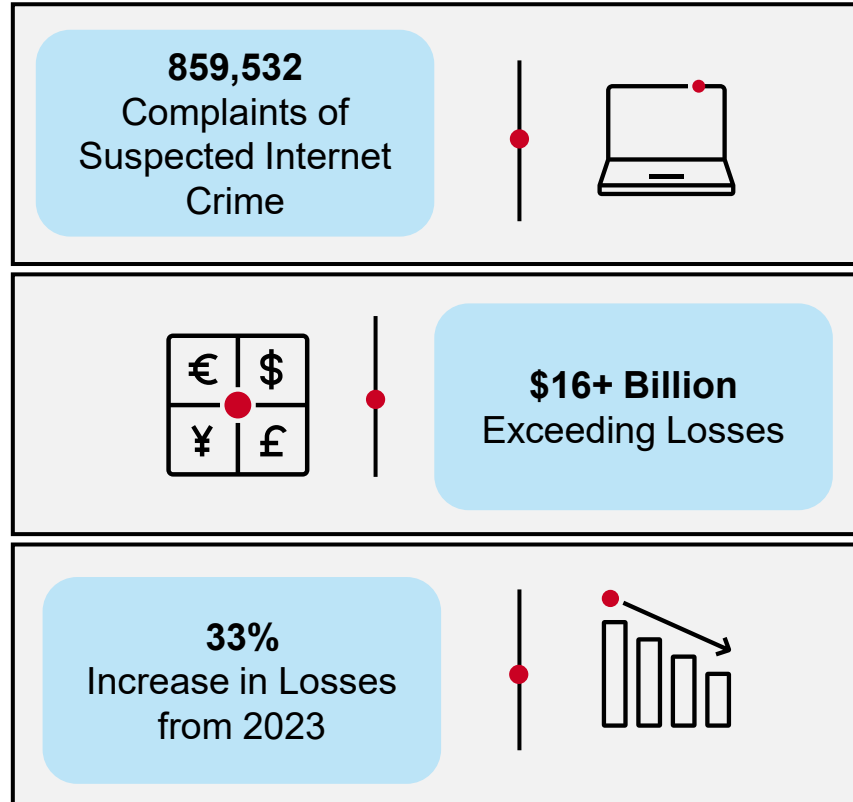
From bird feeders to business espionage

Bad guys are paying attention

- 40K Security Cameras Found Compromised Online | Bitsight

Motivation: For Safer and More Secure Digital Products

- Hardware and software products are increasingly targeted by successful cyberattacks.
- These flaws lead to higher costs and risks for both users and society.
 - **Low cybersecurity**: Widespread vulnerabilities and irregular security updates
 - **Limited user awareness**: Inadequate info for informed and secure usage



Motivation: For Safer and More Secure Digital Products

- **Prevalence of Digital Products:** Many of the daily use digital products have inadequate cybersecurity measures, making them vulnerable to cyberattacks.
- **Inadequate Security Standards:** A significant number of digital products lack robust cybersecurity features, and many do not receive timely security updates, leaving them exposed to potential threats.
- **Consumer and Business Challenges:** Consumers and businesses often struggle to identify which products are secure.
- **Need for Lifecycle Security:** There is a necessity for manufacturers and retailers to ensure cybersecurity throughout the entire lifecycle of their products.
- **Market Confidence:** By implementing mandatory cybersecurity requirements and CE marking, the CRA aims to help buyers make informed decisions, fostering trust in the cybersecurity of digital products.

Motivation: For safer and more secure digital products

"I am convinced that there are only two types of companies: those that have been hacked and those that will be. And even they are converging into one category: companies that have been hacked and will be hacked again."

Robert S. Mueller III,
6th Director of the Federal Bureau of Investigation (FBI)



Founding “Pillars” of new cybersecurity Standards

EU Security Union Strategy

What is the strategy about?

- The **EU Security Union Strategy** (2020–2025) was launched to **safeguard EU citizens** and uphold the European way of life.
- In April 2025, it was replaced by **ProtectEU**, the EU’s new internal security strategy.
- **ProtectEU** focuses on enhancing the EU’s ability to counter **terrorism, organized crime, cybercrime, and hybrid threats**, both online and offline.
- A key pillar of the original strategy emphasized **future-proofing security**, including the protection of public spaces, critical infrastructure, and addressing cybersecurity threats.



One Solution: The EU Cyber Resilience Act

EU Cyber Resilience Act (CRA)

Link:

[Regulation - 2024/2847](#)
[- EN - EUR-Lex](#)



Document Code : 32024R2847



Timeline

- Adopted: 23 October 2024, enforced 20 November 2024
- Compliance: 36 months after adoption



Applies To

- All Products with Digital Elements



Amends

- Regulation (EU) No 168/2013
- Regulation (EU) 2019/1020
- Directive (EU) 2020/1828



Languages

- Available in all 24 official EU languages

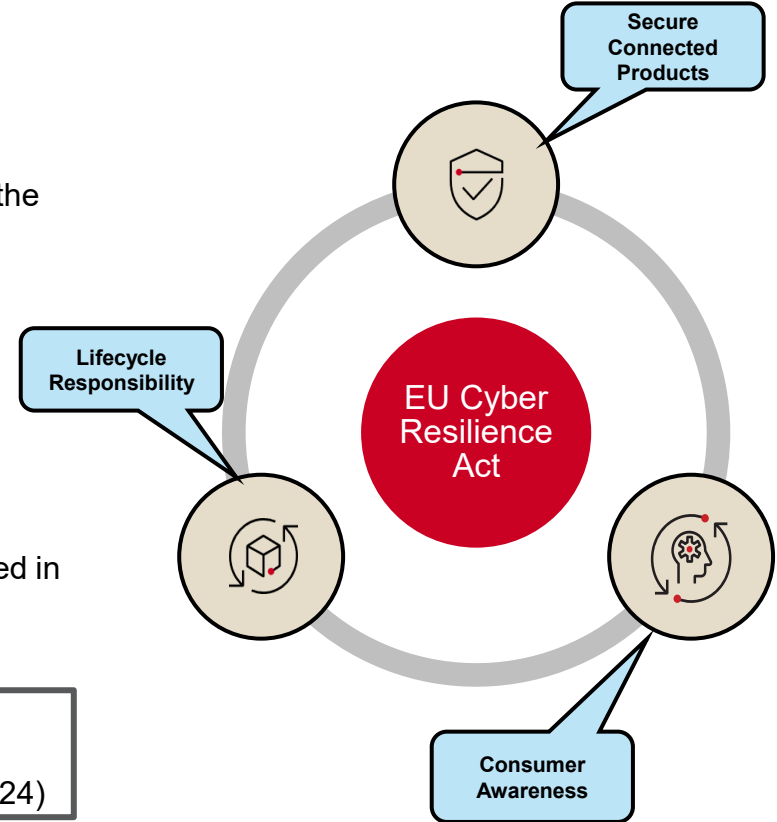
The EU Cyber Resilience Act

- Objectives include:
 - Enhancing **security in wired and wireless products** connected to the internet.
 - Maintain its **responsibility to manufacturers, importers, and distributors** for the cybersecurity of a product throughout its lifecycle.
 - Properly **informing consumers** about the cybersecurity features of the products they purchase and use.
- **Only products meeting essential cybersecurity requirements** outlined in CRA Annex I **are permitted on the EU market**.

Implementation timeline

September 2026: Start reporting

December 2027: Full applicability (36 months after adoption in 2024)



Scope of CRA

- The EU's Cyber Resilience Act (EU) 2024/2847 applies to a large group of products, **with digital elements** placed on the EU market, **regardless of where the manufacturer is based**, that can connect directly or indirectly to other devices or networks, including:

Hardware Products

(e.g. internet-of-things (IoT) devices, smart home appliances, industrial control systems, microchips);

Software Products

(e.g. video games, apps, computer programs).

Extends cybersecurity requirements to also apply to **data processing solutions, operating systems, browsers, password management software and certain microprocessors and microcontrollers**



CRA does not Apply to these Products



Certain Vehicles



Marine Equipment



In-vitro Diagnostic Devices



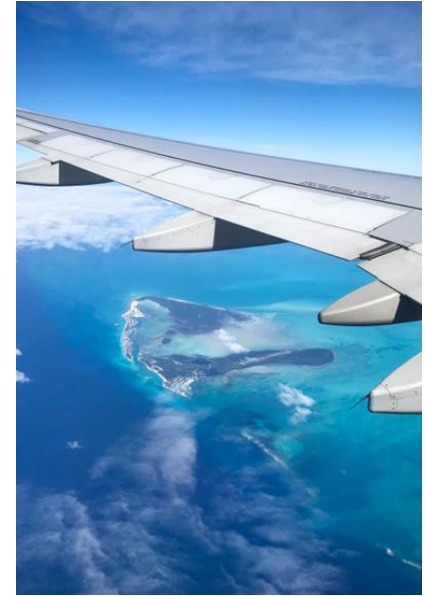
Products intended for National security



Products intended for Defense



Products intended for processing classified material



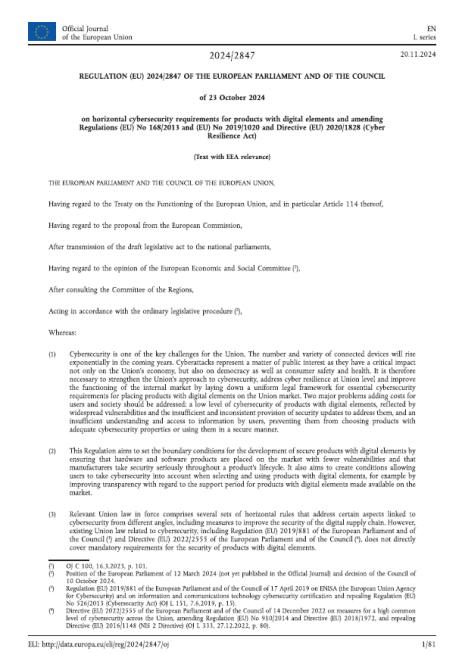
Aircraft



These products are already subject to their own sector-specific cybersecurity regulations, but do not apply to the industries in general (only specific regulations are excluded from CRA).

Content Overview of the EU Cyber Resilience Act

Regulation (EU) 2024/2847 has total 81 pages,
including following contents:



1st page of CRA

Preamble

Enacting Terms – Chapter 1-VIII

Concluding Formulas

Annex I
CS essential
requirements

Annex II
Info and
instruction to
users

Annex III
Important
PwDE*

Annex IV
Critical
PwDE

Annex V EU
Clarification of
conformity

Annex VI
Simplified
clarification of
conformity

Annex VII
Contents of
technical
documentation

Annex VIII
Conformity
assessment



CRA: Enacting Terms - Chapter overview

- **Chapter I – General Provisions:** Scope, Definitions, Cybersecurity Requirements, Product classification, Cybersecurity Skills, General Product Safety and High Risk AI systems.
- **Chapter II: Obligations of Economic Operators:** Responsibilities of manufacturers, importers, distributors, and authorized representatives.
- **Chapter III: Conformity of Products:** Procedures for conformity assessments, CE marking, and technical documentation.
- **Chapter IV: Notification and Market Surveillance:** Rules for reporting vulnerabilities and incidents, and mechanisms for market oversight.
- **Chapter V: Enforcement:** Penalties, compliance checks, and enforcement mechanisms.
- **Chapter VI: Delegated and Implementing Acts:** Powers granted to the European Commission to update and enforce the regulation.
- **Chapter VII: Final Provisions:** Transitional arrangements, entry into force, and review clauses.

Key Takeaways

Scope and Coverage

- Applies to **products with digital elements (PwDE)** placed on the EU market
- Includes **both hardware and software**, plus remote data processing solutions

Mandatory Cybersecurity Requirements

- Security by design
- Vulnerability management
- Incident reporting
- Traceability: SBOM (Software Bill of Materials) creation
- Product support and updates

Lifecycle Responsibilities

- Obligations for **manufacturers, distributors, and importers**
- Cybersecurity requirements covering **the entire product lifecycle**, from design to end of life

Compliance and Enforcement

- Differentiated **conformity assessment methods** depending on product category
- Risk of non-compliance fines **up to EUR 15 million or 2.5% of worldwide turnover**



EUR-Lex / Cyber Resilience Act 2024/2847



[Regulation - EU - 2024/2847 - EN - EUR-Lex](#)

Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. **Legal and Standardization Framework from EU
Supporting CRA**
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Topics

1. Interaction with existing EU rules
2. Types of Legal Acts
3. European Commission's request for standardization
4. What happens if your products do not comply with the CRA?



Topics

1. **Interaction with existing EU rules**
2. Types of Legal Acts
3. European Commission's request for standardization
4. What happens if your products do not comply with the CRA?



Interaction with Existing EU Rules



Unified Cybersecurity Requirements

One regulation for all digital products.



No Overlap with Existing Laws

CRA avoids conflicting or duplicate obligations.



Simplified Market Access

Easier entry for businesses to EU countries.

Before: Fragmented Laws

Multiple, disparate cybersecurity requirements across member states.



After: Harmonized CRA Pathway

A single, clear framework for all products with digital elements in the EU

Topics

1. Interaction with existing EU rules
2. **Types of Legal Acts**
3. European Commission's request for standardization
4. What happens if your products do not comply with the CRA?



What is an EU regulation? / Types of Legal Acts



Regulations

Uniformly applicable and directly binding in all member states.

No need for each member state to pass a separate national law.

Examples:

- EU Data Act
- EU AI Act
- EU Machinery Regulation



Directives

Bind member states to a **result**, but they choose how to implement it into national law.

Businesses may face slightly different obligations depending on the country.

Examples:

- NIS 2 Directive
- RED Radio Equipment Directive



CRA

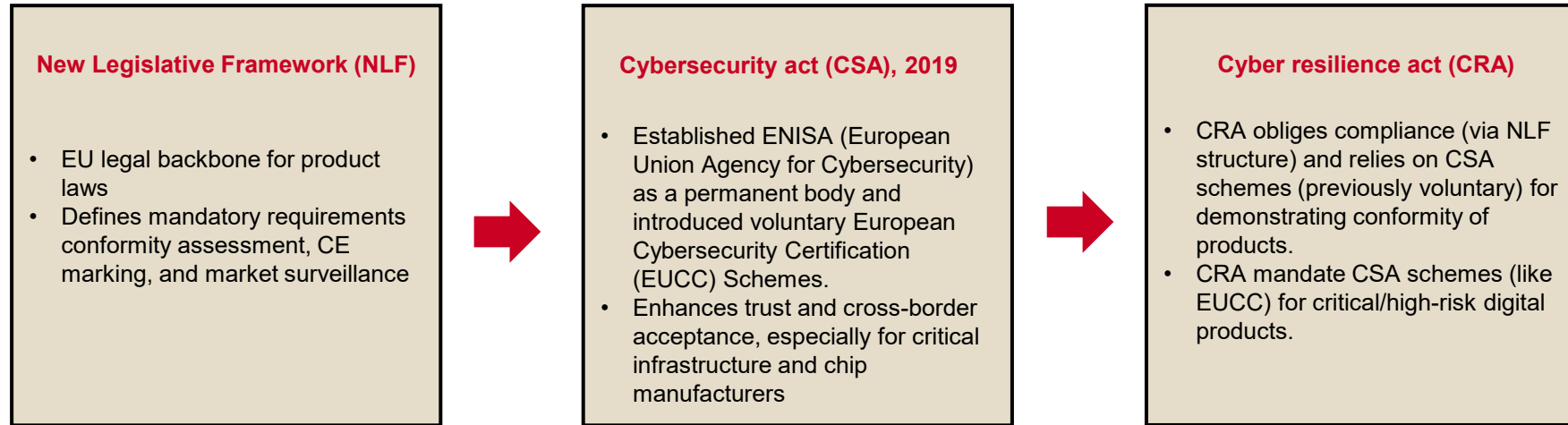
[More Details see: Types of EU Legal Acts](#)

Topics

1. Interaction with existing EU rules
2. Types of Legal Acts
3. **European Commission's request for standardization**
4. What happens if your products do not comply with the CRA?



European Commission's request for standardization



CSA's voluntary schemes become leveraged as mandatory references under CRA for certain high-risk categories.

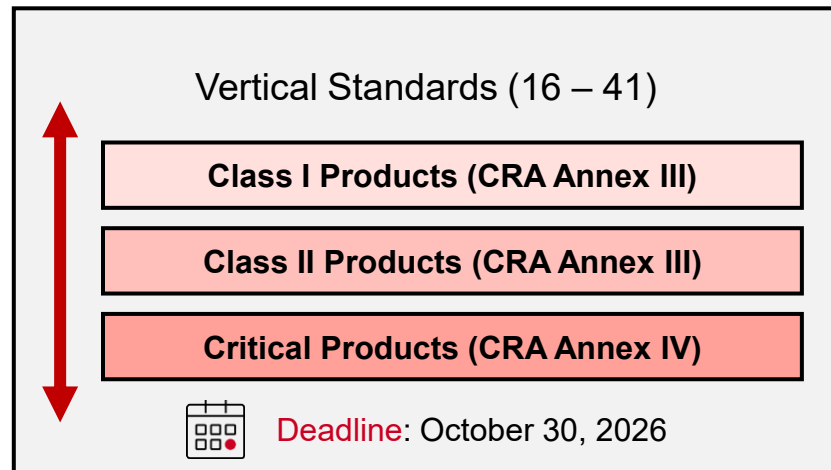
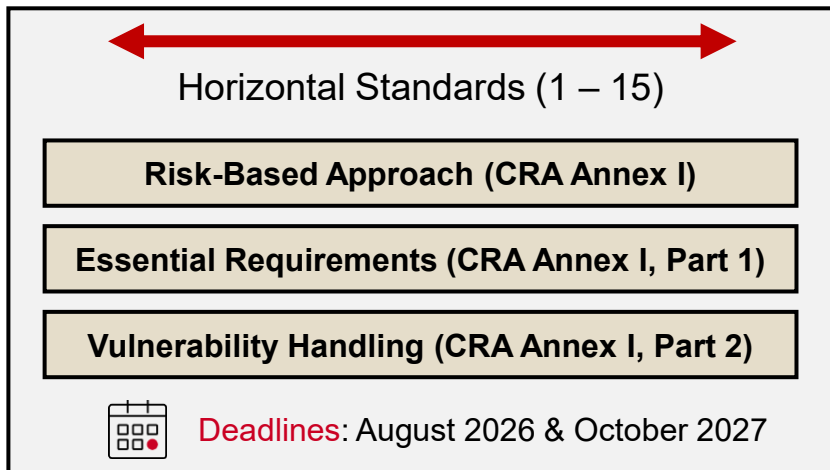
European Commission's request for standardization

More guidance for implementation is on its way

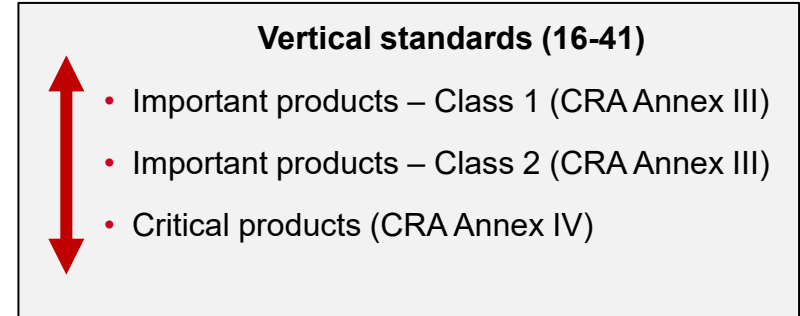
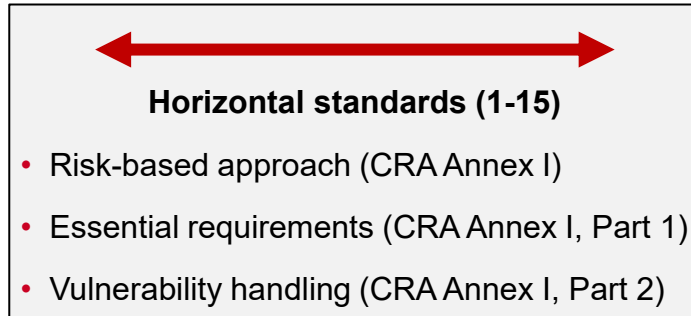
- The **European Commission** has requested **CEN, CENELEC and ETSI** to develop **41 harmonized standards** for CRA compliance.
- The goal is **to align cybersecurity requirements across industries**: IOT, Industrial, etc. as well as their supply chain such as chip vendors, and components.



Source: Cen cenelec website



CRA – Horizontal and Vertical Standards



- **Definition:** **Cross-sectoral standards** that apply to all products with digital elements (PDEs) covered by the CRA, regardless of their specific function or industry.
- **Purpose:** To establish baseline cybersecurity requirements and vulnerability handling practices that are universally applicable.
- **Number:** 15 horizontal standards
- **Examples:** Risk based Cybersecurity design, Vulnerability handling processes

- **Definition:** These are **product-specific standards** tailored to particular categories of digital products classified as Important Class I, Important Class II, or Critical Class.
- **Purpose:** To provide detailed technical specifications for cybersecurity in specific product types.
- **Number:** 26 vertical standards
- **Examples:** Cybersecurity requirements for embedded browsers

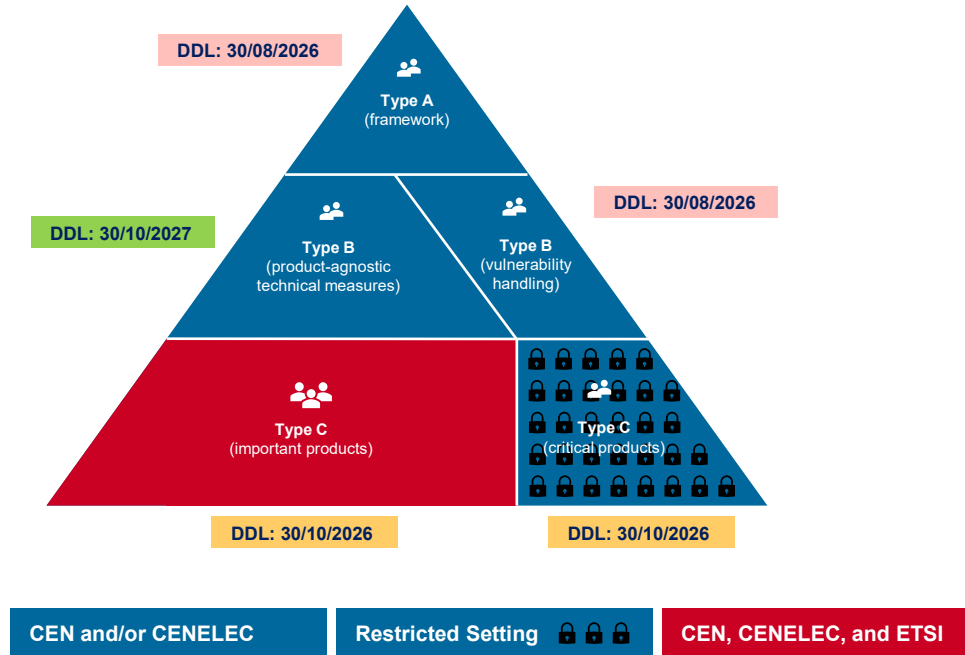
CRA Product Categories – more details

Category	Definition	Why it matters	Examples
Default Products	Products with digital elements that are not listed in Annexes III or IV and do not have important or critical cybersecurity vulnerabilities.	Self-Assessment with Annex I requirements	Photo editing software, text processing software, hard drives and games etc.
Important Products: Class I	Products performing important cybersecurity functions but with a lower risk compared to Class II; significant cybersecurity risk profile. This means digital-element products where security is important to protect data, privacy, and operation, but not the highest assurance level.	Standard security requirements. Protects users and data	Identity management systems and hardware, browsers, password managers, antivirus software, VPN software, routers, modems, OS, smart lock.
Important Products: Class II	Products performing critical cybersecurity functions or posing high potential adverse effects if compromised; crucial for the security of other systems and services. This means digital-element products needing higher security assurance due to greater exposure or impact, but not at critical-risk level	Stricter assessment. Higher impact if compromised.	Hypervisors, container runtime systems, firewalls, intrusion detection systems, tamper-resistant microprocessors, hardware with security boxes.
Critical Products	Products with digital elements having core functionality of a category in Annex IV, requiring a European cybersecurity certificate. Digital-element products whose security must prevent significant harm to safety, public interest, or critical infrastructure; require heightened security and robust assurance.	Most stringent requirements. Systematic risk if it fails.	Smart cards, secure elements, smart meter gateways, hardware security module (HSM).

Harmonized Standards Overview

M/606	Topic (Main Area)	TC ref.	Technical Committee(s)	TC title	Standard title	Last revised stage	Deadline for adoption	
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks								
1		CEN-CLC/TC 13 WG 9		Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/06/30	
Lines 2-14: European standard(s) on essential cybersecurity requirements								
2 to 14		CEN-CLC/TC 13 WG 9		Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30	
Line 15: European standard(s) on vulnerability handling for products with digital elements								
15		CEN-CLC/TC 13 WG 9		Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Vulnerability Handling	10.99 - NWI - New Work Item adopted	2026/06/30	
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers								
16		CEN/TC 224 WG 17		Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectoral environment	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers – criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30	
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers								
17a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30	
17b		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30	
Line 18: European standard(s) on essential cybersecurity requirements for password managers								
18		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30	
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software								
19		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30	
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)								
20a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30	
20b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 21: European standard(s) on essential cybersecurity requirements for network management systems								
21a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30	
21b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 22: European standard(s) on essential cybersecurity requirements for Security information and event management (SIEM) systems								
22a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for Security information and event management (SIEM) systems	PWI - Proposed Work Item created	2026/10/30	
22b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for security information and event management (SIEM) systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 23: European standard(s) on essential cybersecurity requirements for boot managers								
23		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for boot managers	PWI - Proposed Work Item created	2026/10/30	
Line 24: European standard(s) on essential cybersecurity requirements for public key infrastructure and digital certificate issuance software								
24		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for public key infrastructure and digital certificate issuance software	TC decision taken	2026/10/30	
Line 25: European standard(s) on essential cybersecurity requirements for physical and virtual network interfaces								
25a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for physical and virtual network interfaces	TC decision taken	2026/10/30	
25b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for physical and virtual network interfaces (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 26: European standard(s) on essential cybersecurity requirements for operating systems								
26		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for operating systems	PWI - Proposed Work Item created	2026/10/30	
Line 27: European standard(s) on essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches								
27a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches	PWI - Proposed Work Item created	2026/10/30	
27b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for routers, modems intended for the connection to the internet, and switches (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 28 & Line 29: European standard(s) on essential cybersecurity requirements for microprocessors with security-related functionalities & European standard(s) on essential cybersecurity requirements for microcontrollers with security-related functionalities								
28, 29		CLC/TC 47X WG 1		Semiconductors and Trusted Chips Implementation	Cybersecurity requirements for microprocessors and microcontrollers with security-related functionalities	10.99 - NWI - New Work Item adopted	2026/10/30	
Line 30: European standard(s) on essential cybersecurity requirements for application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities								
30		CLC/TC 47X WG CRA		Semiconductors and Trusted Chips Implementation	Semiconductors and Trusted Chips Implementation	European standard(s) on essential cybersecurity requirements for application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities	TC decision taken	2026/10/30
Line 31: European standard(s) on essential cybersecurity requirements for smart home general purpose virtual assistants								
31		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for smart home general purpose virtual assistants	PWI - Proposed Work Item created	2026/10/30	
Line 32: European standard(s) on essential cybersecurity requirements for smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems								
32		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems	PWI - Proposed Work Item created	2026/10/30	
Line 33: European standard(s) on essential cybersecurity requirements for Internet connected toys covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features								
33		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for Internet connected toys covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features	Work item sent for adoption	2026/10/30	
Line 34: European standard(s) on essential cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/746 or Regulation (EU) 2017/746 do not apply or personal wearable products that are intended for the use by and for children								
34		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/746 or Regulation (EU) 2017/746 do not apply or personal wearable products that are intended for the use by and for children	Work item sent for adoption	2026/10/30	
Line 35: European standard(s) on essential cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments								
35		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments	TC decision taken	2026/10/30	
Line 36: European standard(s) on essential cybersecurity requirements for firewalls, intrusion detection and/or prevention systems								
36a		ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR		European standard(s) on essential cybersecurity requirements for firewalls, intrusion detection and/or prevention systems	TC decision taken	2026/10/30	
36b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security Profile for firewalls and intrusion detection and prevention systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 37 & 38: European standard(s) on essential cybersecurity requirements for tamper-resistant microprocessors & European standard(s) on essential cybersecurity requirements for tamper-resistant microcontrollers								
37, 38		CLC/TC 47X WG 2		Semiconductors and Trusted Chips Implementation	Cybersecurity requirements for tamper-resistant microprocessors and microcontrollers	10.99 - NWI - New Work Item adopted	2026/10/30	
Line 39: European standard(s) on essential cybersecurity requirements for Hardware Devices with Security Boxes								
39		CEN/TC 224 WG 17		Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectoral environment	Cybersecurity requirements for Hardware Devices with Security Boxes	TC decision taken	2026/10/30	
Line 40: European standard(s) on essential cybersecurity requirements for smart meter gateways within smart metering systems as defined in Article 2 (23) of Directive (EU) 2019/944 and other devices for advanced security purposes, including for secure cryptoprocessing								
40		CEN-CLC/TC 13 WG 6		Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Smart Meter Gateway	TC decision taken	2026/10/30	
Line 41: European standard(s) on essential cybersecurity requirements for smartcards or similar devices, including secure elements								
41a		CLC/TC 47X WG 3		Semiconductors and Trusted Chips Implementation	Cyber Resilience of EUCC certified platforms of Smart Cards and Similar Devices Including Secure Elements	10.99 - NWI - New Work Item adopted	2026/10/30	
41b		CEN/TC 224 WG 17		Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectoral environment	Smartcards, similar devices and Secure Elements – criteria to achieve conformity with essential requirements of Regulation (EU) 2024/2847	TC decision taken	2026/10/30	
Complementary/Supporting deliverables								
Broad vertical supporting OT deliverables								
20b, 21b, 22b, 25b, 27b, 36b		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements	10.99 - NWI - New Work Item adopted	2026/10/30	
		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components	10.99 - NWI - New Work Item adopted	2026/10/30	
		CLC/TC 65X WG 3		Industrial-process measurement, control and automation	Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels	10.99 - NWI - New Work Item adopted	2026/10/30	
Technical reports/specifications in support								
2 to 14		CEN-CLC/TC 13 WG 9		Cybersecurity and Data Protection	Cybersecurity requirements for products with digital elements – Threats and Security Objectives	TC decision taken	2026/10/30	
		CEN-CLC/TC 13 WG 6		Cybersecurity and Data Protection	Guidance for the application of EN 18037 in support of the CRA	To be proposed	2026/10/30	
		CEN-CLC/TC 13 WG 6		Cybersecurity and Data Protection	Documentation of the EN 18037 assessment results for the Consumer IoT market sector	To be proposed	2026/10/30	

Request for standardization - Deliverables



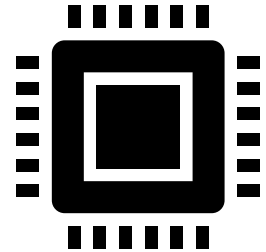
- Type “A” horizontal framework:
Topic 1 – Principles for cyber resilience
- Type “B”:
Topic #2-14 – Generic Security Requirements (product agnostic)
Topic 15 – Vulnerability Handling
- Type “C”:
Topic 16-38 – Important Products &
Topic 39-41 – Critical Products

Source: DG CNECT presentation for CoS (2024-11)

Cenelec/TC 47X - Semiconductors and Trusted Chips – planned harmonized standards

CLC/TC 47X supports the development and adoption of **trustworthy semiconductor devices** and **trusted chips** in the EU, emphasizing security, privacy, and cyber resilience:

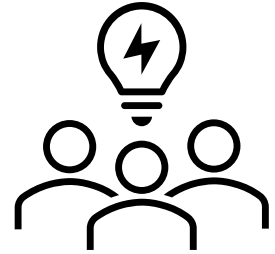
- European standard(s) on essential cybersecurity requirements for **tamper-resistant microprocessors** and **microcontrollers** (lines 37 & 38)
- European standard(s) on essential cybersecurity requirements for **microprocessors** and **microcontrollers** with **security-related** functionalities (lines 28 & 29)
- European standard(s) on essential cybersecurity requirements for application specific integrated circuits (**ASIC**) and field-programmable gate arrays (**FPGA**) security-related functionalities (line 30)
- European standard(s) on essential cybersecurity requirements for **smartcards** or similar devices, including secure elements (shared with CEN/TC 224) (line 41)



Cenelec/TC 47X - Working groups

Working Group 01 (WG 01):

- developing standards to enable **self-assessment of CRA compliance** for microcontrollers (MCUs) and microprocessors (MPUs) that provide security functions without tamper-resistance claims (only basic security functions)
- builds upon existing standards such as **SESIP** (Security Evaluation Standard for IoT Products) and
- aims to identify relevant protection profiles and address gaps in the CRA's cybersecurity essential requirements.



Working Group 02 (WG 02):

- defining standards for **third-party assessment of CRA compliance** for MCUs and MPUs with tamper resistance
- also builds upon **SESIP** and aims to identify gap in CRA

Topics

1. Interaction with existing EU rules
2. Types of Legal Acts
3. European Commission's request for standardization
4. **What happens if your products do not comply with the CRA?**



What happens if your products do not comply with the CRA?



Imposition of fines

Up to **€15 million** or **2.5%** of global annual turnover, whichever is higher.

Applies to: **Class I** & **Class II** Products



Market withdrawal or distribution restrictions

Authorities may **order the withdrawal of a non-compliant product** from the market or restrict its distribution.

Market sweeps will detect non-compliance.



Product Recall

In serious cases, a **complete withdrawal or recall of the product** may be required.

Mandatory: For products posing a severe cybersecurity risk.

Details, see Article 64: https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=OJ:L_202402847

Enforcement Penalties under the CRA I

- Member States must **define and enforce penalties** for CRA breaches.
- Penalties must be **effective, proportionate, and dissuasive**.
- European Commission must be **notified of national penalty rules** and any updates.

Severe Breaches of Essential Requirements	➡	Covers: Annex I obligations + Articles 13 & 14	up to €15 million or 2.5% of global annual turnover (whichever is higher).
Other Key Breaches	➡	Covers: Articles 18–23, 28, 30–33, 39, 41, 47, 49, 53.	up to €10 million or 2% of global annual turnover (whichever is higher).
False or Misleading Information	➡	Applies when false, incomplete, or misleading information is provided to MSAs or notified bodies.	up to €5 million or 1% of global annual turnover (whichever is higher).

Administrative Fines and Enforcement under the CRA

Exemptions & Special Rules

- **Micro & Small Enterprises** → exempt from fines for missing the 24-hour early warning notification on critical vulnerabilities
- **Open-Source Stewards** → fully exempt from fines under this Regulation
- **Individuals (non-business users)** → fines should reflect local income levels and personal financial situation
- **Public Authorities** → Member States decide whether fines apply



Enforcement Penalties under the CRA

Penalty depends on

- **Nature & severity** of the breach (e.g., critical security flaw vs. reporting delay).
- **Duration** of non-compliance.
- **Consequences** for consumers, businesses, and cybersecurity resilience.
- **Prior penalties** or enforcement actions applied to the same operator by any EU authority.

Company Size & Market Presence is considered

- Consideration of **micro**, **small**, and **medium-sized enterprises** (SMEs), including start-ups.
- Ensures penalties remain **proportionate** to the economic operator's capacity.
- Regarding **Public Authorities** Member States decide whether fines apply.
- **Individuals (non-business users)** fines should reflect local income levels and personal financial situation.

Key Takeaways

- After an EU harmonization: There is a **single, clear framework** for all product with digital elements in the EU.
- The goal is to **align cybersecurity requirements across industries**: IOT, Industrial, etc. as well as their supply chain such as chip vendors, and components.
- ↔ • The **horizontal standards** can be directly applied **to all products** that fall under the scope of the CRA.
- ↕ • The **vertical standards** are specific to product types that fall into the **Important Class I, Important Class II** and **Critical Class** categories.
- Implementation **timeline**:
 - Sep 2026: Start reporting
 - Dec 2027: Full applicability (36 months after adoption in 2024)



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. **CRA within the Global Cybersecurity Landscape**
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Exercise: Brainstorming of Cybersecurity Regulations, Standards etc.



Identify and discuss cybersecurity regulations, standards, and frameworks:

1. “Which cybersecurity standards, frameworks, or regulations do you know?”
2. “Which ones are used in your team or region?”
3. “Which ones could support compliance/have overlaps with CRA?”



Topics

1. **EU Legal Instruments**
2. **CRA Harmonized standards**
 - EU Data Act
 - EU AI Act
 - EU Machinery Regulation
 - NIS 2 Directive
 - RED Radio Equipment Directive
3. **Cybersecurity laws in other regions**



What is an EU regulation? / Types of Legal Acts



Regulations

Uniformly applicable and directly binding in all member states.
No need for each member state to pass a separate national law.

Examples:

- EU Data Act
- EU AI Act
- EU Machinery Regulation



Directives

Bind member states to a **result**, but they choose how to implement it into national law.

Businesses may face slightly different obligations depending on the country.

Examples:

- NIS 2 Directive
- RED Radio Equipment Directive



CRA

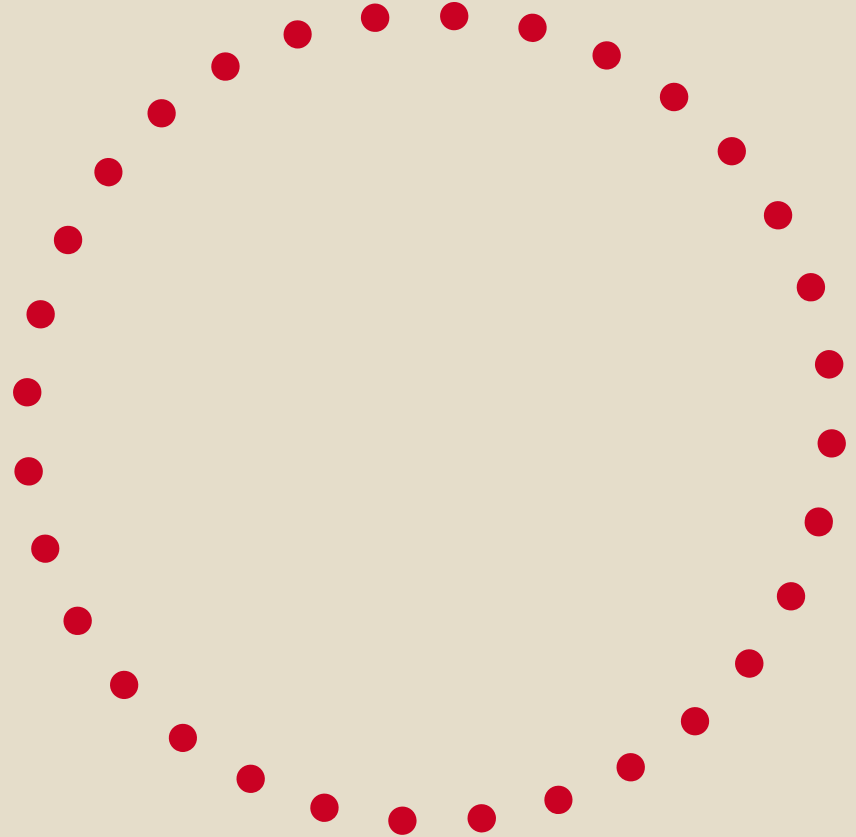
[More Details see: Types of EU Legal Acts](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - **EU Data Act**
 - EU AI Act
 - EU Machinery Regulation
 - NIS 2 Directive
 - RED Radio Equipment Directive
3. Cybersecurity laws in other regions



EU Data Act



Regulation EU Data Act

- Regulation (EU) 2023/2854 of the European Parliament and of the Council of 13 December 2023 on **harmonized rules on fair access to and use of data**
- The Data Act is a key pillar of the European data strategy and it will make a significant contribution to advancing digital transformation.
- The Data Act is designed to consumers and businesses — by giving them greater control over the data generated by their connected devices, such as cars, smart TVs, and industrial machinery.



EU regulation Data Act: Implementation

Data Act

is a cross-sectoral piece of legislation

(i.e. it lays out principles and guidelines that apply to all sectors).

Link:

[Regulation - 2023/2854 - EN - EUR-Lex](#)



Document Code : 32023R2854



Timeline

- The Data Act is applicable from 12 September 2025



Applies To

- Manufacturers of connected products and providers of related services placed on the EU market



Evaluation

- Within 3 years of its entry into application, the Commission will carry out an evaluation of the impact of the Data Act (if necessary, an amendment to the Act will be proposed).



Languages

- Available in all 24 official EU languages

EU regulations: Data Act and the Cyber Resilience Act

Both the EU Data Act and the EU CRA are EU regulations, which means that they apply directly to all EU member states.

The **Data Act** aims to **make data generated by products more accessible to users**,

while the **CRA** ensures that these **products are secure and protected from cyber threats** by requiring CE marking and conformity assessments.

- The **Data Act** focuses on user data access and sharing rights for connected products.
- The **CRA** mandates cybersecurity requirements throughout the product lifecycle.

Focus on different
areas



User rights to access, use and share data generated by connected products.



Cybersecurity of products with digital elements.

EUR-Lex / Data Act 2023/2854



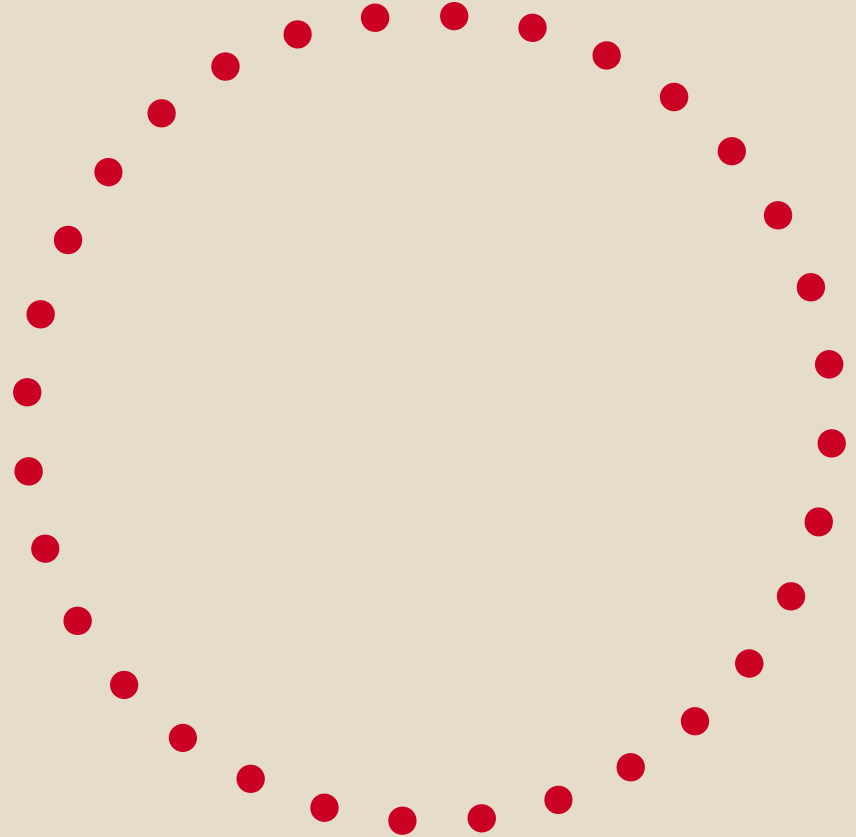
[Regulation - EU - 2023/2854 - EN - EUR-Lex](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - EU Data Act
 - **EU AI Act**
 - EU Machinery Regulation
 - NIS 2 Directive
 - RED Radio Equipment Directive
3. Cybersecurity laws in other regions



EU AI Act



The EU Artificial Intelligence Act

What is the aim of the regulation?

To encourage the development and uptake of **safe and trustworthy artificial intelligence (AI) systems** across the EU:

- In both **private** and **public** sectors
- The regulation sets out **risk-based rules** on (key content):
 - Placing on the market, putting into service and using certain AI systems,
 - Requirements and obligations around high-risk AI systems,
 - Transparency and risk management for general-purpose AI models
 - Market monitoring, market surveillance, governance and enforcement
 - Supporting innovation.



EU AI Act

EU AI Act

1. **Act** – EU AI Act
2. **What it is:** Although called an “Act,” the EU AI ACT is a **Regulation**. It will apply directly across the EU once in force.
3. **Purpose:** Establish a risk-based framework for AI regulation and ensure safe, transparent, and trustworthy AI aligned with EU values.
4. **Impact:** On all systems that include AI

CRA

vs

EU AI Act

1. **Similarity:** CRA and AI Act both require
 - incident reporting,
 - risk assessments, and
 - secure development.
2. **Relation:**
 - the CRA secures AI-enabled products;
 - the AI Act governs **how** AI systems **are developed, deployed, and monitored**
3. **Example:** A high-risk AI medical diagnostic tool must meet CRA’s product security **and** AI Act’s transparency and risk management obligations.

EUR-Lex / Artificial Intelligence Act (AI Act) 2024/1689



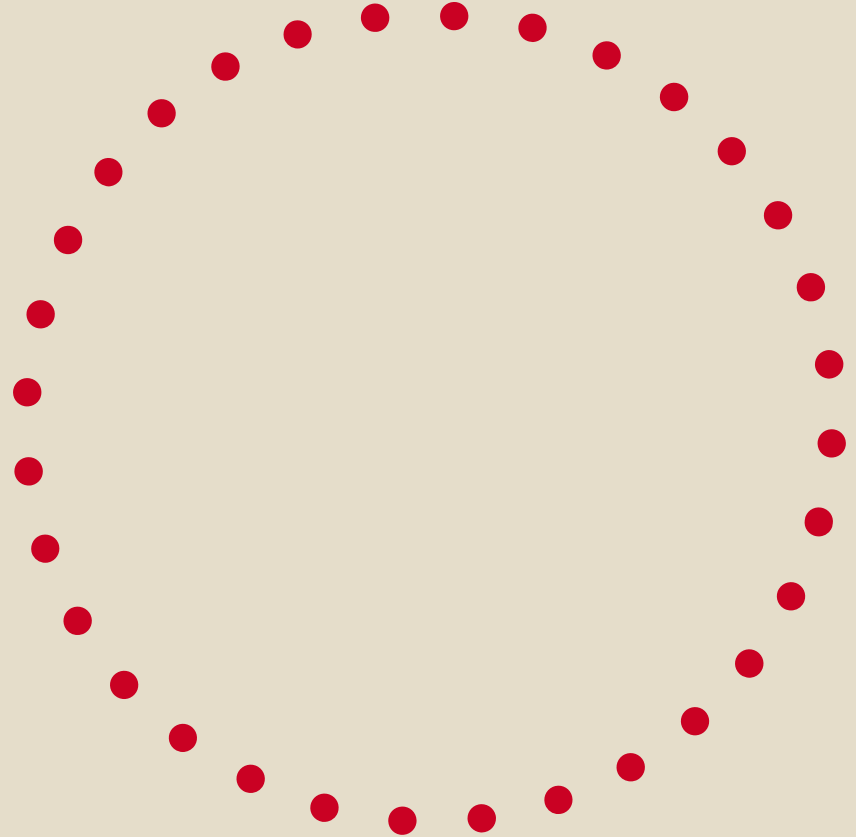
[Regulation - EU - 2024/1689 - EN - EUR-Lex](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - EU Data Act
 - EU AI Act
 - **EU Machinery Regulation**
 - NIS 2 Directive
 - RED Radio Equipment Directive
3. Cybersecurity laws in other regions



EU Machinery Regulation



EU regulations regarding machinery safety

The **new machinery regulation 2023/1230** replaces the **old machinery directive 2006/42/EC**.

Purpose and content:

1. Ensure that design, manufacture and operation, including risk assessment in machinery comply with safety standards.
2. The new regulation expands the scope and application of the current regulation with more specific machine safety provisions, giving more legal clarity through well-defined requirements.
3. From January 2027, the new Regulation becomes mandatory, and all economic operators must apply it.



Machinery Regulation (EU) 2023/1230 and the EU CRA

Both the CRA and the Machinery Regulation are EU regulations, which means that they apply directly to all EU member states.

- There is a common legal framework for all these regulations, the **New Legislative Framework**. The CRA and the Machinery Directive therefore have a common basis.
- The display of conformity is given through the **CE mark**.
- EU CRA applies from 11 December 2027 (reporting of exploited vulnerabilities from 11 September 2026).
- Machinery Regulation applies from 20 January 2027.
- The core of both regulations are certain **requirements for products** within their scope.
 - In the **CRA** they are listed in **Annex I**,
 - in the **Machinery Regulation** in **Annex III**.



Shared legal framework



Intend to ensure that the same safety standards apply to products in all member states.

EUR-Lex / Machinery Regulation 2023/1230



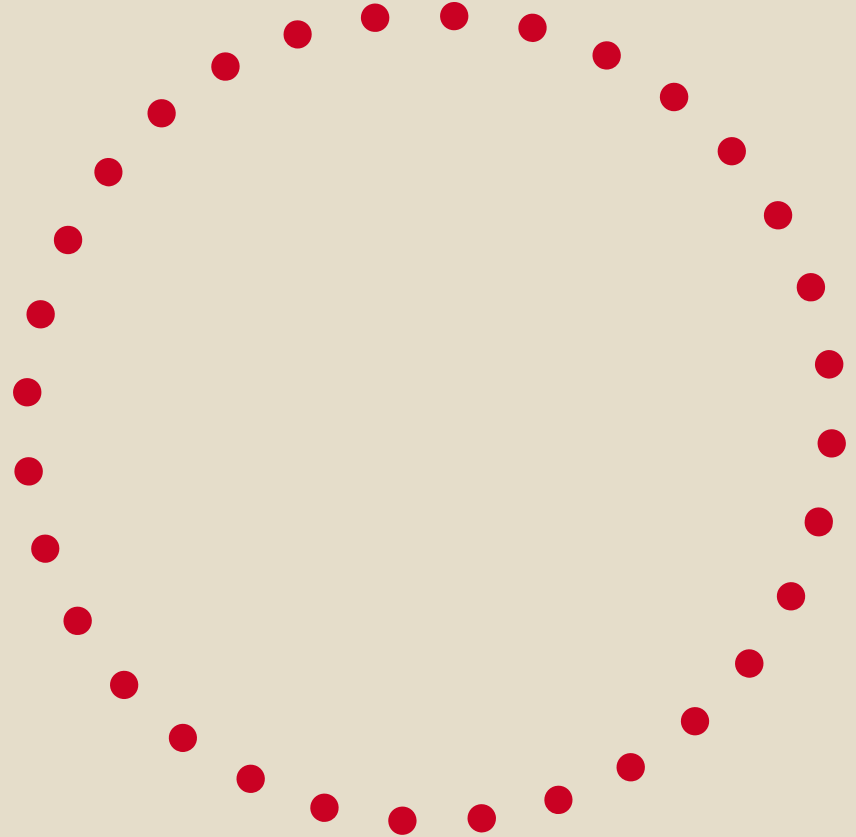
[Regulation - EU - 2023/1230 - EN - EUR-Lex](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - EU Data Act
 - EU AI Act
 - EU Machinery Regulation
 - **NIS 2 Directive**
 - RED Radio Equipment Directive
3. Cybersecurity laws in other regions



NIS 2 Directive



CRA and NIS 2 Directive

Rules on the security of **N**etwork and **I**nformation **S**ystems / **NIS** 2 Directive

- The **Cyber Resilience Act** complements the **NIS 2 Directive**, adopted by the EU Parliament and Council.
- The NIS 2 Directive puts in place cybersecurity requirements, including **supply chain security measures**.
- Sets **mandatory incident reporting** for essential and important entities.
- Aims to strengthen the **resilience of digital products and services** across the EU.



Identification of Incidents



Timely Reporting



Systemic Response & Improvement

Comparison – NIS 2 Directive and CRA

Aspect	NIS2 Directive	Cyber Resilience Act (CRA)
Legal form	EU Directive (requires transposition into national law)	Regulation (directly applicable across EU)
Scope	Organizational cybersecurity across 18 critical sectors (infrastructure and services)	Product cybersecurity for digital products (hardware/software)
Target Entities	Essential and important entities (banks, energy, healthcare, transport, etc.)	Manufacturers, importers, distributors of products with digital elements
Core requirements	Risk management, incident reporting, supply chain security, governance accountability	Secure-by-design, secure-by-default, vulnerability handling, updates, incident reporting documentation, CE marking
Certification	No official product labels	CE-mark required; self-assessment and technical documentation mandated
Reporting	Significant cybersecurity incidents within ~24 h + detailed reports	Exploited vulnerabilities/incidents within 24 h

Comparison – NIS 2 Directive and CRA

Aspect	NIS2 Directive	Cyber Resilience Act (CRA)
Legal form	EU Directive (requires transposition in national law)	Regulation (directly applicable across EU)
Scope	Organizational cybersecurity and digital resilience of critical sectors (infrastructure and essential services)	Digital products and services
Target Entities	Essential and important entities in critical sectors (energy, healthcare, transport, etc.)	Manufacturers of digital products with significant impact
Core requirements	Risk management, incident response, supply chain security, governance, accountability	Security by design, security of supply, incident response, documentation, technical measures
Certification	No official product labels	Technical documentation mandated
Reporting	Significant cybersecurity incidents within 24 h + detailed reports	Exploited vulnerabilities/incidents within 24 h



CRA is highly relevant to organizations governed by NIS 2, because even if an organization is obligated under NIS 2, it must also ensure that the digital products it uses, distributes, or develops comply with CRA requirements.

EUR-Lex / NIS 2 Directive 2016/1148



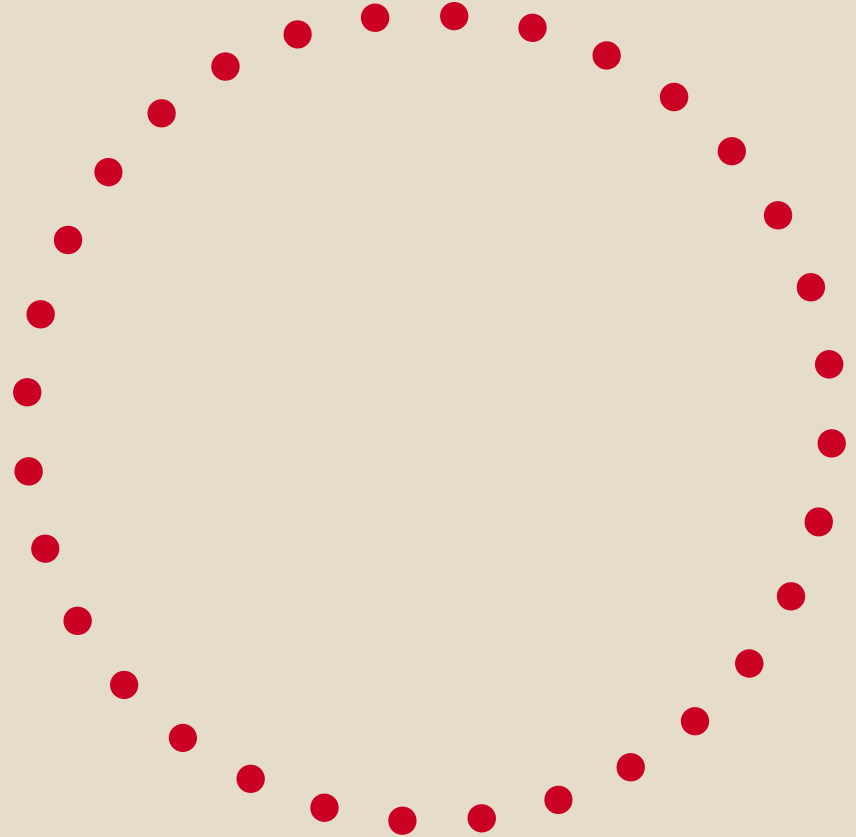
[Directive - EU - 2016/1148 - EN - EUR-Lex](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - EU Data Act
 - EU AI Act
 - EU Machinery Regulation
 - NIS 2 Directive
 - **RED Radio Equipment Directive**
3. Cybersecurity laws in other regions



Radio Equipment Directive (RED)



CRA and Radio Equipment Directive (RED)

Delegated Regulation under the Radio Equipment Directive (RED)

- The Cyber Resilience Act applies to radio equipment in scope of the Delegated Regulation adopted under the Radio Equipment Directive 2014/53/EU (RED Delegated Regulation).
- The Cyber Resilience Act is aligned with the requirements of the RED Delegated Regulation, including the specific requested standards under the RED Delegated Regulation.



Protection from fraud



**Protection of personal data
and privacy**



**Obligations
of manufacturers,
importers/distributors**

RED and CRA

Aspect	Radio Equipment Directive (RED)	Cyber Resilience Act (CRA)
Legal form	EU Directive (transposed into national law)	Regulation (directly applicable across EU)
Scope	Ensure safety, electromagnetic compatibility, and efficient radio spectrum use for radio equipment	Product cybersecurity for digital products (hardware/software)
Target Entities	RED requires CE-marking, testing, and conformity assessment, enforced through Member States	Manufacturers, importers, distributors of products with digital elements
Core requirements	Safe operation, EM interference, effective use of spectrum, essential requirements for radio operation	Secure-by-design, secure-by-default, vulnerability handling, updates, incident reporting documentation, CE marking
Certification	CE mark required under RED for radio and safety conformity	CE-mark required; self-assessment and technical documentation mandated
Reporting	Only incidents affecting radio safety or EMC compliance (if applicable)	Exploited vulnerabilities/incidents within 24 h

RED and CRA

Aspect	Radio Equipment Directive (RED)	Cyber Resilience Act (CRA)
Legal form	EU Directive (transposed into national law)	Regulation (directly applicable across EU)
Scope	Ensure safety, electromagnetic compatibility, and use for radio equipment	Product cybersecurity for digital products
Target Entities	RED requires conformity with EMC Directive	Manufacturers of products with digital features
Core requirements	Safety of use of radio equipment	Product cybersecurity, vulnerability assessment, documentation, incident response
Certification	CE mark required for safety conformity	Documentation management and technical file
Reporting	Only incidents affecting radio safety or EMC compliance (if applicable)	Exploited vulnerabilities/incidents within 24 h

The CRA and RED complement each other by ensuring EU products are both broadly cybersecurity-resilient and compliant with specific radio equipment safety and security requirements.



EUR-Lex / Radio Equipment Directive (RED) C(2021)7672



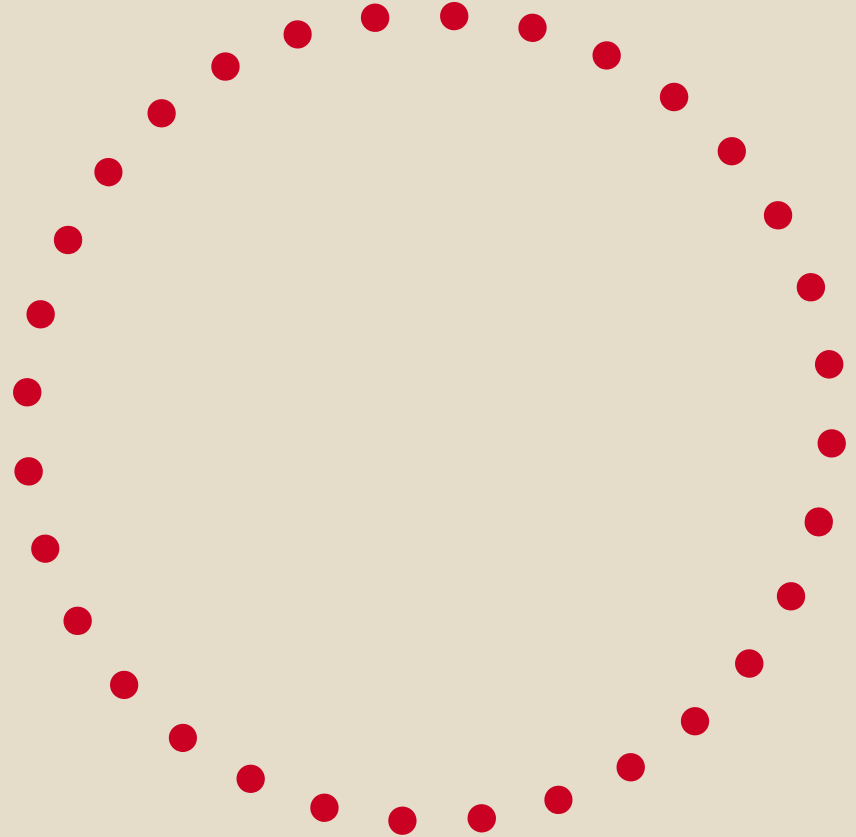
[EUR-Lex - C\(2021\)7672 - EN - EUR-Lex](#)

Topics

1. EU Legal Instruments
2. CRA Harmonized standards
 - EU Data Act
 - EU AI Act
 - EU Machinery Regulation
 - NIS 2 Directive
 - RED Radio Equipment Directive
3. **Cybersecurity laws in other regions**

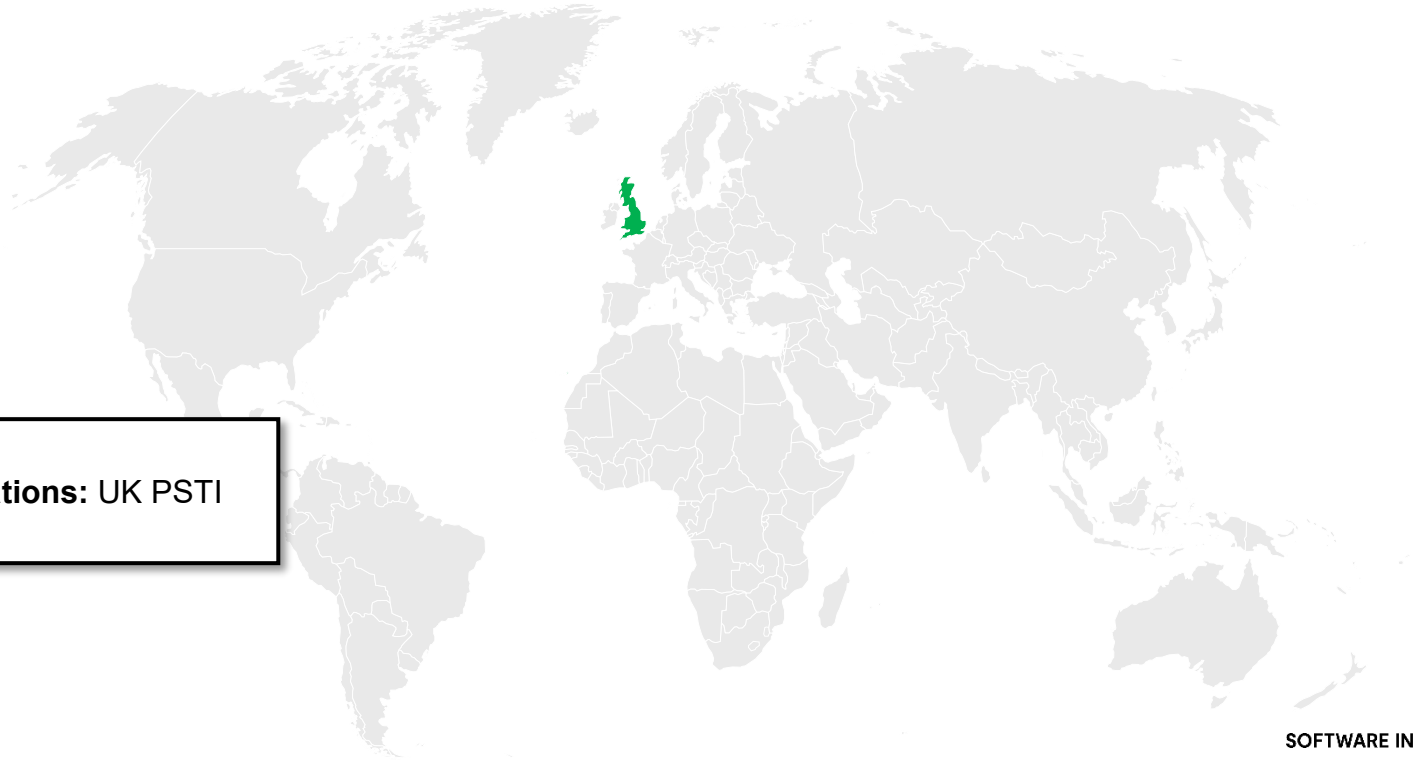


Cybersecurity laws in other regions



Cybersecurity other Regions

United Kingdom



> **Regulations: UK PSTI**

Comparison UK PSTI Act to EU CRA

Feature	PSTI (UK)	CRA (EU)
Legal Nature	Binding regulation	Binding regulation
Scope	Consumer IoT/connectable products only	All network-connected digital products
Requirements	No default passwords, vuln. reporting channel, update policy transparency	Security by design/default, vuln. mgmt., CE marking, incident reporting
Lifecycle Coverage	Partial (security updates duration declared, vuln. disclosure)	Full lifecycle (design → production → updates → incident handling)
Enforcement	Ofcom + regulator	National authorities + ENISA oversight
Certification	no certification scheme	CE-mark required; self-assessment and technical documentation mandated



CRA sets a comprehensive, risk-based EU regime with certification and strict reporting, while the UK's PSTI Act enforces basic IoT security hygiene without formal certification and lighter reporting duties.

Cybersecurity other Regions

United States



NIST SP 800-30

- Guidance for conducting **comprehensive risk assessments**
- Identifies **threats and vulnerabilities** in information systems
- Evaluates **likelihood and impact of potential events**
- Supports **calculation of overall risk levels**
- Enables informed and effective **security decisions**



Wide **industry** acceptance



Alignment with **international** regulations



Focus on **structured risk assessment** techniques



Serves as a **core reference** for threat & risk analysis

NIST SP 800-30 Overview



Asset

Parts of our solution that we want to secure



Threat

Things we're trying to defend our assets against



Countermeasure

Things we've done to protect our assets against threats



Vulnerability

Weakness in our defense against threats, i.e., gaps in our countermeasures



Risk

The overall resulting residual risk that remains that the threat is exploited

NIST SP 800-30 supports CRA risk assessment

NIST SP 800-30 Component	CRA Requirement	CRA Focus Area	Explanation
Risk Identification	Annex I, Sec. 1(a)	Threat modeling, secure design	CRA requires identifying known vulnerabilities and threats during design.
Threat & Vulnerability Analysis	Annex I, Sec. 1(b), 1(c)	Risk-based approach	CRA mandates assessing risks based on known threats and vulnerabilities.
Impact Analysis	Annex I, Sec. 1(d)	Security impact on users and systems	CRA requires evaluating consequences of exploitation.
Likelihood Determination	Annex I, Sec. 1(e)	Risk prioritization	CRA expects manufacturers to prioritize risks based on likelihood.
Risk Determination	Annex I, Sec. 1(f)	Overall risk level	CRA requires defining acceptable risk levels for product deployment.
Control Recommendations	Annex I, Sec. 2	Security measures	CRA mandates implementing appropriate technical and organizational measures.
Documentation & Reporting	Annex II	Technical documentation	CRA requires maintaining documentation of risk assessments and mitigations.
Review & Update	Annex I, Sec. 3	Lifecycle security	CRA emphasizes continuous monitoring and updates post-market.

NIST SP 800-53 – Control Families

- **Access Control:** Policy, Permitted Actions without Identification or Authentication, Remote Access, Wireless Access, Access Control for Mobile Devices
- **Awareness and Training:** ... security training due to legal or regulatory issues; privacy training if applicable; security as part of lifecycle process, ...
- **Audit and Accountability:** Policy, Audit Events, Review, Analysis and Reporting
- **Assessment and Authorization and Monitoring:** ... Continuous Monitoring, Penetration test, ...
- **Configuration Management:** Policy, Change Control, Security Impact Analysis
- **Contingency Planning:** Policy, Plan, Training, ...
- **Identification and Authentication:** Device Identification and Authentication, Identifier Management, ...
- **Incident Response:** Incident Handling, Monitoring, ...
- **Maintenance:** Controlled Maintenance, Tools, ...
- **Media Protection:** Policy and Procedures, Media Sanitization
- **Physical Environmental Protection:** ..., Access Control for Transmission Medium, Monitoring Physical Access
- **Planning:** Security Planning Policy and Procedures
- **Program Management:** Plan, Roles, Insider, ...
- **Personnel Security:** Policy, Screening, Sanctions, ...
- **Personally identifiable information processing and transparency**
- **Risk Assessment:** ..., Vulnerability Scanning, ...
- **System and Services Acquisition:** Developer Security Testing and Evaluation, Supply Chain Protection, Tamper Resistance and Detection, Component Authenticity
- **System and Communications Protection:** Denial of Service Protection, Boundary Protection, Cryptographic Protection, Fail in Known State, Wireless Link Protection,...
- **System and Information Integrity:** Malicious Code Protection, Information System Monitoring, Security Alerts, SW, Firmware and Information Integrity, Memory Protection
- **Supply Chain Risk Management**

NIST SP 800-53 – Mapping with CRA Requirements

CRA Requirement Reference	CRA Description	NIST Control Family	Example Controls
Annex I, 1(a)	Products shall be designed, developed and produced in accordance with essential cybersecurity requirements.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest
Annex I, 1(b)	Products shall be delivered with a secure default configuration.	Configuration Management (CM)	CM-6: Configuration Settings; CM-7: Least Functionality
Annex I, 1(c)	Products shall be designed to protect against unauthorized access.	Access Control (AC)	AC-2: Account Management; AC-3: Access Enforcement
Annex I, 1(d)	Products shall be designed to protect against data being stored, processed or transmitted without authorization.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest
Annex I, 1(e)	Products shall be designed to protect against known vulnerabilities.	System and Information Integrity (SI)	SI-2: Flaw Remediation; SI-5: Security Alerts, Advisories, and Directives
Annex I, 2	Products shall include mechanisms for logging and monitoring.	Audit and Accountability (AU)	AU-2: Audit Events; AU-6: Audit Review, Analysis, and Reporting
Annex I, 3	Products shall be designed to allow for secure updates.	System and Information Integrity (SI)	SI-2: Flaw Remediation; SI-4: System Monitoring
Annex I, 4	Products shall ensure protection of stored and transmitted data.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest; SC-12: Cryptographic Protection

NIST SP 800-53 – Mapping with CRA Requirements

CRA Requirement Reference	CRA Description	NIST Control Family	Example Controls
Annex I, 1(a)	Products shall be designed, developed and produced in accordance with essential cybersecurity requirements.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest
Annex I, 1(b)	Products shall be delivered with a secure default configuration.	Configuration Management (CM)	CM-6: Configuration Settings; CM-7: Least Functionality
Annex I, 1(c)	Products shall be designed to protect against unauthorized access.	Access Control (AC)	AC-2: Account Management; AC-3: Access Enforcement
Annex I, 1(d)	Products shall be designed to protect against data being stored, processed or transmitted without authorization.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest
Annex I, 1(e)	Products shall be designed to protect against known vulnerabilities.	System and Information Integrity (SI)	SI-2: Flaw Remediation; SI-5: Security Alerts, Advisories, and Directives
Annex I, 2	Products shall include mechanisms for logging and monitoring.	Audit and Accountability (AU)	AU-2: Audit Events; AU-6: Audit Review, Analysis, and Reporting
Annex I, 3	Products shall be designed to allow for secure updates.	System and Information Integrity (SI)	SI-2: Flaw Remediation; SI-4: System Monitoring
Annex I, 4	Products shall ensure protection of stored and transmitted data.	System and Communications Protection (SC)	SC-12: Cryptographic Key Establishment; SC-28: Protection of Information at Rest; SC-12: Cryptographic Protection

Comparison US Cybersecurity to EU CRA

Feature	Cyber Trust Mark (US)	NIST CSF (US)	CRA (EU)
Legal Nature	Voluntary labeling program	Voluntary framework	Binding regulation
Scope	Wireless consumer IoT products	All sectors, especially critical infrastructure	All network-connected digital products
Requirements	Unique and strong default passwords, software updates, data protection, and incident detection capabilities.	Flexible, risk-based approach with focus on Identify, Protect, Detect, Respond, and Recover.	Security by design/default, vuln. mgmt., CE marking, incident reporting
Lifecycle Coverage	Product-level labeling	Organizational risk management	Full lifecycle (design → production → updates → incident handling)
Enforcement	Voluntary; however, non-compliance may affect eligibility for federal contracts	Voluntary; however, non-compliance may affect eligibility for federal contracts	National authorities + ENISA oversight
Certification	Third-party testing required	No official certification	CE-mark required; self-assessment and technical documentation mandated

Cyber Trust Mark provides consumer-facing assurance of secure IoT products, while NIST CSF offers a comprehensive risk-based cybersecurity framework; together, they complement CRA by supporting both technical cybersecurity practices and market-trusted product labeling, ensuring EU-bound products meet regulatory security expectations.

Cybersecurity other Regions

Mainland China

- China Cybersecurity Law (CSL) and related laws

Comparison China Cybersecurity law (CSL) and Data Security law (DSL) to EU CRA

Feature	China CSL, 2017	DSL, 2021	CRA (EU)
Legal Nature	Binding regulation	Binding regulation	Binding regulation
Scope	Applies to all network operators in China, including critical information infrastructure operators.	Focuses on data security, including data collection, storage, processing, and transfer for protecting national security.	All network-connected digital products
Requirements	Real-name registration, data localization	Data based on importance, implementation of data security measures,	Security by design/default, vuln. mgmt., CE marking, incident reporting
Lifecycle Coverage	Operational lifecycle of network infrastructure	Covers the entire data lifecycle, from collection to deletion	Full lifecycle (design → production → updates → incident handling)
Enforcement	Government enforcement with penalties	Government enforcement with penalties	National authorities + ENISA oversight
Certification	Requires security certification for critical network equipment	Does not mandate specific certifications but requires compliance with data security measures	CE-mark required; self-assessment and technical documentation mandated



China's CSL and DSL enforce state-driven cybersecurity on critical infrastructure and data security, while the EU CRA mandates product-focused cybersecurity compliance across the EU market.

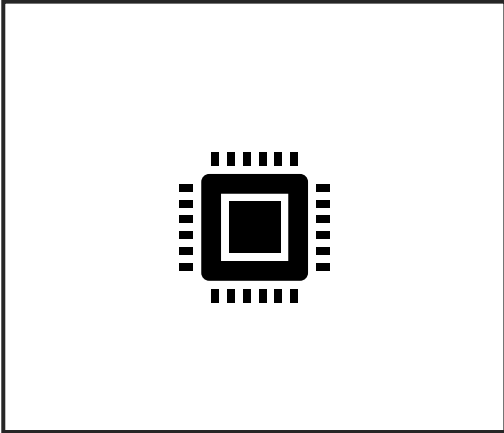
Cybersecurity in other Regions

Countries in Asia

- Cybersecurity **Basic Act (2014)**
 - Focuses on national strategy, public-private cooperation, and critical infrastructure protection, sets the stage for sector-specific cybersecurity policies.
- **SEMI E187/E188 standards**
- **METI Guidelines** for Secure **IoT** Systems
 - Promotes secure-by-design principles for IoT devices. Encourages manufacturers to implement vulnerability management, secure updates, and incident response (similar to CRA Annex I)
- **IPA Security Guidelines** for **Embedded Systems**
 - Focuses on secure development practices for embedded systems, includes lifecycle security, threat modeling, and secure configuration (aligned with CRA's product-level requirements)



SEMI E187/E188 Standards



SEMI E187 Focus

SEMI E187 targets new **semiconductor** equipment security, requiring OS, network, endpoint protection, and security monitoring before dispatch.

Objective: Secure **development** and **delivery** of new equipment.

SEMI E188 Extension

SEMI E188 extends cybersecurity to **existing equipment** and **computational components**, emphasizing **malware** and **vulnerability** scanning.

Objective: Protection against malware during delivery, installation, and maintenance.

Industry Adoption

Although voluntary, SEMI E187 and E188 are widely adopted as best practices for semiconductor manufacturing cybersecurity, seen as a prerequisite for collaboration in the semiconductor industry.

CRA & SEMI E187/E188 Standards

Common Goals and Differences

Common Goals

Lifecycle Cybersecurity Management

Both ensure cybersecurity is maintained from design phase to product end-of-life, emphasizing continuous protection.

Vulnerability Handling and Patching

Timely identification and patching of vulnerabilities to prevent unauthorized access and cyber threats as malware.

Processes for Security Evaluation and Updates

Regular assessments, implement appropriate security controls, provide updates.

Transparency and Trust

Both promote transparency and trust to strengthen confidence in digital and semiconductor product security.

Key Differences

Scope of Standards

EU CRA covers all digital products broadly, while SEMI standards focus on semiconductor manufacturing equipment specifically.

Enforcement Differences

CRA is legally binding with penalties, SEMI standards are voluntary and rely on industry best practices.

Security Requirements

Technical Standards for SEMI are tailored to the semiconductor industry, focusing on practical cybersecurity controls during equipment delivery and maintenance, CRA is broader. More details likely to be developed in vertical standards.

International Standards – ISO

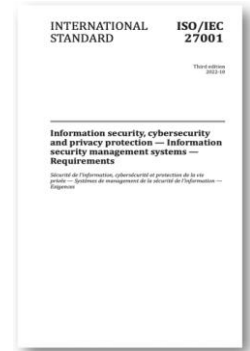
Example for ISO 27001

- 
- ISO 27001 – Information Security Management System

ISO 27001- Certified Organizations

If an organization is already **ISO 27001 certified**, **strong foundation** in risk management and security governance exists:

- Assessing information security risks
- Treating information security risks
- Incident planning and response, ongoing monitoring
- Selecting and implementing controls
- Supply Chain Security



→ **Enterprise-level** risk assessment & treatment vs. **Product-specific** risk assessment & mitigation!

Lifecycle Coverage within **ISMS** mainly focuses on **organizational processes**, **CRA** on **Product design, development, deployment, post-market**.

Lack **product-specific controls** required by CRA (e.g., secure default configurations, vulnerability handling, update mechanisms) and **conformity assessment** procedures.



→ extend ISMS to cover product lifecycle and technical documentation for CE marking.

Key Takeaways

- The legal instruments of the European Union are **Regulations** (CRA, Data Act, AI Act and Machinery Reg.) and **Directives** (NIS 2 and RED).
- EU regulations are directly applicable to all EU member states.
- EU's CRA sets comprehensive cybersecurity requirements for all networked products, while the UK's PSTI Act targets consumer IoT devices with lighter obligations.
- The CRA ensures AI-enabled products are secure, whereas the EU AI Act regulates the development and oversight of AI systems; the two are complementary.
- China's CSL and DSL focus on state-driven cybersecurity and national security, contrasting with the EU's market-focused approach emphasizing individual rights and product security.
- US approach, exemplified by the NIST CSF and the Cyber Trust Mark, is largely **voluntary** and risk-based, providing **guidelines** and a consumer-facing label, whereas the EU's CRA is a mandatory, legal requirement for market access.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
- 4. Products Affected by CRA**
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Topics

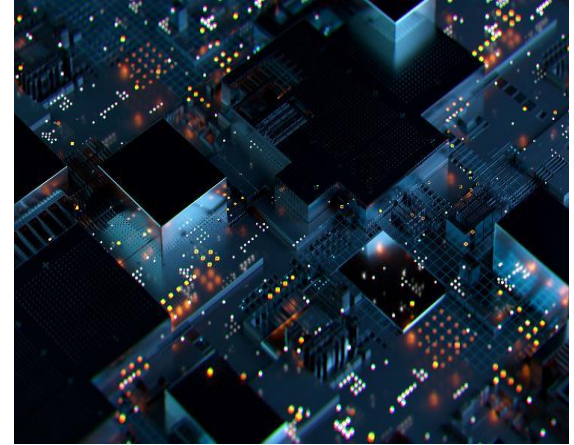
1. Scope Overview
2. Understanding out of scope
 - Software
 - Automotive
 - Medical and in vitro devices
 - Marine
 - Aeronautics
3. Classification of products



Products affected by the EU Cyber Resilience Act

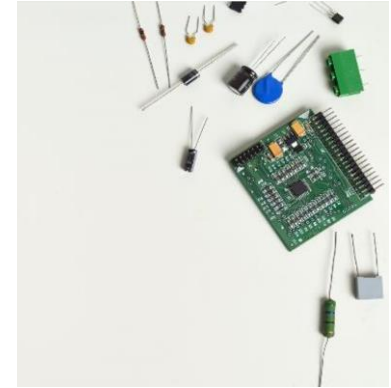
General Scope:

- Broad range of products containing **digital elements**, which include both hardware and software products that have a direct or indirect logical or physical data connection to a device or network.
- Products placed on the **EU market**.
- There are some exception for product in scope of earlier EU regulation (see following slides).



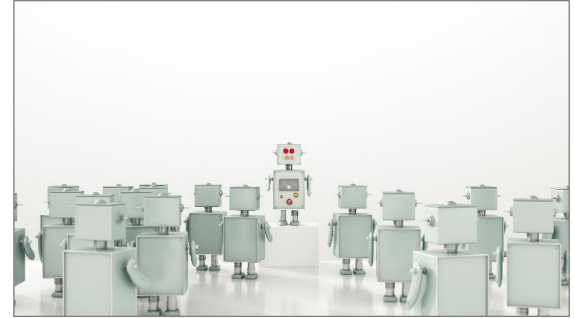
Products affected by the EU Cyber Resilience Act

- **Hardware** products (including components placed on the market) (e.g. notebooks, smart appliances, mobile phones, network equipment or CPUs...)
- **Software** products (including components placed on the market) (e.g. operating systems, word processing, games or mobile apps, software libraries...)
- including their **Remote Data Processing Solutions**, where the absence of such processing would prevent the product from performing one of its functions i.e. a product with digital elements relies on remote data processing to function.
- including **spare parts** if not already undergone a conformity assessment
- **Technical support and services** for products under CRA



Products out of scope of EU Cyber Resilience Act

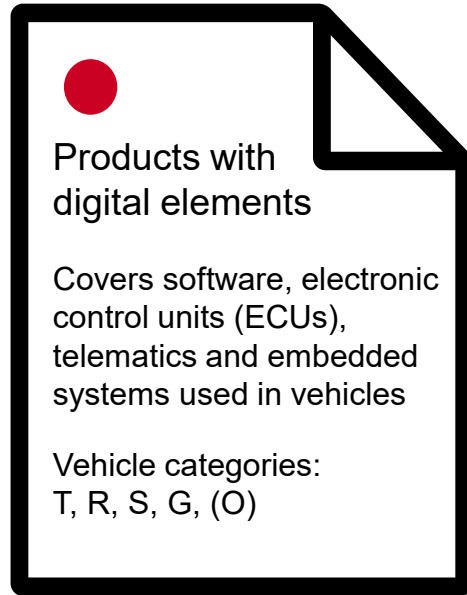
- Non-commercial products
- Services, in particular standalone SaaS (websites, purely web-based offerings...)
- Vehicle “type-approval”
- Medical devices
- In vitro diagnostic medical devices
- Aeronautical products, parts and equipment, including software
- Marine equipment
- Products exclusively for national security or defense purposes
- Spare parts to replace identical certified components under certain conditions



Scope of the Cyber Resilience Act: Automotive Industry

Different vehicle types and their environment

Cyber Resilience Act (CRA)



*Draft Delegation -> EU 168/2013
includes UN R 155

Excludes

General Safety Regulation (GSR) 2019/2144



EU 168/2013



+ Vehicle Category O?

+ Automotive suppliers:

(developing products with digital elements: developed exclusively for a specific client included in type approval, not placed on the market separately)

Software Out of Scope from EU Cyber Resilience Act

Free and Open-Source Software:

- If a fee is charged solely to recover actual costs, or products developed or modified by public administration entities exclusively for their own use
- If not made available on the market in the course of a commercial activity
(but there are specific provisions for open-source software stewards)

Products affected by the CRA are classified

- **Important, Critical Products and Default Products:**

These products are subject to **stricter conformity assessment** procedures.

- **Important Products (class 1 and 2)** that perform critical cybersecurity functions or carry significant risks of adverse effects.
 - Class 1 Self-Assessment if compliant with EU standards or common specifications
 - Class 2 Third-party conformity assessment by notified body
- **Critical Products** that have a high level of cybersecurity risk and are essential for the functioning of critical infrastructures.
 - Conformity based on full quality assurance mandatory, EU certification
- **Default Products** all other products with digital elements.
 - Self-Assessment with Annex I requirement to be performed



Risk-Based Product Classification

Benefits of risk-based product classification

- **Prioritization of Resources:** Not all digital products pose the same level of cybersecurity risk. By classifying products based on their risk levels, resources can be allocated more efficiently. High-risk products receive more stringent scrutiny and security measures, ensuring that efforts are concentrated where they are most needed.
- **Tailored Security Measures:** A risk-based classification allows for the implementation of tailored security measures that are **appropriate for the level of risk** a product poses. This ensures that security measures are both effective and proportionate.
- **Enhanced Protection:** This helps in safeguarding essential services and infrastructures that are vital for public safety and economic stability.
- **Market Confidence:** When products are classified and certified based on their risk levels, it provides assurance to users about the security and reliability of these products.



CRA Product Categories – more details

Category	Definition	Why it matters	Examples
Default Products	Products with digital elements that are not listed in Annexes III or IV and do not have important or critical cybersecurity vulnerabilities.	Self-Assessment with Annex I requirements	Photo editing software, text processing software, hard drives and games etc.
Important Products: Class I	Products performing important cybersecurity functions but with a lower risk compared to Class II; significant cybersecurity risk profile. This means digital-element products where security is important to protect data, privacy, and operation, but not the highest assurance level.	Standard security requirements. Protects users and data	Identity management systems and hardware, browsers, password managers, antivirus software, VPN software, routers, modems, OS, smart lock
Important Products: Class II	Products performing critical cybersecurity functions or posing high potential adverse effects if compromised; crucial for the security of other systems and services. This means digital-element products needing higher security assurance due to greater exposure or impact, but not at critical-risk level	Stricter assessment. Higher impact if compromised.	Hypervisors, container runtime systems, firewalls, intrusion detection systems, tamper-resistant microprocessors, hardware with security boxes.
Critical Products	Products with digital elements having core functionality of a category in Annex IV, requiring a European cybersecurity certificate. Digital-element products whose security must prevent significant harm to safety, public interest, or critical infrastructure; require heightened security and robust assurance.	Most stringent requirements. Systematic risk if it fails.	Smart cards, secure elements, smart meter gateways, hardware security module (HSM).

Key Takeaways

- Products already regulated **by other EU laws are not under scope of CRA**
 - Non-commercial products
 - Medical devices and in vitro diagnostic medical devices
 - Aviation equipment
 - Vehicle „type-approval“
 - Marine equipment
 - Services, in particular standalone SaaS (websites, purely web-based offerings...)
 - Products exclusively for national security or defense purposes
- **Even if central products out of scope**, industry branches medical technology, aviation, automotive and marine should care about CRA and understand its relevance beyond the central products.
- CRA demands tailored actions from companies producing, importing, dealing, repairing with products under CRA **based on risk classification**.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
- 5. Actors Affected by CRA**
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Topic

1. Actors affected by CRA
2. Relationship between the different CRA actors



Topic

1. **Actors affected by CRA**
2. Relationship between the different CRA actors



Actors Affected by CRA

Actors	Why Involved?	Real world examples
Manufacturer	Design, assess, update, and support secure digital products	Non-EU: Samsung Electronics (South Korea) EU: Siemens AG (Germany)
Authorized Representative	EU accountability for non-EU manufacturers	Compliance Gate (Germany)
Importer	Filters non-EU products entering the EU and ensures compliance	RS Components GmbH(Germany)
Distributor	Check and sell only compliant products	Conrad Electronic (Germany)
Economic Operators	Become responsible as manufacturer if substantially modifying products	Siemens AG (Germany)
Open-Source Software Stewards	Ensure open-source components meet cybersecurity standards	Linux Foundation, Apache Software Foundation, OpenSSL Project
Market Surveillance Authority	Monitors, investigates, and enforces CRA compliance in the EU market	„BAuA“ - Federal Institute for Occupational Safety and Health (Germany)
ENISA (EU Agency for Cybersecurity)	Plays central role in EU-level threat intelligence, coordination, and incident management	ENISA (EU-wide) – Official EU cybersecurity agency
Notified Body (under development)	Performs third-party conformity assessments of high-risk (Class II / Critical) products	UL Solutions, TÜV Rheinland (Germany), SGS (Switzerland)
CSIRT (Computer Security Incident Response Team)	Manages cybersecurity incidents and coordinates vulnerability disclosure under the CRA	National CERTs (e.g., CERT-DE in Germany)

Manufacturer



A **manufacturer** is any natural or legal person who:

- **develops or manufactures products** with digital elements, or
- has such products **designed, developed, or manufactured** on their behalf, and
- markets them under their **own name or trademark**, whether for payment or free of charge

Responsibilities



Cybersecurity by Design & Default – embed security from the start of product development



Risk Assessment – identify and evaluate cybersecurity risks



Conformity Assessment – perform self-assessment or seek 3rd-party assessment (Notified Body), depending on risk class or European Cybersecurity Scheme (Common Criteria ITSEF)



Technical Documentation – maintain product documentation and issue an EU Declaration of Conformity



CE Marking – affix CE marking before placing the product on the EU market



Vulnerability Handling – establish a coordinated vulnerability disclosure and handling process.



Updates & Patches – provide security updates for at least 5 years or for the expected product lifetime.

Manufacturer's obligations to suppliers ¹ of 2

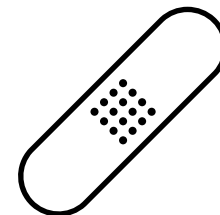
• Due Diligence on Components:

- Check that third-party components (hardware, software, open-source libraries) are secure.
- Verify CE marking or CRA compliance when applicable.
- Ensure components receive regular security updates.
- Check public vulnerability databases for known issues.
- Perform additional security testing if needed.



• Vulnerability Management - If a supplier component has a vulnerability:

- Inform the supplier/maintainer.
- Remediate the issue in the final product.
- Share security fixes with the supplier where relevant.



Manufacturer's obligations to suppliers ^{2 of 2}

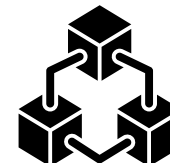
- **Documentation and Tracking:**

- Maintain an SBOM (Software Bill of Materials) listing all components.
- Use it to track vulnerabilities and risks in supplier components.



- **Integration Responsibility:**

- Ensure that all supplier components, once integrated, do not compromise overall product security.
- Remain ultimately accountable for the final product's compliance, even if parts come from suppliers.



Authorized Representative



An **Authorized representative** is a natural or legal person established within the European Union who:

- Appointed by a **manufacturer** through a written mandate
- Acts on **behalf of the manufacturer** for specific tasks relate to products with digital elements

Responsibilities



Written Agreement – Define precise scope with manufacturer



Information & Documentation – Cooperate with market surveillance authorities



Corrective Measures – Assist in recalls/withdrawals/non-compliance actions

Importer



An importer means a natural or legal person established in the European Union who:

- **Places on the market** a product with digital elements that bears the name or trademark of a person **outside the Union**

Responsibilities



Compliance Check – Verify manufacturer's CRA compliance before market placement



Cooperate – Work with Market Surveillance Authorities



Notify – Inform authorities & users of serious cybersecurity risks or closure of manufacturer



Documentation – Keep EU Declaration of Conformity for 10+ years

Distributor



A distributor means a natural or legal person in the supply chain (**not manufacturer or importer**)

- **makes a product** with digital elements available in the EU market **without altering its properties**.

Responsibilities



Pre-Market Checks – Ensure CE marking and CRA obligations are fulfilled



Documentation – Verify required compliance docs are available



Notify – Inform manufacturer & authorities of major cybersecurity risks or manufacturer's closure



Provide Info – Supply compliance docs to authorities when requested

Economic Operators



- Any **manufacturer, authorized representative, importer, distributor**, or other person with obligations under CRA
- Includes anyone who substantially **modifies a product** before placing it on the EU market (treated as a manufacturer in that case)

Responsibilities



Traceability – Provide names & addresses of suppliers/customers and retain for 10 years



Manufacturer Duties if Modified – Comply with all manufacturer responsibilities if product is substantially altered



Support Authorities – Provide documentation and information when reasonably requested

Open-Source Software Steward



An **open-source software steward** is a legal person (other than a manufacturer) who

- supports the development of specific **free and open-source software** (FOSS) products with digital elements
- Ensures the **viability** of these products for commercial activities.

Responsibilities



Cybersecurity Policy – Develop & document policies for secure development and vulnerability handling



Collaborate with Authorities – Work with market surveillance to mitigate cybersecurity risks



Product & Incident Management – Comply with obligations related to FOSS product development and incident handling

OSS-Steward – only for commercial OSS

Difference between Manufacturer and OSS-Steward

Aspect	Manufacturer	OSS-Steward
Places product on EU market	Yes	No
Full CRA compliance needed	Yes (Annex I & II)	Only limited obligations (Article 24)
Maintains open-source code	No	Yes
Handles conformity assessment	Required	Not required



Manufacturer: ensures full CRA compliance for the final product



OSS-Steward: supports development without placing products on the market, holding limited duties centered on cybersecurity best practices, **only for commercial OSS**

Market Surveillance Authority



Market Surveillance Authority is a:

- public body **appointed by each EU Member State** to enforce CRA compliance for products with digital elements
- can be a **newly established body or an existing authority**

Responsibilities



Incident & Vulnerability Coordination – Work with ENISA and national certification bodies



Cooperation – Collaborate with other EU market surveillance authorities under regulations like 2019/1020



Product Evaluations – Assess high-risk products; coordinate with CSIRTs



Joint Operations – Work with authorities for coordinated actions on high-risk products



Guidance to Operators – Support economic operators with CRA implementation



OSS Steward Oversight – Enforce obligations under Article 24 and require corrective actions for non-compliance



Reporting & Resources – Provide annual reports to the Commission; ensure funding and qualified personnel

Notified Body



- Notified Body is a **conformity assessment body** designated under CRA and relevant EU legislation
- Authorized by a **national authority** in an EU Member State
- Designation **communicated to the European Commission** and other Member States

Responsibilities



Conduct Assessments – Perform conformity assessments according to CRA procedures



Independence – Avoid conflicts; remain independent from product design, manufacture, sales, or use



Certification – Issue EU-type examination certificates only if Annex I requirements are met



Audit – Ensure vulnerability handling processes (Annex I, Part II) are implemented



Subcontracting – Allowed only if subcontractors meet the same criteria

Computer Security Incident Response Team (CSIRT)



- **CSIRT** (Designated as Coordinator) is a team designated by each EU Member State to manage cybersecurity incidents and coordinate vulnerability disclosure under CRA
- Based on Article 12(1) of Directive (EU) 2022/2555

Responsibilities



Vulnerability Hub – Central point for reporting and helping manufacturers fix issues before public release



Disclosure Coordination – determining how to postpone reporting temporarily to allow time for fixes



ENISA Coordination – Ensure timely receipt of vulnerability information



Incident Management – Quickly and systematically manage serious cybersecurity incidents

European Union Agency for Cybersecurity (ENISA)



- EU-level cybersecurity agency established under **Regulation (EU) 2019/881**
- Supports **Member States and EU institutions** in implementing cybersecurity policies
- Coordinates across **Member States, supports standards development, and assesses emerging threats under CRA**

Responsibilities



Vulnerability Reporting – Receive reports of actively exploited vulnerabilities and severe incidents within 24 hours



Forwarding Reports – Send reports to national CSIRTs and market surveillance authorities via a single reporting platform



Coordinated Disclosure – Facilitate collaboration between manufacturers and CSIRTs



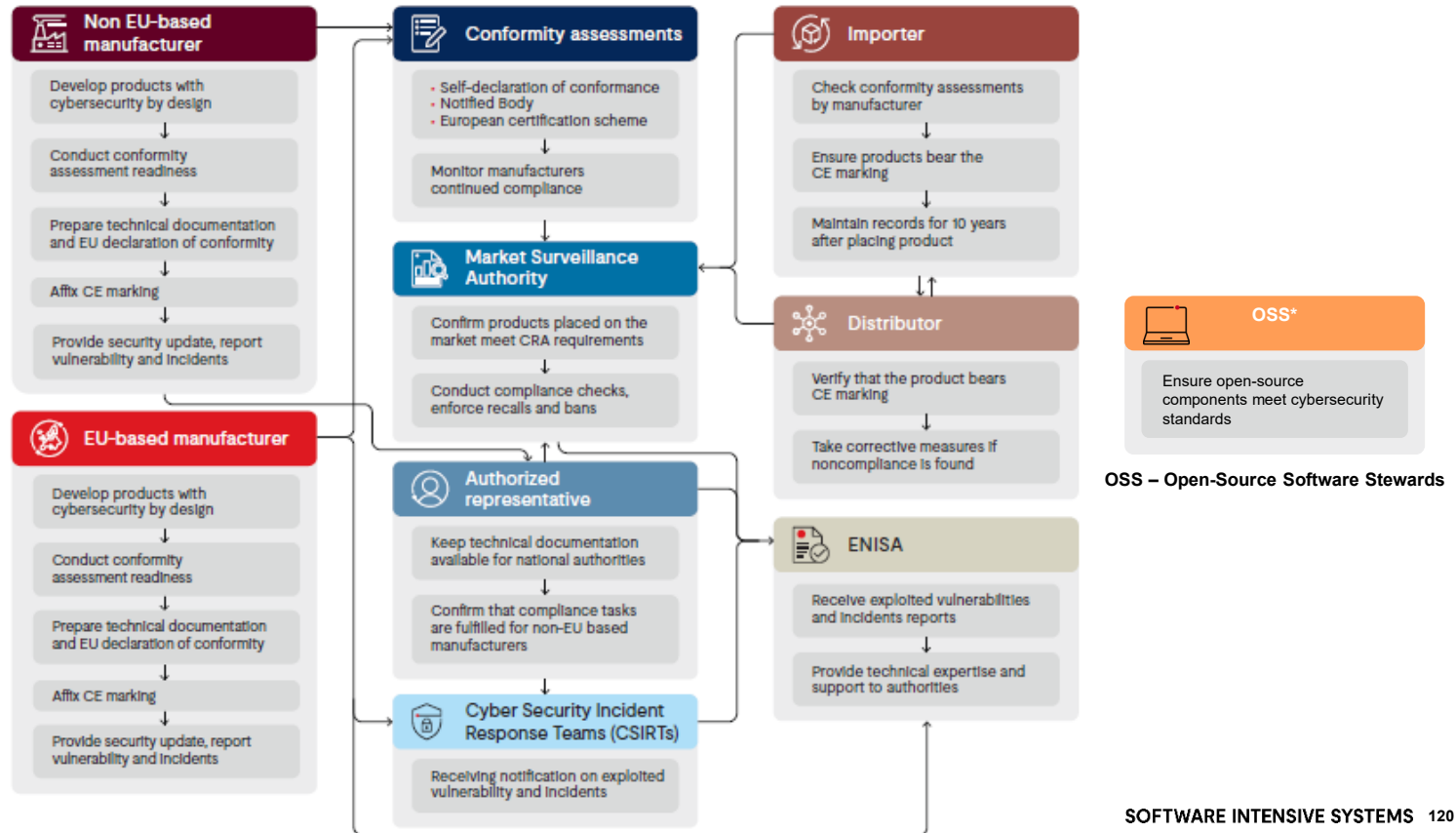
Resource Management – Ensure adequate staffing and resources for CRA duties

Topics

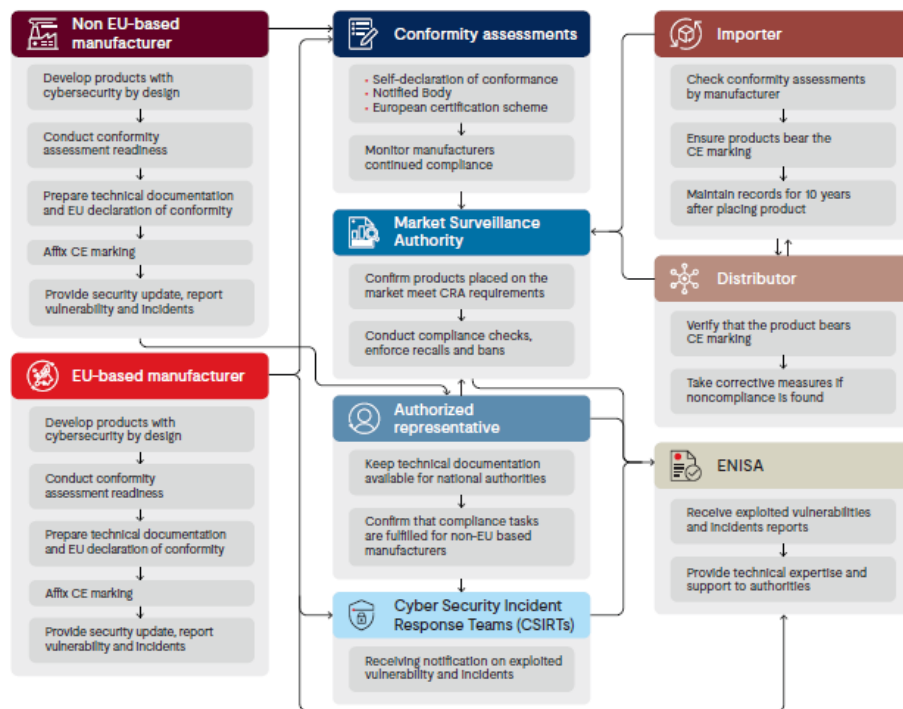
1. Actors affected by CRA
2. Relationship between the different CRA actors



Relationship between the different CRA actors



Relationship between the different CRA actors



First stakeholder	Second stakeholder	Relationship between first stakeholder and second stakeholder
Non EU-based manufacturer	Authorized representative	Formally appoints
Authorized representative	Market Surveillance Authority	Provides technical documentation and responds to product issue
Non EU/EU-based manufacturer	Notified Body	Provides technical security documentation for assessment
Non EU/EU-based manufacturer	Market Surveillance Authority	Provides assessment documents for inspection and compliance enforcement
Authorized representative	CSIRTs	Reports actively exploited vulnerabilities and cybersecurity incidents
EU-based manufacturer	CSIRTs	Reports actively exploited vulnerabilities and cybersecurity incidents
Authorized representative	ENISA	Shares notification of actively exploited vulnerabilities and cybersecurity incidents
EU-based manufacturer	ENISA	Shares notification of actively exploited vulnerabilities and cybersecurity incidents
CSIRTs	ENISA	Shares data on threats, vulnerabilities and incidents
Market Surveillance Authority	ENISA	Collaborates with ENISA in case of significant cybersecurity incidents and threat intelligence
Importer	Market surveillance authority	Reports suspected cybersecurity risk
Distributor	Market surveillance authority	Reports suspected cybersecurity risk
Distributor	Importer	Reports suspected cybersecurity risk
Importer	Distributor	Supplies product
Non EU-based manufacturer	Importer	Shares CE marking and documentation for product placement

Key Takeaways ^{1 of 2}

- **Manufacturers:** Must ensure cybersecurity by design, report severe incidents within 24 hours, and provide regular security updates throughout the product lifecycle.
- **Importers:** Must verify that products comply with CRA requirements before placing them on the EU market and ensure proper documentation.
- **Distributors:** Must confirm that products bear CE marking and not distribute non-compliant or unsafe products.
- **Authorized Representatives:** Act on behalf of manufacturers and must cooperate with authorities, hold technical documentation, and support incident communication.
- **Open-source Software Stewards:** Must establish security policies and report severe incidents affecting their development infrastructure to ENISA and CSIRTs.
- **Market Surveillance Authorities:** Responsible for enforcing compliance, coordinating with CSIRTs, and sharing findings across CRA and AI Act frameworks.



Key Takeaways ^{2 of 2}

- **CSIRTs** (designated as coordinators): Receive vulnerability and incident reports, support risk assessment, and communicate urgent risks to the public if needed.
- **ENISA**: Operates the single reporting platform and supports coordination and cybersecurity posture across Member States.
- **Notified body**: An accredited third-party organization designated by an EU Member State to conduct conformity assessments.
- **Economic operator**: Any party that substantially modifies a product before placing it on the EU market is treated as a manufacturer and must fully comply with all manufacturer obligations under the CRA.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
- 6. Reporting Obligations and Enforcement Mechanisms**
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Topics

1. Reporting obligations of different actors
2. Reporting platform



Topics

1. Reporting obligations of different actors
2. Reporting platform



Reporting Obligations for Manufacturers

Vulnerability

Manufacturer's notification obligations in case of **actively exploited vulnerabilities** as per article 14:

Early Warning Notification	Detailed Vulnerability Notification	Final Report
 Deadline: Within 24 hours of becoming aware	 Deadline: Within 72 hours (if not already reported)	 Deadline: Within 14 days after mitigation is available
Content: • Exploit alert notification • Specify affected Member States (if known)	Content: • General info on affected product • Nature of vulnerability & exploit • Actions taken / mitigation measures • User recommendations • Sensitivity of information (if relevant)	Content: • Full description of the vulnerability (impact & severity) • Information on any known attacker(s), if available • Details of security updates or corrective actions

Reporting Obligations for Manufacturers

Incident

Manufacturer's notification obligations in case of **Incident**:

- Notify without delay via central **EU reporting platform**, sent simultaneously to designated **CSIRT Coordinator & ENISA**

Early Warning Notification



Deadline: Within **24 hours** of becoming aware

Content:

- Incident alert notification with initial info (possible unlawful/malicious actions)
- Affected Member States (if known)

Detailed Vulnerability Notification



Deadline: Within **72 hours** (if not already reported)

Content:

- General information on the affected product
- Nature of the Incident
- Initial assessment and mitigation measures taken
- User recommendations
- Sensitivity of the information, if relevant

Final Report



Deadline: Within **1 month** after mitigation is available

Content:

- Full description of the Incident (impact & severity)
- Likely cause or type of threat
- Mitigation actions implemented or planned

Reporting Obligations for Manufacturers

Vulnerability

In case of **actively exploited vulnerabilities**, notify without delay via central **EU reporting platform**, sent simultaneously to designated **CSIRT Coordinator & ENISA**

Early Warning Notification

 **Deadline:** Within **24 hours** of becoming aware

Content:

- Exploit alert notification
- Including whether the incident is suspected of being caused by unlawful or malicious acts
- Specify affected Member States (if known)

Detailed Notification

 **Deadline:** Within **72 hours** (if not already reported)

Content:

- General information on the affected product
- Nature of **vulnerability & exploit**
- Actions and mitigation measures taken
- User recommendations
- Sensitivity of information (if relevant)

Final Report

 **Deadline:** Within **14 days** after mitigation is available

Content:

- Full description of the **vulnerability** (impact & severity)
- Information on any known attacker(s), if available
- Details of security updates or corrective actions

Incident

In case of **incident**, notify without delay via central **EU reporting platform**, sent simultaneously to designated **CSIRT Coordinator & ENISA**

Early Warning Notification

 **Deadline:** Within **24 hours** of becoming aware

Content:

- Incident alert notification with initial info (possible unlawful / malicious actions)
- Specify affected Member States (if known)

Detailed Notification

 **Deadline:** Within **72 hours** (if not already reported)

Content:

- General information on the affected product
- Nature of the **incident**
- Initial assessment and mitigation measures taken
- User recommendations
- Sensitivity of information (if relevant)

Final Report

 **Deadline:** Within **1 month** after mitigation is available

Content:

- Full description of the **incident** (impact & severity)
- Likely cause or type of threat
- Mitigation actions implemented or planned

Reporting Channels for Manufacturers

- Centralized **EU-wide portal** (maintained by ENISA) → All incident & vulnerability notifications go here
- Streamlines & simplifies reporting for manufacturers
- **Who Submits Where?**
 - **Primary Rule:** Submit to the CSIRT of the Member State where the manufacturer's cybersecurity decisions are made
 - If unclear, then where the largest workforce is in the EU
 - If outside the EU, submit to CSIRT based on the following fallback order:
 - Member State of the main authorized representative
 - Member State of the main importer
 - Member State of the main distributor
 - Member State with the largest user base
- **Subsequent Notifications**

Future reports can be submitted to the same CSIRT as the first one, even if based on different locations.



[Implementation of the Single Reporting Platform | ENISA](#)

Communication to User by Manufacturer



Manufacturer detects a **vulnerability or a severe incident**.



Inform affected users without delay (<24 h) about:

- **Risk mitigation / corrective actions**
- Information should be provided in a **structured, machine-readable format** (if possible)

What happens if the manufacturer fails to act?



- If the manufacturer fails to inform users, the **CSIRT** may step in to share the necessary information to protect users.
- This action must be both **necessary and proportionate** to the risk.

Reporting Obligations for Importers and Distributors

Normal Obligations

- Inform manufacturer & cooperate with authorities if a vulnerability or incident is found.
- Withdraw or recall a product if required due to a security risk.
- Act and report without undue delay.

Importer/Distributor becomes a Manufacturer if they...



- Rebrand a product under their own name or trademark.
- Substantially modify a product already on the market.



Implication: They are then fully subject to Manufacturer Obligations (CRA Articles 13 & 14), including Conformity Assessment and Reporting Obligations.

Reporting Obligations for Open-source Software Stewards



Applicability

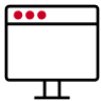
Must comply with these reporting obligations only

- When actively **involved in product development**
- **Examples:** contributing code, maintaining core components



Vulnerability Reporting

- Report vulnerabilities **only if involved in development**
- Follow **same timelines & reporting channels** as manufacturers (24h Early Warning, 72h Detailed Report via Single EU Platform)



Incident Reporting

Must report severe cybersecurity incidents affecting their **development infrastructure**

- **Example:** compromised CI/CD servers, repo hijacks
- **Notification path:** Coordinating CSIRT and ENISA via Single EU Reporting Platform



User Notification

Must promptly **notify affected users** if:

- **Known, actively exploited vulnerability** discovered
- Serious **cybersecurity incident impacts** their product
- Should include **mitigation/corrective actions**

Reporting Obligations for Authorized Representative



No Direct Reporting

- No direct vulnerability or incident reporting obligations
- Reporting responsibility stays with the manufacturer



Acting on Behalf

- Represent the manufacturer in the EU
- Act as communication channel for authorities & users



Support to Authorities

- Assist market surveillance authorities when requested
- Help with actions to remove or mitigate risks for products with digital elements under their mandate

Reporting Obligations for Market Surveillance Authority (MSAs)



Receiving Notifications

- **Receive information** on actively exploited vulnerabilities & severe incidents via CSIRTs & ENISA.



Coordinated Action

- Work with **CSIRTs & ENISA** to oversee reporting.
- **Verify manufacturers** take appropriate corrective actions.



Enforcement Powers

- If **non-compliance or confirmed risk**:
- Order **corrective measures**
 - **Restrict or prohibit** market placement
 - Require product **withdrawal** or recall
 - **Impose fines** where appropriate



Information Sharing

- Coordinate with other authorities.
- For high-risk AI systems: **AI Act MSA** takes the lead, coordinate with **CRA-designated MSAs, CSIRTs, and ENISA** regarding vulnerabilities and incident reporting.

Reporting Obligations for Notified Body

No Reporting Duties

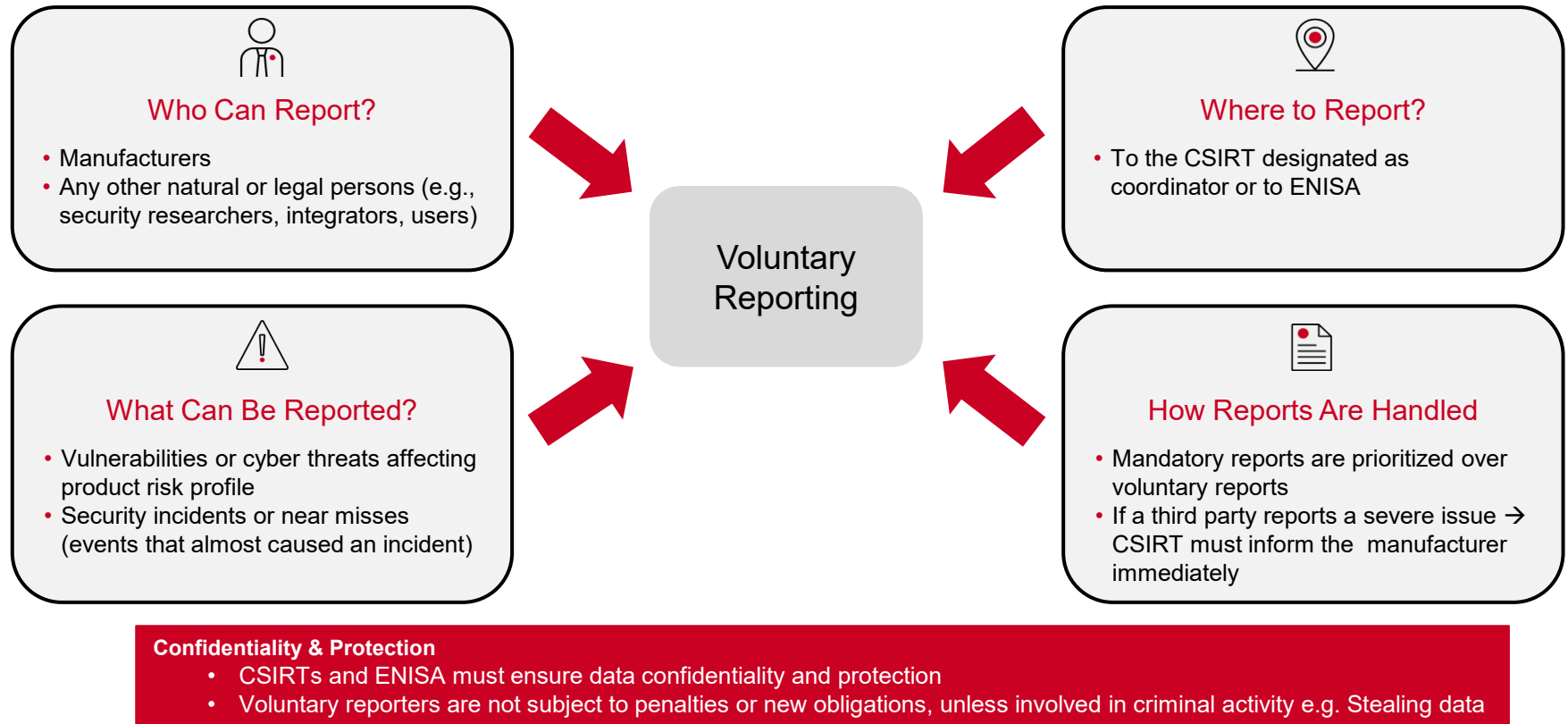


Not required to report vulnerabilities or incidents to CSIRTs/ENISA.



Article 14 obligations remain strictly with manufacturers, open-source stewards, or economic operators acting as manufacturers.

Voluntary Reporting



Topics

1. Reporting obligation of different actors
2. **Reporting platform**



Single Reporting Platform



Centralized Platform

- ENISA manages the **EU reporting platform** as a single access point for manufacturers, **integrated with Member States' CSIRTs**.



Notification Handling

- Manufacturers **report to ENISA**, CSIRT **Coordinator receives** it, and shares with all **relevant Member States' CSIRTs**.



Delayed Dissemination

- Dissemination may be temporarily delayed if **vulnerability** under coordinated disclosure process, **information is too sensitive** for Member State interests and there is **Immediate risk escalation** from premature disclosure



Market Surveillance Support

- CSIRTs forward essential information to **Market Surveillance Authorities (MSAs)** and helps MSAs enforce actions such as **corrective measures, restrictions, recalls, fines**.



Platform Security

- ENISA ensures security through **technical, operational, and organizational measures** and must **notify CSIRT and the EU Commission** if the platform suffers security incident.



Technical Cooperation

- **ENISA and CSIRTs** jointly establish detailed security & operational protocols for notification handling, especially for vulnerabilities without available fixes and information is shared only on a **need-to-know basis**



Coordination with Vulnerability Disclosure

- Notifications related to coordinated vulnerability disclosure procedures may be delayed but manufacturers can still notify **voluntarily at any time**.

Key Takeaways

- **Manufacturers** must report severe security incidents and actively exploited vulnerabilities **without undue delay** via the **EU's single reporting platform**.
- **Open-source stewards** must also report incidents impacting their development infrastructure.
- Users must be informed promptly **by the manufacturer** about **vulnerabilities** or **incidents** and any **necessary mitigation actions**.
- **Authorized representatives** must support authorities, including providing technical documentation and assisting in incident response if mandated.
- Notified Bodies do not have direct reporting duties for vulnerabilities or incidents.
- **Market Surveillance Authorities** (MSAs) receive reports via CSIRTs/ENISA, oversee incident handling, enforce actions, and coordinate with AI Act authorities for high-risk AI products.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
- 7. The Product Lifecycle and Essential CRA Requirements**
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Topics

1. CRA and the Product Lifecycle Mindset
2. CRA Essential Requirements Meets Lifecycle



Topics

1. **CRA and the Product Lifecycle Mindset**
2. CRA Essential Requirements Meets Lifecycle



CRA and the Product Lifecycle Mindset

Cybersecurity must cover the full product lifecycle

- The CRA legally requires manufacturers to implement cybersecurity measures across the entire **Product Life-Cycle (PLC)** – from Conception through End-of-Life.
- This includes **design, development, testing, release, operation, monitoring** and **decommissioning**.
- CRA reflects a shift from *a reactive “fix and forget” security approach* to proactive and holistic **Secure Product Life-Cycle Management**.
- Cybersecurity is no longer a one-time or isolated practice – it is a **continuous responsibility** manufacturers must achieve throughout the product’s entire life in the market.

A Typical Product Lifecycle (PLC):



Automotive SPICE as basis for Cybersecurity

ID	Name
<u>Automotive SPICE v3.1</u>	
SPL.2	Product Release
SYS.1	Requirements Elicitation
SWE.1	Software Requirements Analysis
SWE.2	Software Architectural Design
SWE.3	Software Detailed Design and Unit Construction
SWE.4	Software Unit Verification
SWE.5	Software Integration and Integration Test
SWE.6	Software Qualification Test
SUP.1	Quality Assurance
SUP.8	Configuration Management
SUP.9	Problem Resolution Management
SUP.10	Change Request Management
MAN.3	Project Management
MAN.5	Risk Management

→ Product Release Security:
technical file readiness

Security by design: Covers secure
software development from
requirements to qualification testing

→ Conformity assessment/ audit

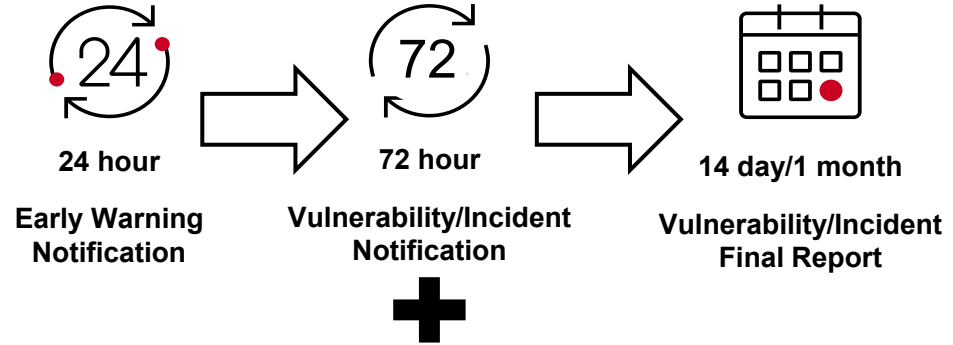
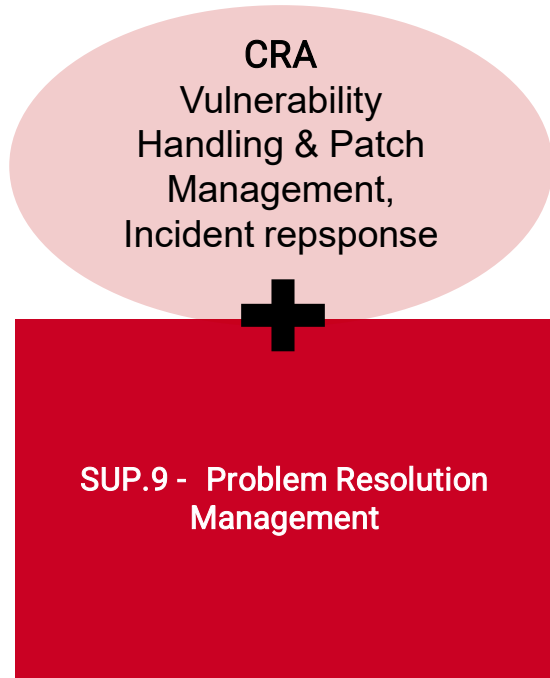
→ Basis for SBoM creation

Vulnerability Handling & Patch
Management, Incident response

→ Cybersecurity Risk Assessment

Practical Implementation Example

SUP.9 as basis for vulnerability & incident response



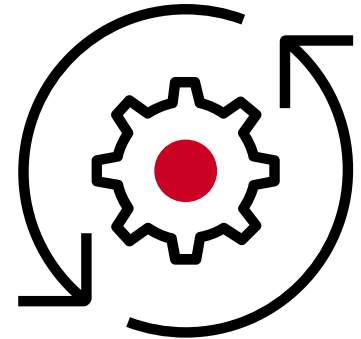
SUP.9 basis:

- requires **systematic problem identification**, which can include cybersecurity vulnerabilities
- defines a **structured problem resolution process**, which can be adapted for vulnerability mitigation and incident response
- mandates **logging and tracking of problems**, includes **verification of problem resolution**, ensuring vulnerabilities are **properly mitigated**
- supports **stakeholder communication** during problem resolution, which is essential for incident management

CRA Lifecycle Responsibilities

Maintenance and end-of-life support

- The **support period** for which the manufacturer ensures the effective handling of vulnerabilities should be **no less than five years**, unless the lifetime of the product with digital elements is less than five years.
- Keep the **technical documentation and user manual for at least 10 years** after the product with digital elements has been placed on the market, or for the support period, whichever is longer.
- Manufacturers shall ensure that the **end date of the support period** is clearly and understandably **specified at the time of purchase** in an easily accessible manner.
- Manufacturers shall ensure that each **security update remains available for a minimum of 10 years** after it has been issued, or for the remainder of the support period, whichever is longer.



Lifecycle Impact of Annex I Requirements

What You Must Build In — What You Must Respond To

- Two Parts to **Annex I** – Essential Cybersecurity Requirements:

Part 1

Cybersecurity Requirements Relating to the
Properties of Products with Digital Elements

Part 2

Vulnerability Handling Requirements

Topics

1. CRA and the Product Lifecycle Mindset
2. **CRA Essential Requirements Meets Lifecycle**



CRA Essential Requirements Meets Lifecycle

A Phase-by-Phase Breakdown of Cybersecurity Requirements

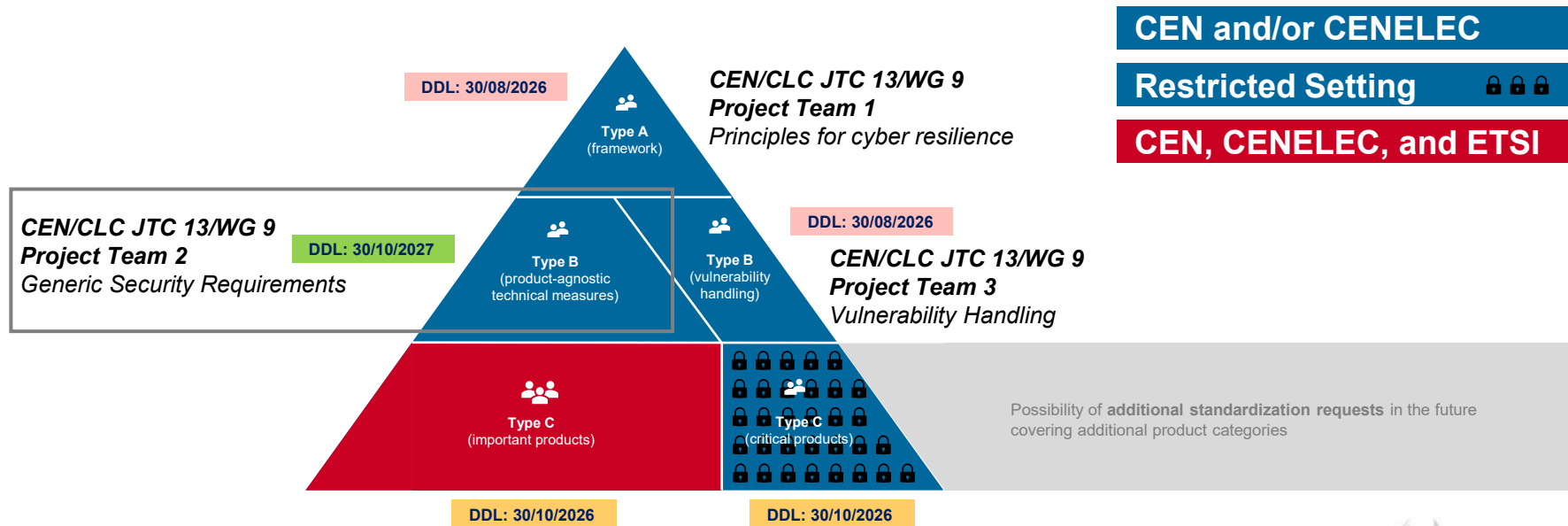
A Typical Product Lifecycle (PLC):



1. **Concept** explores product feature ideas and customer needs, including pursuit and RFI/RFQ activities.
2. **Plan** defines project scope, timeline, and product requirements to guide development.
3. **Develop** creates and evaluates designs for hardware and software elements.
4. **Build** implements software, builds prototype hardware, and develops manufacturing processes.
5. **Test** performs verification and validation to ensure the product meets all requirements.
6. **Release** commissions the product and kicks-off series production (SOP).
7. **Production** of software by compilation, building, packaging, providing download or physical media.
8. **Operation** supports product use through operation, maintenance, and service activities.
9. **Monitor** checks for vulnerabilities, responds to incidents, and maintains cybersecurity solutions.
10. **Retire** removes products from service and manages decommissioning and end-of-life activities.

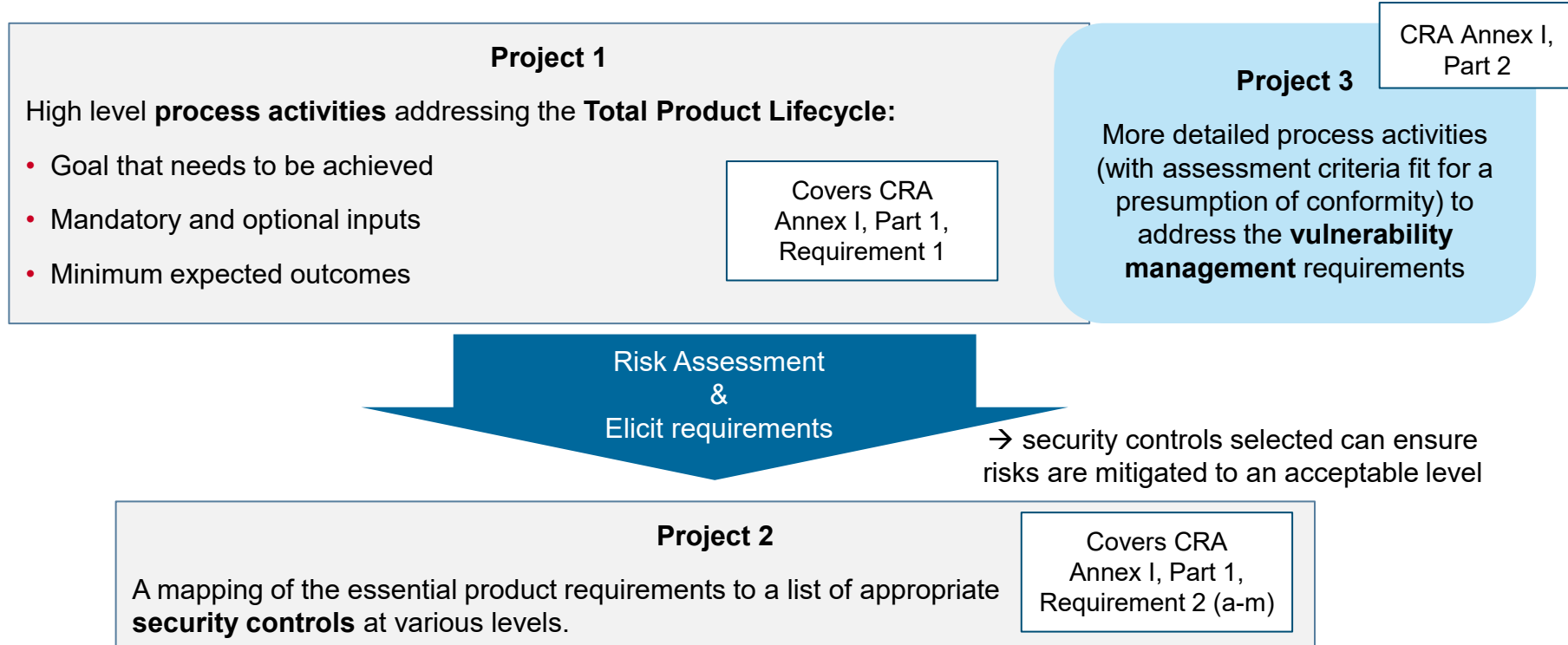
Understanding the Essential requirements

Guidance is on its way

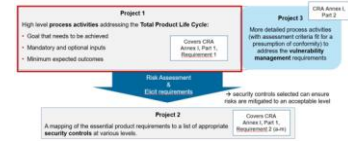


Source: Webinar on 26 February 2025 – Co-organised by Cyberstand.eu, HSbooster.eu & Stan4CR & CEN, CENELEC and ETSI Work Programme - Version: V 0.1

Interplay between the different deliverables



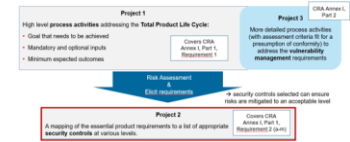
Focus of CEN/CENELEC Working groups



Project Team 1 (PT1): **Principles for Cyber Resilience** JT013089

- Establishes **generic cybersecurity principles** applicable to all stages of the product lifecycle;
- Specifies **requirements for risk assessment** and **treatment of cybersecurity risks**;
- Specifies **requirements on activities** that can be applied to ensure an appropriate level of cybersecurity at **every phase** of the **product lifecycle**;
- Provides **elements and considerations** for **product category specific standards** in order to facilitate a harmonized approach.

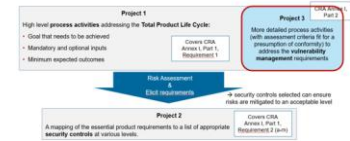
Focus of CEN/CENELEC Working groups



Project Team 2 (PT2): Develop a horizontal standard addressing Annex I Part II of the Cyber Resilience Act, as part of deliverable 2–14 under Standardization Request M/606.

- **Standard identifier** – The horizontal standard is designated as **JT13091**, titled “*Cybersecurity requirements for products with digital elements* — *Generic Security Requirements*.”
- **Scope – Product-centric**, providing a **collection of cybersecurity controls and assessment criteria** for products with digital elements.
 - **Reuses controls** from **EN 18031-X:2024**, ensuring consistency across standards.
- **Work method** – **Project Team 2 (PT2)** will use the **OSD (Online Standards Development)** platform for collaboration.
- **Supporting output** – PT2 will also produce a **Technical Report (TR)** explaining and justifying the **control selections** included in JT13091.

Focus of CEN/CENELEC Working groups



Project Team 3 (PT3): **Develop a harmonized horizontal standard for vulnerability handling** of products with digital elements, as required by **Standardization Request M/606**.

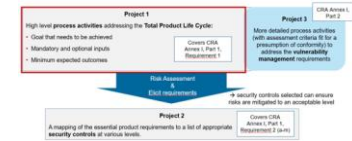
- **Scope** – Addresses the **Essential Requirements (1)–(8)** from **Annex I, Part II** of the **Cyber Resilience Act (CRA)** related to **vulnerability handling**.
- **Timeline** – The **publication** of this standard is targeted for **August 30, 2026**.
- **Structure** – The standard's structure follows the **phases of the Coordinated Vulnerability Disclosure (CVD)** process, aligned with:
 - **ISO/IEC 29147:2018** (Vulnerability disclosure)
 - **EN ISO/IEC 30111:2019** (Vulnerability handling processes)
- **Key characteristic** – Among the horizontal standards (PT1, PT2, PT3), **PT3** is the **only one likely to be cited** in the **Official Journal of the EU**, granting **presumption of conformity** with CRA Annex I, Part II.

Essential Cybersecurity Requirements – Annex 1

Part 1: Cybersecurity requirements relating to the properties of products with digital elements

1. Products with digital elements shall be **designed, developed and produced** in such a way that they **ensure** an appropriate level of **cybersecurity based on the risks**.

Project 1 - Cybersecurity Principles

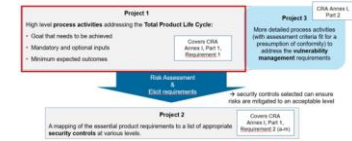


Risk-Based Approach	Security by Design	Security by Default	Transparency
Efforts and resources are prioritized to address the highest risks first , using methods to ensure cybersecurity measures align with threat impact and likelihood to prioritize protections effectively.	Hardware and software must consider security during development , not after deployment — preventing vulnerabilities at the root.	Product is as secure as possible out-of-the-box without any additional security configurations, minimize vulnerabilities without user intervention.	Manufacturers must provide easy-to-understand security details , helping users to make better purchasing decisions and boosting trust. Support open communication about cybersecurity risks and their mitigation.



These principles are fundamental for compliance with the essential requirements. Activities are established to enable compliance with these principles.

Project 1: Lifecycle Activities



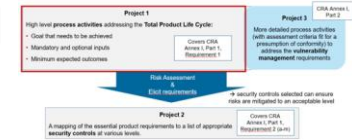
Definition:

A set of cybersecurity activities applied across all stages of the product lifecycle, from planning to decommissioning.

Key Elements:

- Develop a cybersecurity plan with defined roles and responsibilities
- Design secure architecture and implementation (SBOM, coding standards)
- Conduct verification and validation (e.g., penetration testing, fuzzing)
- Ensure secure production (digital and physical)
- Manage cybersecurity issues and monitor product post-deployment
- Plan for secure decommissioning and data deletion





Principle 1: Risk-Based Approach

Definition:

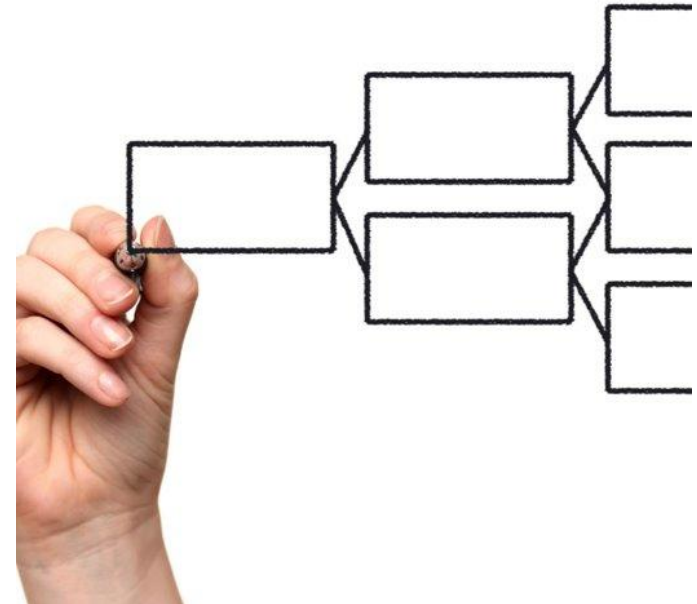
Cybersecurity measures should be **proportional to the risk level**, based on likelihood and impact.

Key Components:

- **Establish context** (use, environment, user)
- **Risk assessment:** Identify → Analyze → Evaluate
- **Risk treatment:** Avoid, reduce, share, accept
- Continuous **monitoring and review**

Benefits:

- Efficient resource allocation
- Informed decision-making



Principle 2: Security by Design

Definition:

Integrate cybersecurity from concept through lifecycle — NOT as an afterthought.

Key Elements:

- **Least Privilege:** Minimal access rights.
- **Attack Surface Minimization:** Reduce entry points (e.g., disable unused ports).
- **Defense in Depth:** Multiple layers of security.
- **Secure Coding Practices:** Avoid hard-coded credentials, validate inputs.
- **Avoid Security by Obscurity:** Transparency in design.

Benefits:

- Resilient products, reduced vulnerabilities.



Examples

- Use **memory-safe** and **defensive programming** to eliminate memory corruption risks and attack paths
- Architect with **secure hardware features** (e.g., Secure Boot, HSM)
- Apply **threat modeling** (e.g., STRIDE) during design
- Design with **secure/encrypted communication protocols**
- Conduct **Static/Dynamic Application Security Testing (SAST/DAST)**
- Use **code obfuscation or hardening** for mission-critical algorithms
- Design for **secure update infrastructure** (signed updates, secure channels)

Principle 3: Security by Default

Definition:

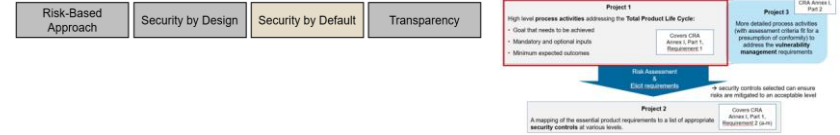
Products should ship with **secure configurations enabled by default**.

Key Points:

- **No user action required** for baseline security.
- **Reduces human error** and **protects non-technical users**.
- **Default settings** should **minimize vulnerabilities**.

Benefits:

- Immediate protection upon deployment.
- Promotes a proactive stance on cybersecurity



Examples

- **Eliminate or randomize default passwords** in production devices (e.g. routers shipped with unique, strong passwords instead of “admin/admin”)
- Enforce **Multi-Factor Authentication (MFA)** for admin and privileged users
- Enable **secure configuration defaults** (e.g., least privilege, disabled ports)
- Enable **audit logging** and **secure log storage** by default
- Ship products with **minimal exposed services** (disable unnecessary features)
- **Preload signed updates** and **rollback protection** mechanisms
- Disable **debug interfaces** and **developer backdoors** in production builds

Principle 4: Transparency

Definition:

Communicate cybersecurity-related information to stakeholders.

Key Elements:

- Threats and vulnerabilities
- Risk treatment measures
- Incident notifications

Benefits:

- Builds trust
- Enables informed decisions

Example:

Vendor publishes vulnerability advisories and patch timelines.



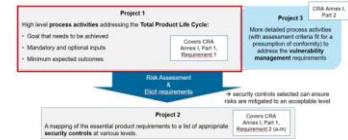
Project 1: Risk Management Framework

Definition:

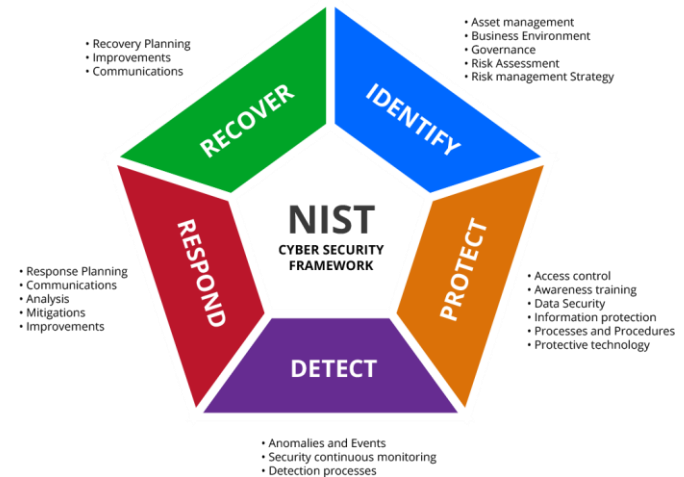
A structured approach to identify, assess, treat, and monitor cybersecurity risks throughout the product lifecycle.

Key Elements:

- Establish product context (use, environment, user)
- Perform applicability analysis (EU Regulation 2024/2847)
- Define risk acceptance criteria
- Consult stakeholders
- Assess, treat, and monitor risks
- Communicate and review outcomes

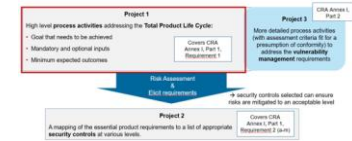


Example for established Risk Management Frameworks:



Source: [Understanding NIST Risk Assessment Framework: A Practical Approach](#)

How to Integrate the CRA Risk Management Requirements into your SecDevOps



CRA Risk Requirement	SecDevOps Phase	Supporting Mechanisms
Threat/Risk Identification	Plan / Design	Threat modelling, risk assessment tools (e.g., OWASP Threat Dragon, STRIDE, MITRE ATT&CK, Space Shield, ...)
Security-by-Design & Default	Design / Implement	Security requirements, secure/security libraries (e.g., derived from risk models)
Vulnerability Management	Build / Test / Deploy / Operate	SAST, DAST, SCA, container scanning, patch management, dependency management (e.g., CodeQL, VUSC, OWASP Dependency Scan, ...)
Security Validation & Testing	Test	Automated security testing, manual penetration testing (e.g., Nikto, SQLmap, ...)
Documentation & Traceability	All phases	Secure Development Lifecycle artifact management, SBOM generation, logging (e.g., CycloneDX, SPDX, ...)
Conformity & Compliance Checks	Release / Operate	Compliance-as-code, policy-as-code, infrastructure-as-code

Table 2. Mapping CRA Requirements to SecDevOps phases



Source, both: [Cyber Resilience Act - Risk Management](#)

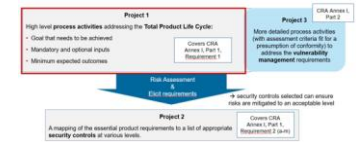
Third-Party Component Management

Definition:

Processes to ensure external components integrated into a product do not introduce unacceptable cybersecurity risks.

Key Elements:

- Risks from third-party components
- Due diligence before integration
- Authenticity and integrity checks
- Monitor end-of-support and obsolete tech
- Implement controls (encryption, authentication)
- Review and audit procedures



Essential Cybersecurity Requirements – Annex 1

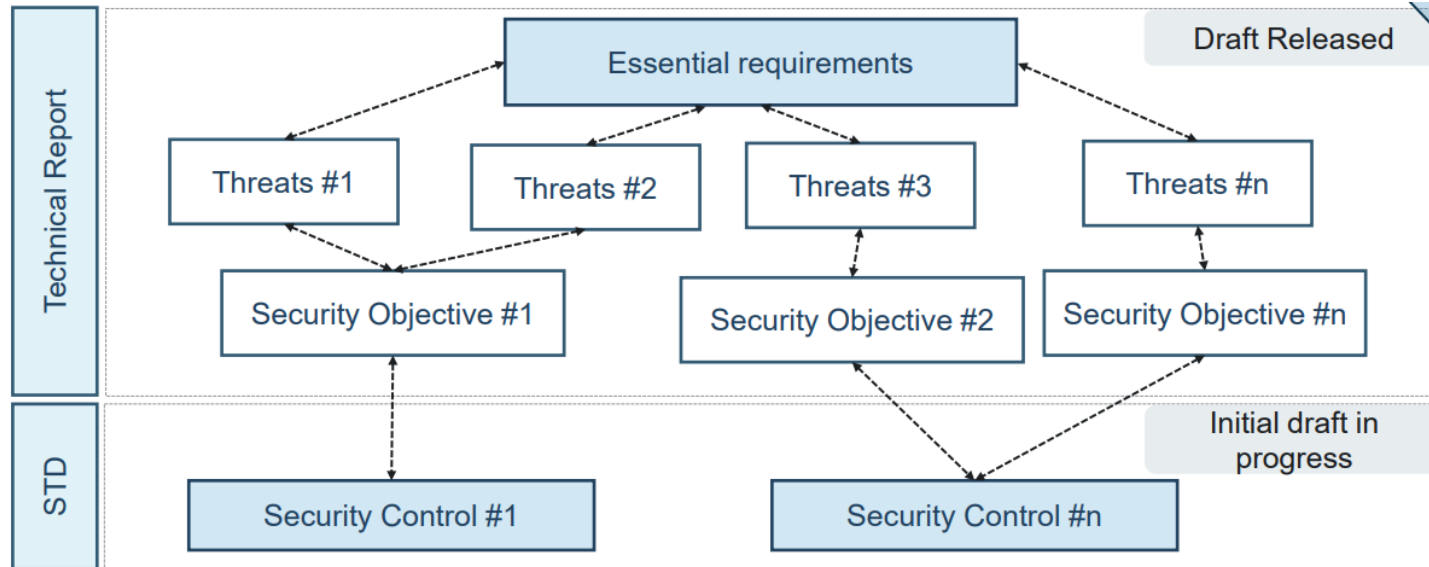
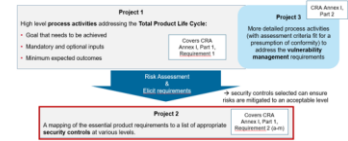
Part 1: Cybersecurity requirements relating to the properties of products with digital elements

On the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall: fulfill requirements a) to m)

Summarized:

- a. Vulnerability assessment
- b. Secure by default configuration
- c. Security updates
- d. Authorized access
- e. Confidentiality protection
- f. Integrity protection
- g. Data minimization
- h. Availability protection
- i. Minimize negative impact
- j. Attack surface minimization
- k. Reduce the impact of an incident
- l. Logging and monitoring controls
- m. Secure deletion mechanisms

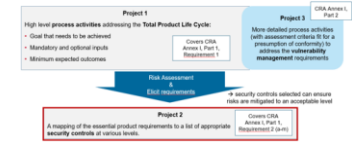
Project 2 - Generic security requirements



The deliverables provide a library of security controls with their objectives and more technical assessment criteria and builds upon the EN 18031:2024 series, and provides a mapping of the essential requirements to these security controls

Best Practices from EN 18031-X:2024

Example: Vulnerability Assessment



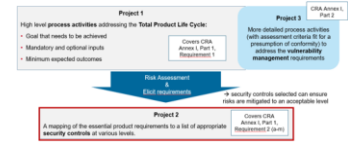
ANNEX I Part I (2) (a) be made available on the market without known exploitable vulnerabilities

Threat	Security Objective
Threat.KnownVulnerabilityExploitation	SO.VulnerabilityManagementProcess
Mapping with 18031-X:2024	
[GEC] General equipment capabilities [GEC-1] Up-to-date software and hardware with no publicly known exploitable vulnerabilities	
ADDED SECURITY CONTROLS	
NO ADDITION	

Source: Webinar CRA Standards Unlocked: Unlocking CRA Security Controls: preparation for UNE Event

Best Practices from EN 18031-X:2024

Example: Secure Configuration



ANNEX I Part I (2) (b) be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state

Mapping with 18031-X:2024

NO MAPPING

ADDED SECURITY CONTROLS

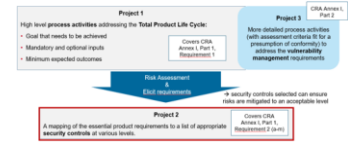
[GEC] General Equipment Capabilities

- [GEC-8] Secure default configuration
- [GEC-9] Secure startup configuration
- [GEC-10] Factory Reset

Source: Webinar CRA Standards Unlocked: Unlocking CRA Security Controls: preparation for UNE Event

Best Practices from EN 18031-X:2024

Example: Updates



ANNEX I Part I (2) (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;

Mapping with 18031-X:2024

[SUM] Secure update mechanism

- [SUM-1] Applicability of update mechanisms
- [SUM-2] Secure updates
- [SUM-3] Automated updates

ADDED SECURITY CONTROLS

[SUM] Secure update mechanism

- [SUM-4] Availability of updates [SSU-2]
- [SUM-5] Update Mechanism [SSU-3]
- [SUM-6] Timely Updates [SSU-5]
- [SUM-7] User Update Notifications [SSU-6]
- [SUM-8] Postponed Updates [SSU-7]

Source: Webinar CRA Standards Unlocked: Unlocking CRA Security Controls: preparation for UNE Event

CLC/TC65X WG3: Best Practices from EN IEC 62443-4

Example: Updates

(2) (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;	DM-1: Receiving notifications of security-related issues DM-3: Assessing security-related issues DM-4: Addressing security-related issues DM-5: Disclosing security-related issues Practice 7: Security update management (SUM)	Gap: Support for automatic updates (with an opt out) is not addressed
---	---	--

EU CRA – EN IEC 62443-4-1
Gap Analysis

EU CRA – EN IEC 62443-4-2
Gap Analysis

(2) (c) ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;	EDR/HDR/NDR 3.10: Support for updates	Gap: Support for automatic updates (with opt out) is not addressed in -4-2 There is no requirement on support for updates for software applications independent from the component where the software is installed. However, SW updates are indirectly addressed in EDR/HDR/NDR 3.10 RE (1) but controlled by the HW product.
---	---------------------------------------	---

- CLC/TC65X WG3 is Addressing different products / product-categories specified in EU CRA Annex III
- Limit potential market disruption due to unavailability of harmonized Standards (hENs)
- Mapping of EN IEC 62443-4 and CRA requirements

Exercise: Essential Requirements Workshop (60 min)



- 1. Introduction to the Challenge (15m)**
 - To align participants on the problem and establish a shared purpose.
- 2. Collaborate & Understand (30m)**
 - To build a shared, structured, detailed knowledge of the CRA Essential Requirements.
- 3. Brainstorm Solutions (30m)**
 - To generate a wide variety of creative ideas and potential paths forward.
- 4. Next Steps & Call to Action (15m)**
 - To convert ideas into a concrete plan with ownership.

Our Mission: Defend the City!

Introduction to the Challenge (15m)

Today, we face a new challenge:

- **The City:** Represents our products, our teams, and our company. It's everything we've built and need to protect.
- **The Dragon:** A powerful new threat representing cyber vulnerabilities and the risks of CRA non-compliance.
- **Our Plan:** The **CRA's Essential Requirements** are not just rules; they are our strategic blueprint for building the defenses that will protect our city and help us thrive.
- **Your task for this session:** **Turn the blueprints into a winning defense.**

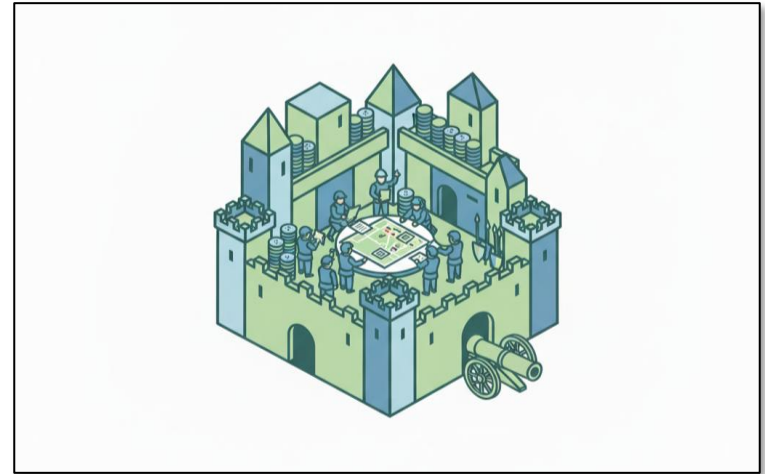


*A fearsome dragon appeared on the horizon,
threatening the peaceful city...*

Activity 1: Map the Dragon's Attack

Collaborate & Understand (30m)

1. **READ:** Review the CRA Essential Requirements provided to your group.
2. **DISCUSS:** Talk through what those requirements mean in your day-to-day language.
 - **What** is it really asking us to do?
 - **Who/What/When** does it impact?
 - Where does the requirement fit in the **development lifecycle**?
3. **SORT:** Write each requirement on a sticky note and group them into lifecycle themes on your board.
4. **NAME:** Give each theme a simple, clear title.

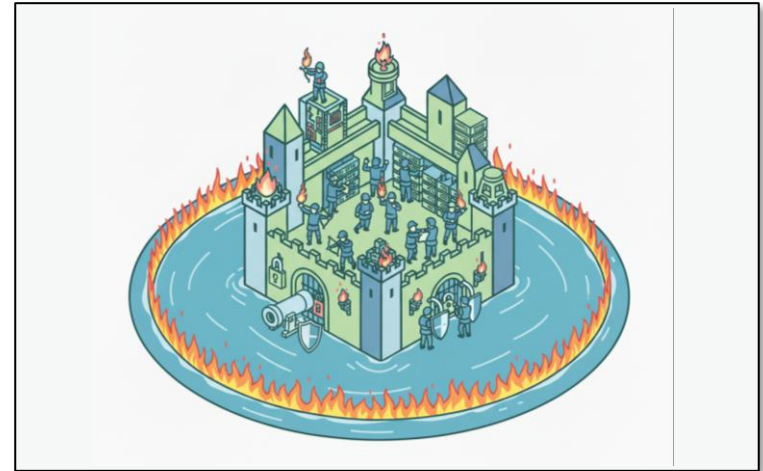


The city's wisest and bravest guards gathered to organize and assess their defenses...

Activity 2: Organize the Defenders

Brainstorm Challenges & Implications (30m)

1. **MAP:** Assign your team/role to a requirement theme which the team/role is responsible for.
2. **BRAINSTORM:** For your selected team/role, list the biggest challenges and obstacles to meeting those requirements.
3. **SHARE:** Briefly present your assigned requirements and the key challenges you foresee.



Through hard work and nerves of steel, they prepared a defense of fire, water, and steel...

Mobilize the Defenders!

Next Steps & Call to Action (15m)

- An idea is only as good as its execution. Let's turn our discussion into a concrete plan!
- For our top "Do Now" ideas, we will agree on the following:
 - **WHO:** Who will own this action item and see it through?
 - **WHAT:** What is the specific, tangible next step to be taken?
 - **WHEN:** What dependencies, relationships, sequences must we consider?
- **Outcome:** A starting-point strategy we will use to start building a more resilient city, today.



*Their forces met the beast; their well-laid plans
turning the tide of battle!*

Key Takeaways

- **Lifecycle-wide responsibility:** CRA transforms cybersecurity from a development task into a continuous obligation spanning concept through retirement
- **Early security integration:** Critical security decisions and processes must be established in concept and planning phases, not retrofitted later
- **Pre-SOP foundation:** Development, build, and test phases focus on embedding security controls and ensuring products ship without known vulnerabilities
- **Post-SOP dominance:** Operation and Monitoring phases contain the most extensive ongoing requirements for updates, surveillance, and incident response
- **Manufacturer accountability:** Companies remain legally responsible for security throughout the product's entire market life, including end-of-life communication
- **Process transformation required:** CRA shifts organizations from reactive "fix and forget" approaches to proactive, structured security lifecycle management

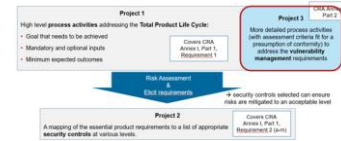


Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. **Vulnerability Management**
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Essential Requirements - Vulnerability Handling

Annex 1, Part 2



Manufacturers of products with digital elements shall:

- Identify, **document vulnerabilities**, and **components** contained in products (**SBOM**)
- **Remediate** vulnerabilities **without delay** (incl. Updates)
- **Regular test and review** of the security of the product
- **Inform** on fixed vulnerabilities
- Have a Coordinated **Vulnerability Disclosure (CVD) Policy** in place
- Intake of **potential vulnerabilities**
- Secure distribution of **updates**, automatic if applicable
- Update available and related dissemination, free of charge, incl. advisory message



Vulnerability handling vs. Incident handling

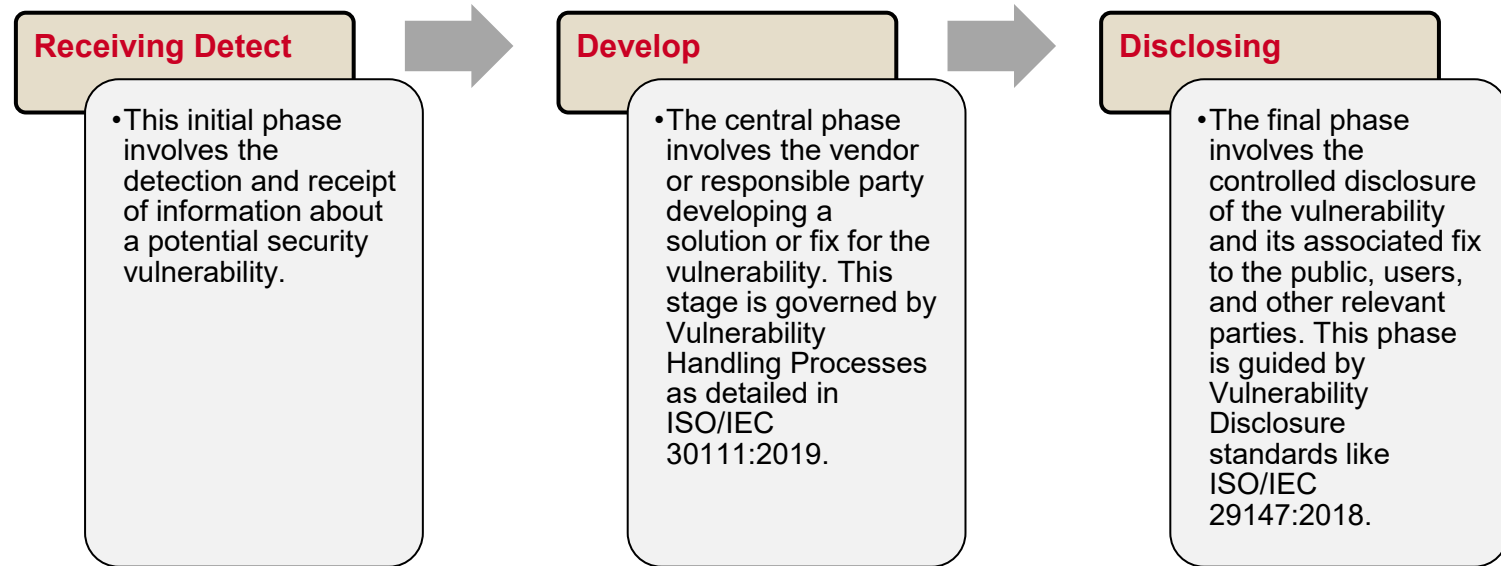
Feature	Vulnerability Handling	Incident Response
Objective	To prevent security incidents from occurring	To recover from security incidents that have occurred
Core Focus	System weaknesses and flaws	Active security breaches and attacks
Approach	Proactive (Preventative)	Reactive (Restorative)
Key Activities	Vulnerability scanning, system patching, configuration hardening	Containment, eradication, and system recovery
Time Frame	Ongoing and continuous effort	Event-driven (Starts upon detection)



Vulnerability handling is concerned with detecting and addressing weaknesses in systems and applications to reduce the risk of exploitation and proactively prevent security incidents. **Incident handling**, by contrast, deals with managing and recovering from security events after they have taken place.

The Vulnerability Lifecycle

The process outlines how security weaknesses are discovered and addressed, primarily following the guidance of ISO/IEC standards.



The standards ISO/IEC 29147 and ISO/IEC 30111 mainly cover straightforward cases between a single reporter and a single vendor. For more complex situations involving multiple organizations or vendors, ISO/IEC TR 5895:2022 provides guidance on coordinated vulnerability disclosure and handling across several parties.

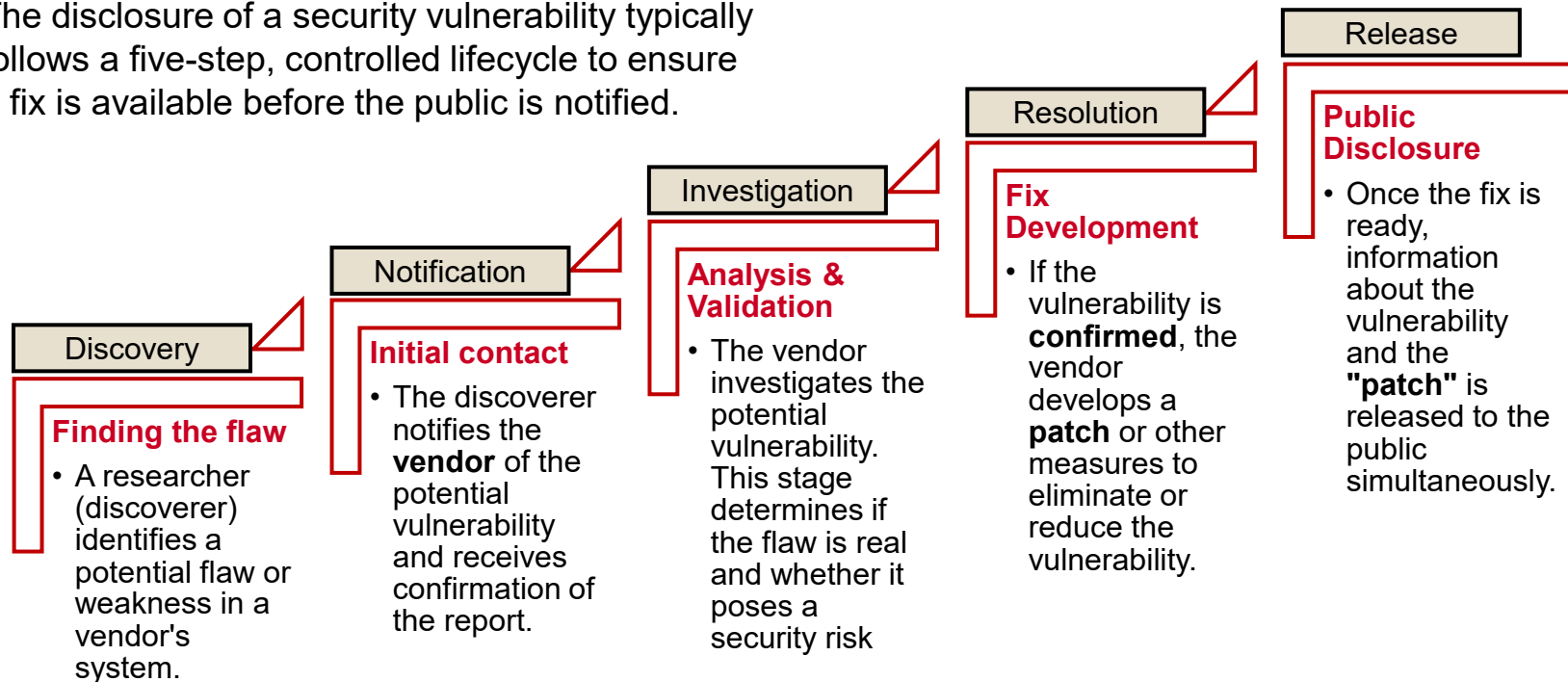
Overview of Key Vulnerability Standards

Feature	ISO/IEC 29147:2018 (Disclosure)	ISO/IEC 30111:2019 (Handling)
Core Focus	External Actions (What the public/reporters see)	Internal Procedures (What the organization does)
Purpose	Defines how to receive, coordinate, and publish vulnerability information.	Defines how to process, manage, and fix vulnerabilities internally.
Key Topics	1. Disclosure Policy: Rules for dealing with vulnerabilities publicly. 2. Receiving Reports: Procedures for accepting vulnerability submissions. 3. Publishing Advisories: How and when to release public information. 4. Coordination: Working with reporters and other parties.	1. Organizational Framework: Roles, responsibilities, and overall policy. 2. Handling Process: Steps for Verification, Remediation, Development, and Release. 3. Process Monitoring: How to track and improve the handling process. 4. Confidentiality & Supply Chain: Securing information and managing third-party risks.

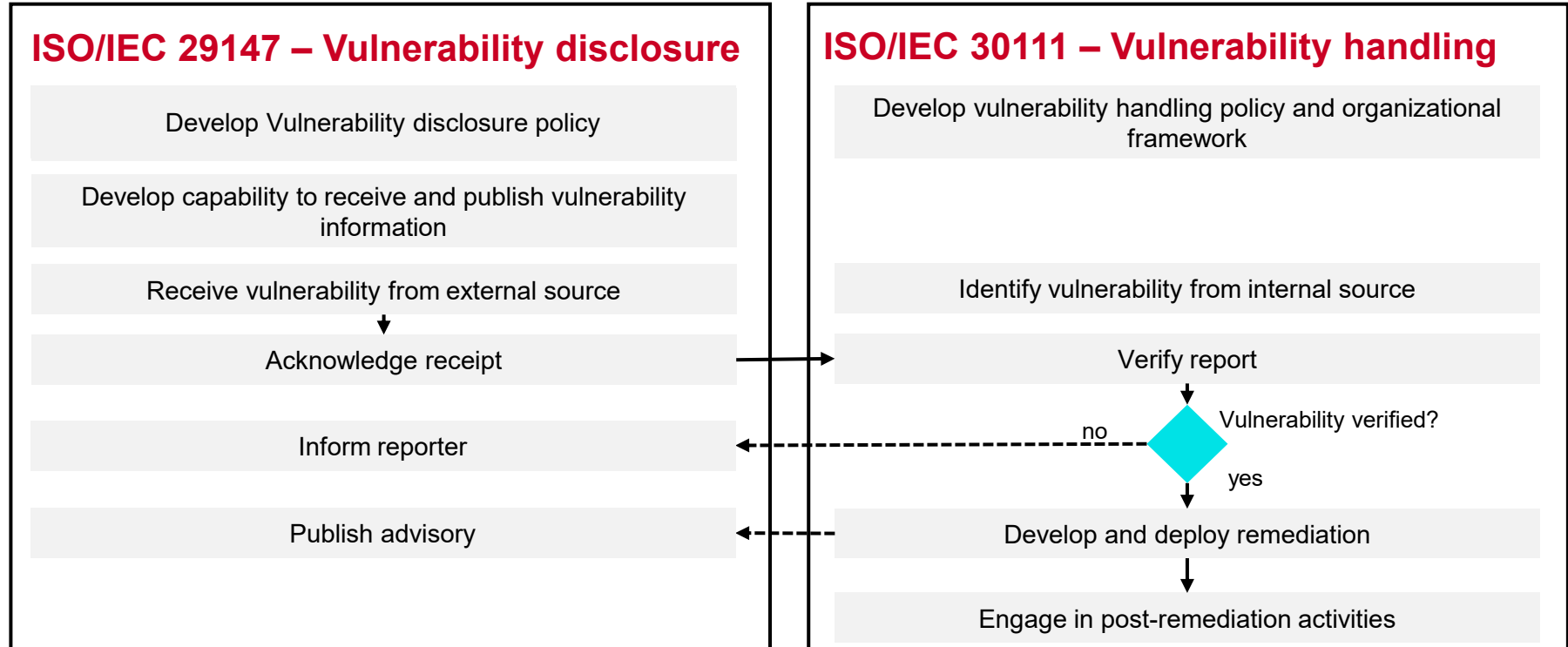


Coordinated Vulnerability Disclosure Process

- The disclosure of a security vulnerability typically follows a five-step, controlled lifecycle to ensure a fix is available before the public is notified.



Understanding the Relationship: ISO 29147 & ISO 30111



Exercise:

Coordinated Vulnerability Disclosure (CVD) Policy



1. Think about the content of a **Coordinated Vulnerability Disclosure (CVD) Policy**.
2. Discussion in Group Forum (15 min)



Good example: Cisco

https://sec.cloudapps.cisco.com/security/center/resources/security_vulnerability_policy.html#Policy



Products and Services

Solutions

Support

Learn

Why Cisco

[Trials and demos](#)

https://sec.cloudapps.cisco.com/security/center/resources/vendor_vulnerability_policy.html

Home / Cisco Security

Security Vulnerability Policy



If you are experiencing a security vulnerability emergency, see [Cisco PSIRT Contact Information](#).

Other contact information:

- [Public Relations and Press Queries](#)
- [General Security-Related Queries](#)

Purpose
Policy
Public Relations or Press Queries
Commitment to Product Security
and Integrity
Cisco Product Security Incident
Response
Cisco PSIRT Contact
Information
General Security-Related
Queries
Incident Response
Assistance
Channels For Security
Vulnerability Information
Email Details
Cisco Process for Product
Security Incident Response
Assistance and

Purpose

This policy was created to guide and inform Cisco customers in the event of a reported vulnerability in a Cisco product or cloud-hosted service. It ensures that Cisco customers have a consistent, unambiguous resource to help them understand how Cisco responds to events of this nature.

Policy

This policy clearly states how Cisco addresses reported security vulnerabilities in Cisco products and cloud-hosted services, including the timeline, actions, and responsibilities that apply to all customers.

Public Relations or Press Queries Regarding Cisco Security Vulnerability Information

Members of the media with queries about Cisco security vulnerability information can contact [media_pr@cisco.com](#).



Vendor Vulnerability Reporting and Disclosure Policy

Purpose

This policy sets forth the reporting and disclosure process that Cisco Systems, Inc. and its subsidiaries (collectively, "Cisco") follow when we discover security vulnerabilities in non-Cisco products and services.

Policy

This policy must clearly state the timeline, actions, and responsibilities equally available to all non-Cisco vendors.

Vendor Vulnerability Reporting and Disclosure

If a vulnerability is found in a vendor's product or service, Cisco will attempt to contact the vendor by email to notify the vendor of such discovery. Cisco will initially attempt to create a secure communication channel with the vendor by exchanging PGP keys for encrypted email. If a secure communication channel is successfully created, then an encrypted copy of the vulnerability report will be sent to the vendor through that channel. If no response to the attempt to create a secure communication channel is received by Cisco within seven (7) days, then a description of the vulnerability will be sent by email to the vendor in plain text.

Our approach to vulnerability disclosure is based on industry standards and the Carnegie Mellon University Computer Emergency Response Team (CERT) vulnerability policy. For additional information, see the [CERT disclosure guidelines](#).

If Cisco discovers a vulnerability in a vendor's product or service, it will take the following steps:

	Actions to be Taken by Cisco
Day 0	• Initial vendor contact • Protections released to Cisco customers for Cisco security products • Cisco may also use this vulnerability information prior to publication to enhance certain Cisco security products • Assignment of CVE (Common Vulnerabilities and Exposures) if vendor is not a CNA (CVE Numbering Authority) • Vendor name and report date listed on Cisco Talos vulnerability tracker website
Day 7	• Second vendor contact if there is no response to Cisco's initial communication
Day 45	• Reminder email sent to the vendor with the release date of the vulnerability report
Day 60	• If the vendor has not responded or has stopped responding, a final reminder email will be sent



Solutions

Source: https://sec.cloudapps.cisco.com/security/center/resources/vendor_vulnerability_policy.html

SOFTWARE INTENSIVE SYSTEMS 186

Definition: SBOM – Software Bill Of Materials

Key for Vulnerability Management

- An SBOM is a formal record containing the details and supply chain relationships of various components used in building software.

IEEE Citation

C. Woody, "Applying the SEI SBOM Framework," *Carnegie Mellon University, Software Engineering Institute's Insights (blog)*. Carnegie Mellon's Software Engineering Institute, 5-Feb-2024 [Online]. Available: <https://doi.org/10.58012/5eh5-5862>. [Accessed: 24-Jan-2025].

4.1 SBOM

(Software Bill of Materials)

list of one or more identified components, their relationships, and other associated information

The SBOM for a single component with no dependencies is just the list of that one component. "Software" can be interpreted as "software system," thus hardware (true hardware, not firmware) and very low-level software (like CPU microcode) can be included. The primary focus of this effort is software components; however, hardware is not excluded.

NTIA Citation

https://www.ntia.gov/files/ntia/publications/ntia_sbom_framing_2nd_edition_20211021.pdf

NTIA Multi-stakeholder Process on Software
Component Transparency

Framing Working Group

2021-10-21

Software Supply Chain challenges and impacts

Challenges

Weaker links between dependencies

Unclear commercial relationships

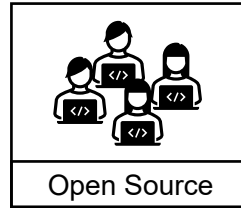
Constant changes in the software

Impacts

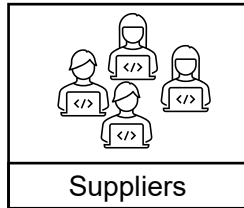
Recalls and upgrades of physical goods

Software is characterized by shift in requirements, continuous changes, vulnerabilities

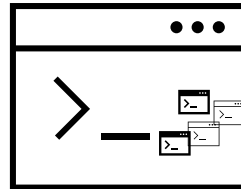
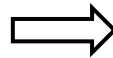
Complex dependencies



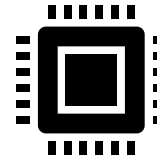
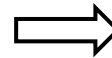
Suppliers decide on using potential open-source software components for their products



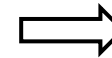
Suppliers (Tier 1, Tier 2, etc.) develop their own software components



Suppliers integrate the developed and acquired software components



Software updated on the intended hardware and delivered to the OEMs



Manufacturers use the delivered hardware components in their products during production

Software Supply Chain challenges and impacts

Challenges

Weaker links between dependencies

Unclear commercial relationships

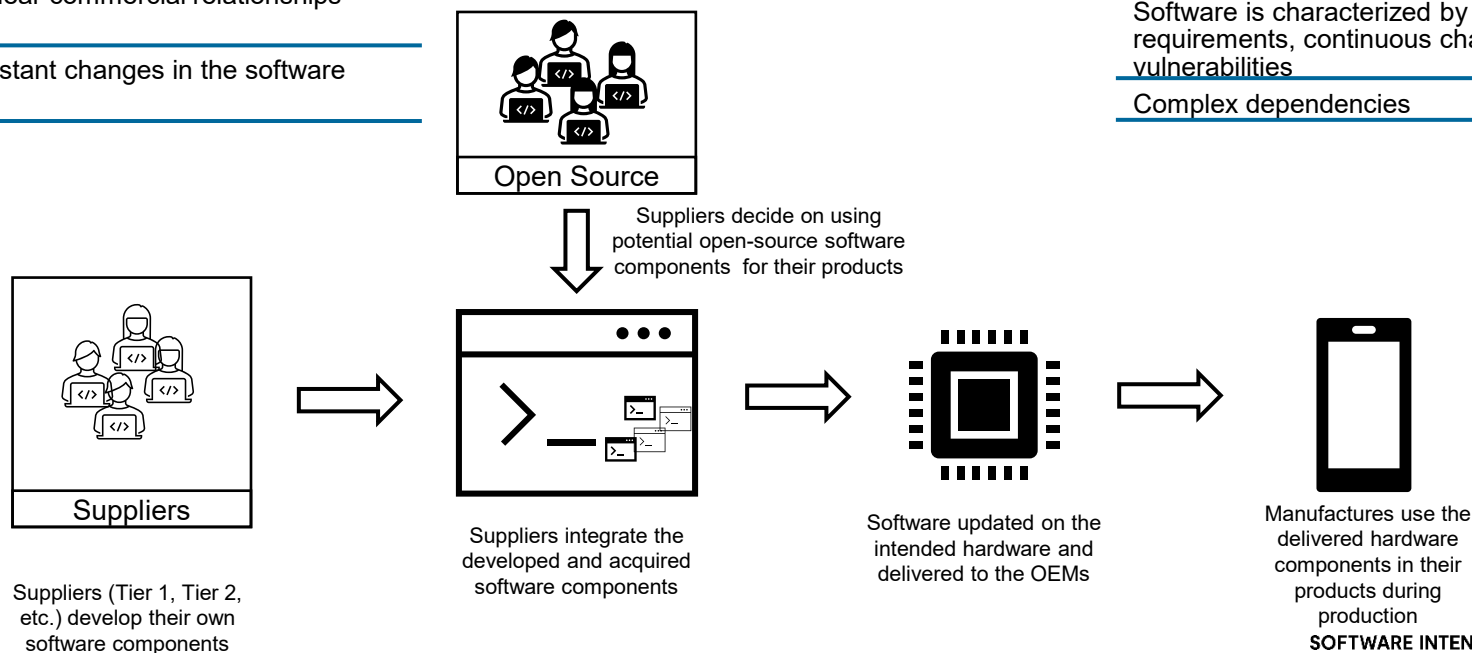
Constant changes in the software

Impacts

Recalls and upgrades of physical goods

Software is characterized by shift in requirements, continuous changes, vulnerabilities

Complex dependencies



SBOM Format



SPDX®

Software package data exchange

- The Linux Foundation
- ISO/IEC 5962:2021 reflects SPDX® V2.2.1, current V3.0

CDX

CycloneDX

- **O**pen **W**orldwide **A**pplication **S**ecurity **P**roject
- Current Version: V1.6

Minimum Content

- **NITA** and **BSI** (in **TR-03183-2**) specify minimum content
- BSI requires **CycloneDX 1.4** or **SPDX® 2.3** or greater
- At least:

Supplier Name

Component Name

Component Version

SBOM Author

Other unique Identifiers

Dependency Relationships

SBOM Timestamp

Software Identification



Vendor



- Changes in ownership
- Changes in name
- Open Source Contributors

Name



- Spelling differences
- Changes in name
- Name conflicts

Version



- Granularity
- Vended Version

What identifies a software?

Package URL – purl

- Succinct identifier through a “pkg” URL

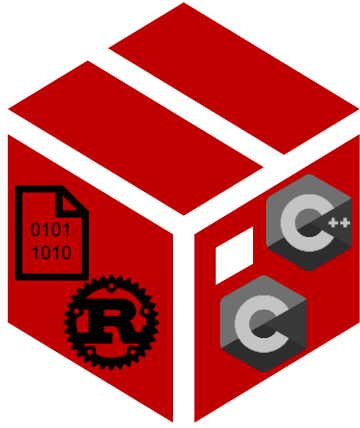
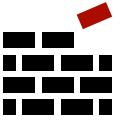
scheme:type/namespace/name@version?qualifiers#subpath

Software Identification – SWID

- XML-based software tag specified in ISO/IEC 19770-2:2015

```
<SoftwareIdentity
name="ACME Roadrunner Management Suite Coyote Edition"
tagId="com.acme.rms-ce-v4-1-5-0"
tagVersion="0"
version="4.1.5">
```

Build Systems



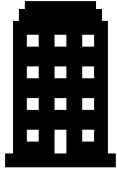
Polyglot Projects

- Multiple languages
- Binary blobs
- Various packaging mechanisms

Usage of Meta Build Systems

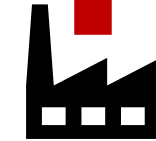
- How to identify build dependencies?
- How to identify various programs?
- How integrate the SBOM generation?

Supplier Management



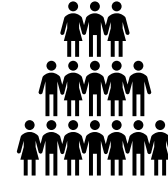
Commercials Off The Shelf (COTS) Vendor

- Sometimes provide SBOM
- Might be required due to regulation
- Might provide SBOM through contractual obligations



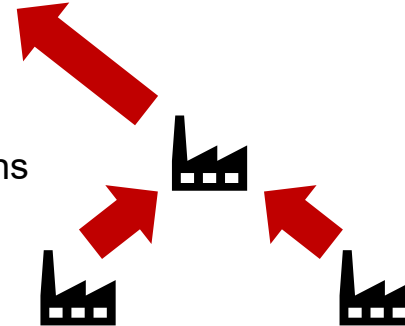
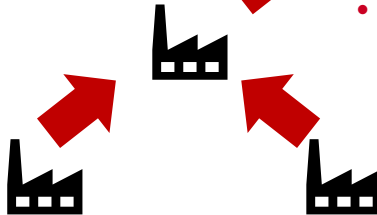
Suppliers

- SBOM through contractual obligations



Open-Source Project

- Sometimes provide SBOMs
- Might offer commercial support
- Open to SBOM contribution



Lifecycle Challenges



When to perform Common Vulnerability and Exposures (Lifecycle) Scanning?

- Frequency should enable quick reaction
- Nightly or Weekly are common

Who is responsible for SBOM Maintenance and Lifecycle Scanning before and after SOP?

- Process should ensure continuance and long-term stability
- Software Updates require adaption not only of tracked versions, but also tracked Lifecycles
- Handle post-market surveillance on an organizational level, e.g. with a central team

SBOM Benefits: General

General Benefits

Enhanced Security: SBOMs provide detailed visibility into software components, helping identify and mitigate vulnerabilities more effectively.

Improved Compliance: They ensure compliance with regulatory requirements by documenting all software components and their origins.

Transparency: SBOMs offer transparency in the software supply chain, making it easier to track and manage dependencies.

Risk Management: They help in assessing and managing risks associated with third-party components.

Efficient Incident Response: In case of a security incident, SBOMs enable quicker identification of affected components, reducing response times.

Key Takeaways

- Manufacturers must **track** and **fix** vulnerabilities, maintain an **SBOM**, give **secure free updates**, and run a clear **CVD** process.
- **ISO/IEC 29147** and **30111** address simple one-to-one vulnerability cases, while **ISO/IEC TR 5895:2022** guides coordinated disclosure across multiple organizations.
- **SBOMs** are essential for modern software security, compliance, and operational efficiency.

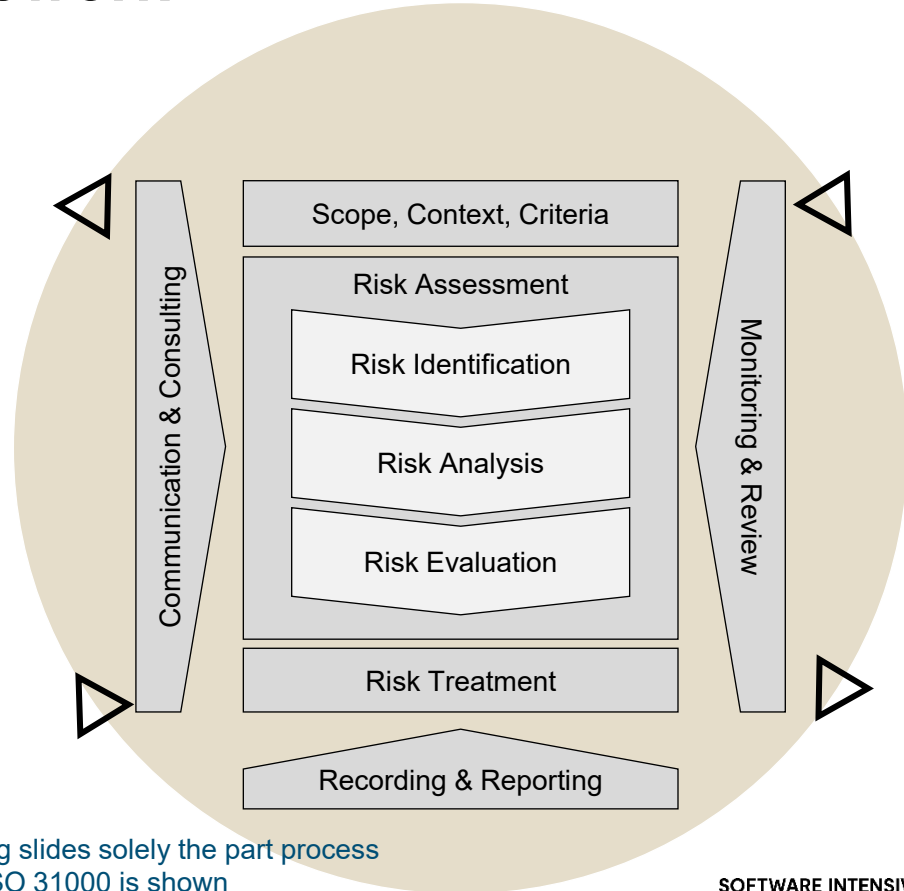


Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
- 9. Risk Management for Cyber Resilience**
10. Conformity Assessment Procedures
11. Real World Use Case Examples

Risk Management Framework

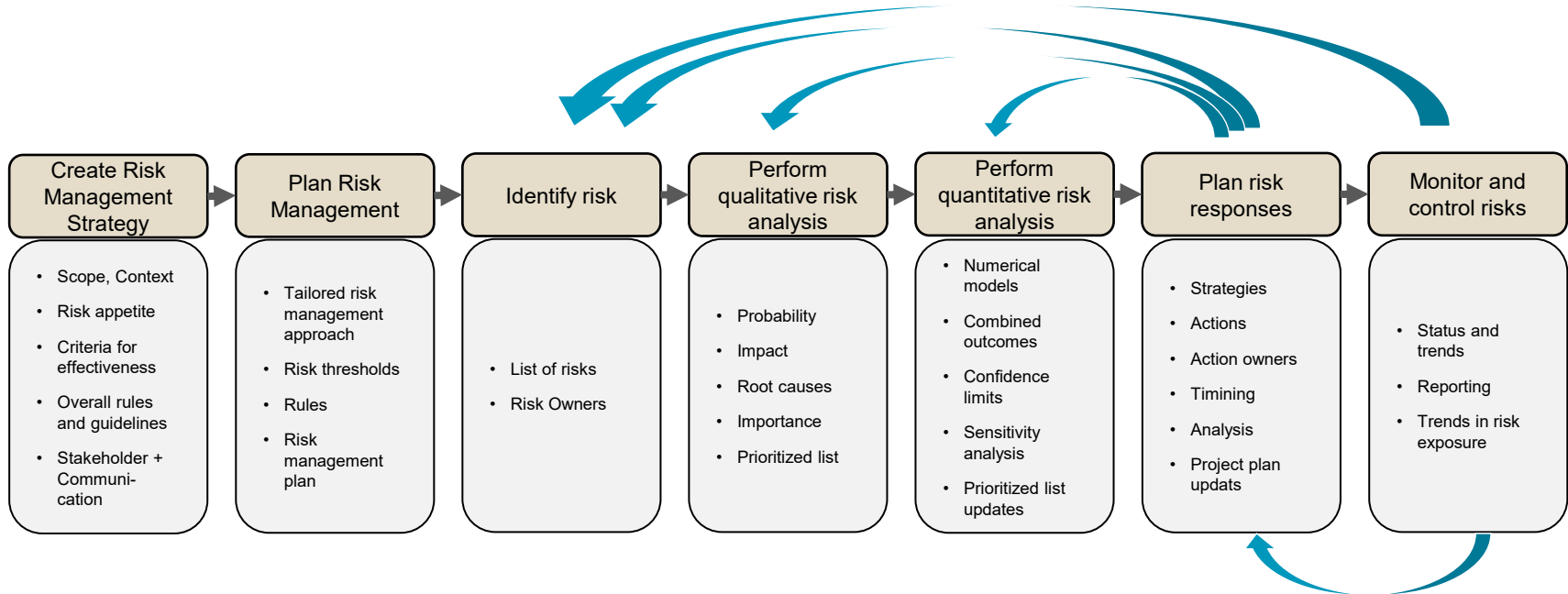
- Many companies use Risk Management according to ISO 31000 for enterprise level
- This framework is also well suited for managing cybersecurity risk
- By considering cyber resilience specific aspects (as shown in the following pages) cybersecurity risk management could be integrated seamless into overarching enterprise or project risk management



Hint: For explainability of the following slides solely the part process (clause 6) of the framework acc. to ISO 31000 is shown

Risk Management Framework

- Many companies use the Project Management Institute (PMI) standard for projects



Framework for managing product cybersecurity risks

The EU CRA provides a **generic framework** for managing product cybersecurity risks, which:

- lays out the requirements for appropriate cybersecurity risk management elements.
- It prescribes relevant elements of appropriate risk management approaches.
- This approach can be used throughout the product lifecycle and repeated when necessary.

What is the **difference** between the risk in the **CRA** from other **Cybersecurity** standards?

- The difference is that the risk **refer to the recipient of the product** with digital elements, **instead of the entity** assessing and mitigating the product.

CRA approach differs from traditional frameworks



CRA is emphasizing product-level and product related risks



rather than organizational security postures

Definition: What is a **Cybersecurity Risk** according to the EU CRA?

A general definition can be found in Article 3 (37) CRA:

*„‘cybersecurity risk’ means the **potential for loss or disruption caused by an incident** and is to be expressed as a combination of the **magnitude of such loss or disruption** and the **likelihood of occurrence of the incident**;“*

Further requirements and parameters for the cybersecurity risk assessment are set in Article 13 (3) CRA:

- Documentation of the cybersecurity risk assessment
- Updating cybersecurity risk assessment during support period (as appropriate)
- Assessment shall comprise at least an analysis of cybersecurity risks based on the products cybersecurity properties (confidentiality, integrity and availability, etc.).



Management of Risks ^{1 of 2}

The management of risks applies to **all phases of the product lifecycle**, including design, development, production and maintenance to ensure an appropriate level of cybersecurity.

Cybersecurity risk is generally defined in Article 3 (37), Chapter 1 CRA

Management of risks includes the following:

- establishing the product context: based on its intended use and reasonably foreseeable use, it's environment and the potential impact of vulnerabilities
- establishing the risk acceptance criteria:
 - Regulatory factors (legislation affecting the product can influence the degree by which a specific risk is acceptable)
 - Contractual agreements, stakeholder expectations or existing business practices
- performing an assessment of the risks
- performing appropriate treatment of the risks
- communicating the residual risks
- reviewing management of the risks

Management of Risks ^{2 of 2}

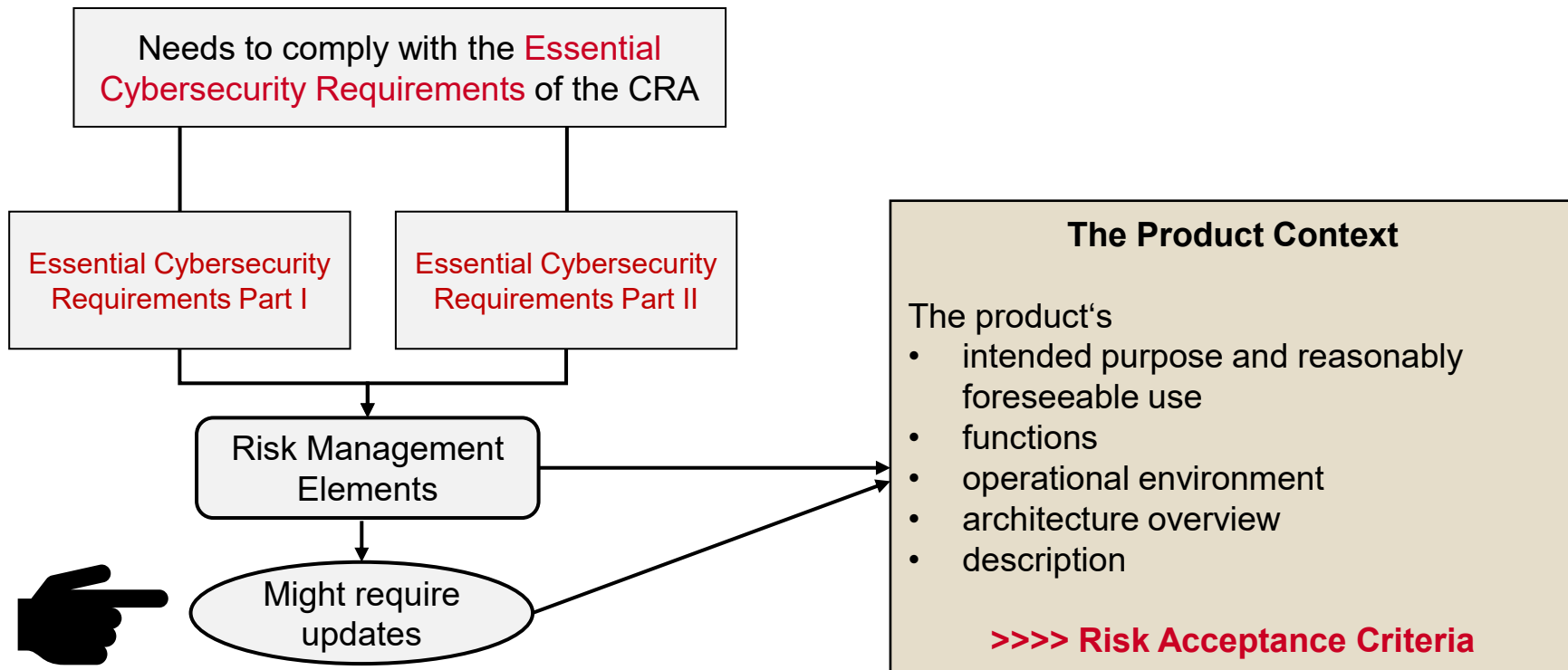
The management of risks applies to **all phases of the product lifecycle**, including design, development, production and maintenance to ensure an appropriate level of cybersecurity.

Cybersecurity risk is generally defined in Article 3 (37), Chapter 1 CRA

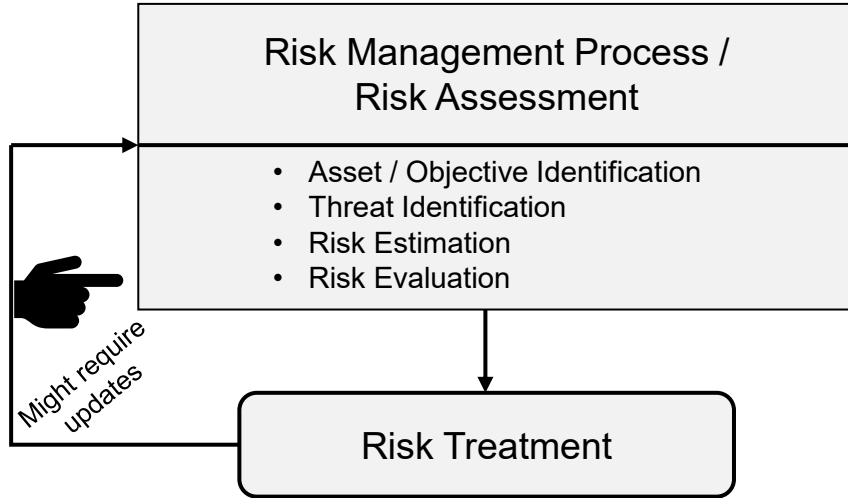
Management of risks includes the following:

- Continuous risk assessments
- Implementation of secure development practices, encompassing both security-by-design and security-by-default methodologies, is imperative
- Management of both known and emerging vulnerabilities
- Ensure transparency and maintain technical documentation
- Demonstration of compliance through conformity assessment

Interplay between the Risk Management Elements ¹ of 2



Interplay between the Risk Management Elements ² of 2



The aim of risk treatment is to reduce or mitigate risks so that the residual risk is acceptable.

Risk Communication



Risk Monitoring and Review

The General Approach in Risk Management



Aim of Risk Treatment

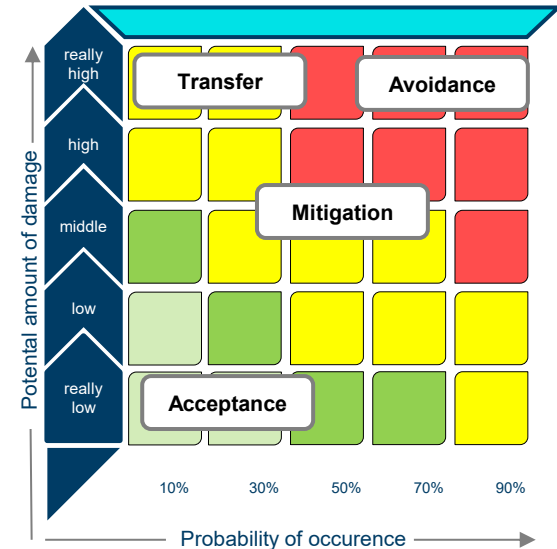
Avoidance - Risk avoidance involves choosing not to incorporate certain components in the product, or modifying the product's context, in order to avoid the risks related to those choices. This can help avoid some classes of vulnerabilities

Mitigation - Risk mitigation involves implementing measures that reduce the likelihood of occurrence or magnitude of potential loss or disruption for a particular threat.

Transfer - Any risk remaining after mitigation, even if acceptable, will inherently be non-zero. This residual risk does not vanish; it is transferred to the user of the product.

Acceptance - A risk can be accepted provided it aligns with the predetermined risk acceptance criteria.

CRA aims to **reduce** the **likelihood** and **impact** of cybersecurity-related incidents.



Risk Management must be performed during the whole Product Lifecycle

CRA Risk Requirement	Lifecycle Phase	Supporting Mechanisms
Threat / Risk Identification	Plan / Design	Risk assessment tool such as OWASP, Threat Dragon, STRIDE, MITRE ...
Security-by-Design & Default	Design / Implement	Security requirements, secure/security libraries (e.g., derived from risk models)
Vulnerability Management	Build / Test / Deploy / Operate	SAST, DAST, SCA, container scanning, patch management, dependency management (e.g., CodeQL, VUSC, OWASP Dependency Scan, ...)
Security Validation & Testing	Test	Automated security testing, manual penetration testing (e.g., Nikto, SQLmap, ...)
Documentation & Traceability	All phases	Secure Development Lifecycle artifact management, SBOM generation, logging (e.g., CycloneDX, SPDX, ...)
Conformity & Compliance Checks	Release / Operate	Compliance-as-code, policy-as-code, infrastructure-as-code

Sources for Risk Identification process step

MITRE* data bases could be used for risk identification:

- Lifecycle – Common Vulnerability and Exposures
- CWE – Common Weakness Enumeration
- CAPEC – Common Attack Pattern Enumeration and Classification
- ATT&CK® – Adversarial Tactics, Techniques & Common Knowledge



** MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations.*

Risk Management Methodologies

By adopting the Risk Management Methodologies **Manufacturers cannot only address CRA requirements** but also:

- enhance their overall product security posture,
- reduce incident response times,
- and establish a competitive advantage through demonstrable security practices that build customer trust.

Exercise: Risk Management



1. Identify potential threats to your product.
2. Assess the impact and likelihood of the threat.
3. Determine the overall risk level (Critical, Moderate, Minor).
4. Define mitigation for the risk (risk level cannot be accepted)
5. Document your findings.

Key Takeaways

The EU CRA provides a generic framework for managing cybersecurity risks in products and sets out the requirements for appropriate elements of cybersecurity risk management:

- It is intended to provide generic principles for cybersecurity and to specify activities for manufacturers covering all stages of the product lifecycle
- in order to ensure and maintain an appropriate, risk-based level of cybersecurity.

Risk assessment and mitigation:

- Manufacturers are required to conduct a risk assessment and keep it up to date, as well as to implement measures to address identified vulnerabilities during the product's lifecycle.
- If manufacturers rely on third-party components or services, they must exercise due diligence when integrating these into their products.

Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
- 10. Conformity Assessment Procedures**
11. Real World Use Case Examples

Topics

1. New Legislative Framework
2. Conformity assessment procedure based on internal control - Module A
3. Conformity assessment procedure based on internal control - Module B
4. Conformity assessment procedure based on internal control - Module C
5. Conformity assessment procedure based on internal control - Module H
6. Annex V and VI



Topics

1. **New Legislative Framework**
2. Conformity assessment procedure based on internal control - Module A
3. Conformity assessment procedure based on internal control - Module B
4. Conformity assessment procedure based on internal control - Module C
5. Conformity assessment procedure based on internal control - Module H
6. Annex V and VI



New Legislative Framework (NLF)

CE-Mark & CRA

- CRA is based on the **New Legislative Framework** (NLF).
- NLF is a comprehensive **set of regulations** adopted by the European Union to enhance the internal market for goods and improve product safety and compliance.
 - Sets clear rules for accreditation of conformity assessment bodies
 - Strengthens confidence in conformity assessments
 - Clarifies and enhances the credibility of CE marking



CRA follows the NLF model and extends the NLF principles to cybersecurity:

- CRA **extends NLF principles** to cybersecurity
- **CE marking now requires cybersecurity compliance**
- Products failing CRA **cannot be sold in EU**

Product Categorization and Assessment Application

CRA Conformity Requirements – CE marking

Category	Requirements	Module*	Examples
Default Category	Products with a lower cybersecurity risk profile require a self-assessment (technical file) . Manufacturers can demonstrate compliance by conducting a self-assessment against relevant standards. → EU declaration of conformity, based exclusively on Harmonized Standards (hENs).	Module A	Memory chips, mobile apps (expected to cover 90% of PDE)
Important Class I:	If you can use a harmonized standard , you may demonstrate compliance through self-assessment . If you cannot use a harmonized standard , you must undergo a conformity assessment by a Notified Body (third-party) .	Module A Optional (if A cannot be used): Module B+C Module H	Operating systems, Microprocessors/ controllers with security-related functionalities, Smart home products w. security functionality
Important Class II:	These higher-risk products always require a third-party conformity assessment by a Notified Body , regardless of harmonized standard availability.	Module B+C Optional: Module H	Firewalls, IDS, Tamper-resistant microprocessors/ controllers
Critical Category:	The highest-risk products must obtain certification under an EU cybersecurity certification scheme (such as EUCC, EUCS, or EU5G), with assurance at least at the 'substantial' level. Alternatively, if certification is not yet available, conformity assessment procedures as specified in CRA Article 32(3) apply.	Common Criteria Module B+C / Module H (Only in absence of CC)	Smart cards, secure elements, smart meter gateways

Topics

1. New Legislative Framework
2. **Conformity assessment procedure based on internal control - Module A**
3. Conformity assessment procedure based on internal control - Module B
4. Conformity assessment procedure based on internal control - Module C
5. Conformity assessment procedure based on internal control - Module H
6. Annex V and VI



Conformity Assessment Procedure

Based on Internal control (self assessment) – Module A^{1 of 2}

Purpose

- Manufacturer **alone ensures and declares product compliance** declares that the product
 - Meets Essential **Cybersecurity Requirements** (Annex I, Part I)
 - Has **Vulnerability Handling Processes** (Annex I, Part II)
- **No Notified Body** involvement



Disadvantages

- **Full responsibility** lies with the manufacturer
- **Non-compliance** → fines, recalls, legal liabilities
- **No external validation** → higher chance of missed vulnerabilities or documentation gaps
- Risk of **retrospective penalties** if authorities perform spot checks

Conformity Assessment Procedure

Based on Internal control (self assessment) – Module A² of 2

Cybersecurity Risk Assessment

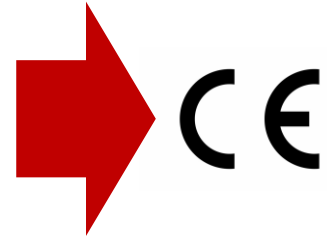
- Identify potential cybersecurity risks related to the product.
- Evaluate threats, vulnerabilities, and potential impacts.
- Document the risk assessment and justify any essential requirements that are not applicable.

Design & Development

- Ensure product is secure by design and default.
- Implement controls for access, data protection, and resilience.

Technical documentation

- Product description
- Design and implementation details
- Risk assessment
- Support Period information
- Applied harmonized standards (if any)
- Security testing results
- Copy of the EU declaration of conformity
- SBOM (Software Bill of Materials)



Topics

1. New Legislative Framework
2. Conformity assessment procedure based on internal control - Module A
3. **Conformity assessment procedure based on internal control - Module B**
4. Conformity assessment procedure based on internal control - Module C
5. Conformity assessment procedure based on internal control - Module H
6. Annex V and VI



EU-type Examination - Module B

Purpose:

- **Independent, third-party conformity** assessment, confirms compliance of CRA requirements (Annex I, Parts I & II)
- examines the technical design and development of a product with digital elements and the vulnerability handling processes put in place by the manufacturer, and attests that a product with digital elements meets the essential cybersecurity requirements



Who Performs It

A Notified Body (EU-accredited independent organization)



What's Assessed

- Technical documentation
- Risk analysis
- Vulnerability Handling processes
- Tests
- Physical product specimens (if required)



If compliant → EU-Type Examination Certificate issued

EU-type Examination and its first steps

Procedure ^{1 of 2}

Step 1



Application by Manufacturer

- Submit to a **single notified body**.
- Include:
 - **Manufacturer & representative** details.
 - Declaration of **exclusivity**.
 - **Technical documentation** (incl. risk analysis, SBOM, design, operation).
 - Supporting **evidence** (test results, standards used).



Step 2



Assessment by Notified Body

- Review **technical design & vulnerability handling**.
- Examine **specimens** of critical parts.
- Verify use of **harmonized standards** or **equivalent solutions**.
- Conduct or oversee **necessary test**.

EU-type Examination and ongoing Obligations

Procedure ^{2 of 2}

Step 3



Evaluation Report & Certificate

- Issue EU-Type Examination Certificate if compliant
- Include:
 - Manufacturer info
 - Conditions for validity
 - Identification of approved type & processes
- Refuse with reasons if non-compliant



Step 4



Ongoing Obligations

- Manufacturer must:
 - Inform notified body of changes
 - Keep certificate & documentation for 10+ years
- Notified body must:
 - Monitor state of the art
 - Conduct periodic audits
 - Share certificate status with authorities & other bodies

Topics

1. New Legislative Framework
2. Conformity assessment procedure based on internal control - Module A
3. Conformity assessment procedure based on internal control - Module B
4. **Conformity assessment procedure based on internal control - Module C**
5. Conformity assessment procedure based on internal control - Module H
6. Annex V and VI



Conformity Assessment – Module C

Based on Internal Production Control ^{1 of 2}

- Module C is a **follow-up procedure** to Module B (always used in **combination with Module B**)
- Ensures mass-produced products **remain identical to the approved type**
- Confirms **continued compliance** with CRA essential cybersecurity requirements

Who Performs It ?
The manufacturer
(under their own responsibility)



No notified body at this stage (already covered in Module B)

Conformity Assessment – Module C

Based on Internal Production Control ^{2 of 2}

Purpose

- Allows manufacturers to **self-declare conformity** of products with digital elements
- Based on an **approved type from prior EU-Type Examination** (Module B)



Production Obligations

- Manufacturer must ensure that:
 - All products match the **approved type** described in the EU-type examination certificate.
 - Products meet the **essential cybersecurity requirements** in **Annex I, Part I**.
 - The manufacturer's **vulnerability handling processes** comply with **Annex I, Part II**.
- Requires **monitoring and control** of production processes to maintain conformity.



CE Marking & Declaration of Conformity

- **CE marking** must be affixed to each compliant product.
- A **written EU Declaration** of Conformity must be:
 - Prepared for **each product model**.
 - Retained for **10 years** or the **support period**, whichever is longer.
 - Made **available to national authorities** upon request.

Topics

1. New Legislative Framework
2. Conformity assessment procedure based on internal control - Module A
3. Conformity assessment procedure based on internal control - Module B
4. Conformity assessment procedure based on internal control - Module C
5. **Conformity assessment procedure based on internal control - Module H**
6. Annex V and VI



Conformity Based on Full Quality Assurance – Module H

Purpose

- Allows manufacturers to **self-declare conformity** based on a **comprehensive quality system** that covers the **entire lifecycle** of the product.

Quality System Requirements must cover:

- Design & development, product inspection & testing
- Vulnerability handling processes
- Must be approved by a notified body and maintained throughout the product's support period

Quality System Documentation:

- Organizational structure and responsibilities.
- Design and development specifications.
- Standards used (or justification for alternatives).
- Control and verification processes.
- Production and testing procedures.
- Quality records and monitoring methods.

Conformity Based on Full Quality Assurance – Module H

Benefits

- Module H may be highly applicable to organizations with **significant number of products categories**, making it impractical for Module B+C, or where there is critical/quick turn-around times of major changes e.g. Software Development companies needing to comply to CRA.

Quality Management System

- The manufacturer must operate an **approved quality system** covering design, manufacture, and product inspection/testing, which typically aligns with standards like EN ISO 9001, supplemented as needed for product specifics according to CRA Requirements

Application to Notified Body: Manufacturer and representative details, Technical documentation for one model per product category & Quality system documentation.

Assessment and Surveillance: Initial audit by notified body, **ongoing surveillance**, manufacturer must notify body of changes to the quality system.

Conformity Based on Full Quality Assurance – Module H

Use-Case: Applicability of ISO9001 with a Delta to CRA Compliance

- ISO 9001 provides a **generic Quality Management System (QMS) framework** covering:
 - Context of the organization.
 - Leadership and commitment.
 - Planning quality objectives and risk-based thinking.
 - Support including competence, awareness, communication.
 - Operation planning and control.
 - Performance evaluation and improvement.
- For Module H, the notified body assesses the **manufacturer's full quality assurance system** to ensure product conformity including design, manufacture, final inspection, and testing phases.
- ISO 9001 is presumed to **fulfill many Module H requirements**, especially when supplemented by **product-specific controls** and **procedures relevant to cybersecurity and CRA requirements**
- Module H goes beyond what basic ISO 9001 addresses by integrating the **design phase fully into the QMS**, making the control and verification of design specifications mandatory rather than optional.

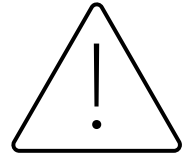


Conformity Based on Full Quality Assurance – Module H

Key Gaps (Delta) and Areas to Supplement Beyond ISO 9001 (1/2)

The gaps:

- Formal and documented **cybersecurity risk assessment** and **lifecycle vulnerability management**.
- Integration of **detailed design control** specific to cybersecurity.
- Emphasis on **technical cybersecurity documentation** and **lifecycle product support**.
- Regulatory requirements for **incident reporting** and **patch management** beyond typical ISO 9001 scope.
- Supplementing an ISO 9001 system with strong **cybersecurity risk management** (potentially adopting complementary standards like ISO/IEC 27001 or IEC 62443 alongside), **explicit design verification**, and **vulnerability management** will address the delta for Module H conformity assessment under the CRA.



Conformity Based on Full Quality Assurance – Module H

Key Gaps (Delta) and Areas to Supplement Beyond ISO 9001 (2/2)

Area	ISO 9001 Coverage	Gap/Module H Additional Requirements
Design Control	General design management principles	Mandatory integration of product design within QMS ; detailed control and verification of design specifications with cybersecurity risk considerations .
Cybersecurity Risk Assessment	Risk-based approach to quality objectives	Specific mandatory cybersecurity risk assessments including threat modeling, vulnerability management, and ongoing update in technical documentation required by CRA
Vulnerability Management	Indirectly covered under corrective actions	Detailed documented vulnerability handling, including Software Bill of Materials (SBOM), proactive patching, and security update support over the lifecycle .
Technical Documentation	Documented information requirements	Inclusion of detailed cybersecurity design elements, test results, risk analysis, and mitigation evidence in technical files beyond ISO 9001's general documentation
Lifecycle Support Commitment	Focus on product conformity and improvement cycles	Explicit responsibility for cybersecurity support and updates for products during expected lifecycle (e.g., min 5 years) is not an ISO 9001 requirement but essential for CRA Module H .
Product-specific Controls	Generic operational controls on product quality	Supplemented with controls specific to digital and cybersecurity products , such as secure coding practices, cryptographic controls, etc.
Incident Reporting and Response	ISO 9001 does not require cybersecurity incident management	CRA requires reporting of actively exploited vulnerabilities and incidents within strict timeframes, driving stringent operational security measures.

Key Takeaways: Overview of Modules – Summary

Module	Name	Who Assesses?	When Used?
A	Internal Control	Manufacturer (self-assessment)	Default & Class I (if harmonized standards exist)
B	EU-Type Examination	Notified Body	Class II & Critical
C	Production Control	Manufacturer	Only after Module B (prerequisite)
H	Full Quality Assurance	Notified Body	Alternative to B+C for Class II & Critical

Topics

1. New Legislative Framework
2. Conformity assessment procedure based on internal control - Module A
3. Conformity assessment procedure based on internal control - Module B
4. Conformity assessment procedure based on internal control - Module C
5. Conformity assessment procedure based on internal control - Module H
6. **Annex V and VI**



What must be content of the Conformity Declaration?

The EU declaration of conformity referred to in Article 28, shall contain all of the following information:

1. Name and type and any additional information enabling the unique identification of the product with digital elements
 2. Name and address of the manufacturer or its authorised representative
 3. A statement that the EU declaration of conformity is issued under the sole responsibility of the provider
 4. Object of the declaration (identification of the product with digital elements allowing traceability, which may include a photograph, where appropriate)
 5. A statement that the object of the declaration described above is in conformity with the relevant Union harmonisation legislation
 6. References to any relevant harmonised standards used or any other common specification or cybersecurity certification in relation to which conformity is declared
 7. Where applicable, the name and number of the notified body, a description of the conformity assessment procedure performed and identification of the certificate issued
 8. Additional information:
- Signed for and on behalf of:.....
- (place and date of issue):
- (name, function) (signature):

ANNEX V EU

ANNEX VI Simplified EU Declaration of Conformity

Purpose:

- It is a shortened version of the full declaration, intended for **user-facing** documentation. You can use the simplified declaration when:
 - You want to provide a concise compliance statement directly to users (e.g., in manuals, packaging, or online).
 - The full EU Declaration of Conformity is made available online via a URL.
 - The product is already CE-marked and fully compliant with the CRA.

The simplified EU declaration of conformity referred to in Article 13(20) shall be provided as follows:

“Hereby, **[name of manufacturer]** declares that the product with digital elements type **[designation of type of product with digital element]** is in compliance with Regulation (EU) 2024/2847.

The full text of the EU declaration of conformity is available at the following internet address: **[URL]**”

Key Takeaways

1. There are different **Product Categories** & **Assessment Types** which should be examined on product level and on organizational level!
2. A robust, approved quality system is essential for compliant product design, manufacturing, and ongoing monitoring in Module H unlike other module.



Training Content

1. Cyber Resilience Act (CRA)
Background, Purpose and Scope
2. Legal and Standardization Framework from EU Supporting CRA
3. CRA within the Global Cybersecurity Landscape
4. Products Affected by CRA
5. Actors Affected by CRA
6. Reporting Obligations and Enforcement Mechanisms
7. The Product Lifecycle and Essential CRA Requirements
8. Vulnerability Management
9. Risk Management for Cyber Resilience
10. Conformity Assessment Procedures
- 11. Real World Use Case Examples**

Topics

1. CRA Essential Requirements Applicability
2. Different Use Cases for CRA



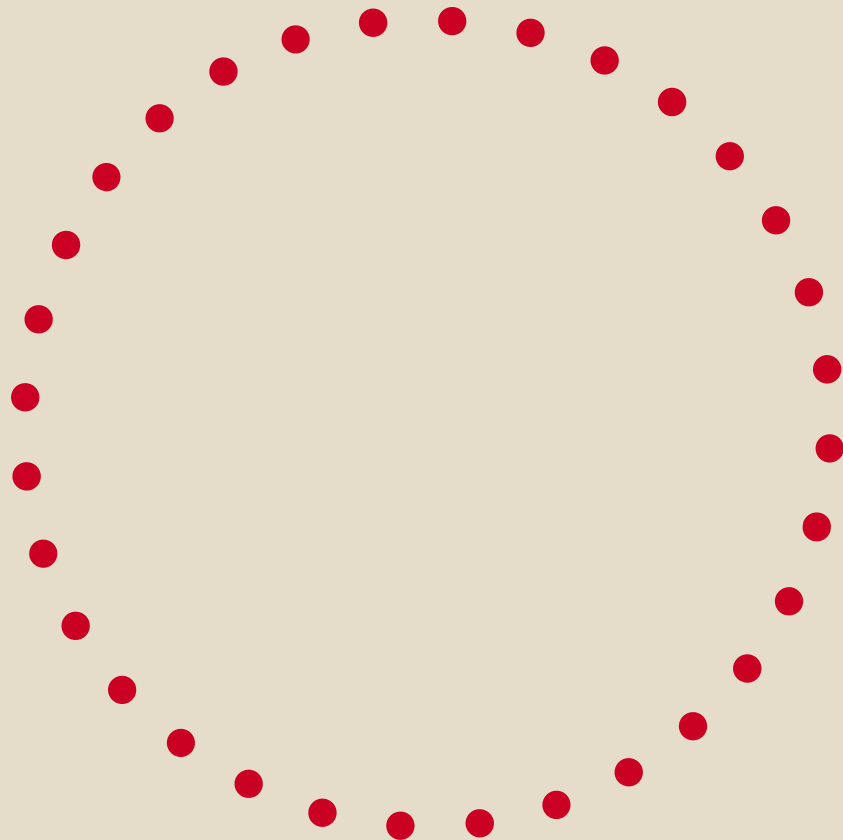
Topics

1. **CRA Essential Requirements Applicability**
2. Different Use Cases for CRA



CRA Essential Requirements Applicability with Examples

→ Essential Requirements Walkthrough



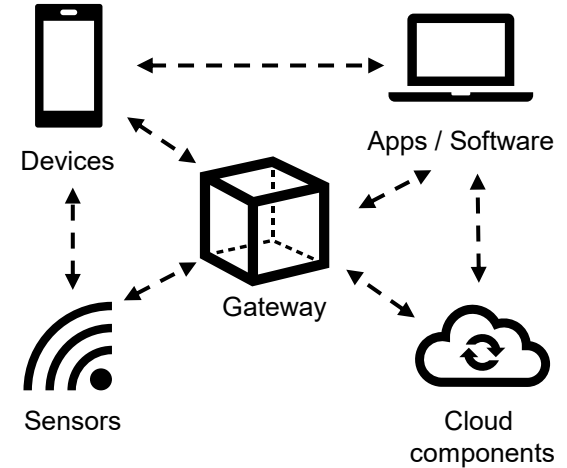
Overview of the CRA Essential Requirements

- Ensure that products with digital elements (both hardware and software) placed on the EU market have **fewer cybersecurity vulnerabilities**.
- **Better protection** for consumers, supply chains, organizations, businesses and IT infrastructure.

Secure by design / Risk Assessment

- | | |
|------------------------------------|-------------------------------------|
| a. Vulnerability assessment | g. Data minimization |
| b. Secure by default configuration | h. Availability protection |
| c. Security updates | i. Minimize negative impact |
| d. Authorized access | j. Attack surface minimization |
| e. Confidentiality protection | k. Reduce the impact of an incident |
| f. Integrity protection | l. Logging and monitoring controls |
| | m. Secure deletion mechanisms |

Vulnerability Handling Requirements



Product with digital elements means a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately.

Class I Category: Operative systems

- Worst case scenario: here is your scope



Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Class I Category: Operative systems

- Worst case scenario: here is your scope
 - **Vulnerability assessment:** For sure, different components available and for those a vulnerability assessment must be in place
 - **Secure by Default configuration:** To ensure that the operating system will be initialized securely by default with minimum open interfaces and services for instance.
 - **Security updates:** That is something 100% supported, software updates to solve any issues or to provide extra functions.
 - **Authorized access:** Applicable to the OS, different users can be set-up and different roles within that ecosystem. The only difficult part to implement (that may be not applicable) is the one where the PDE needs to notify unauthorized attempts. Being a PDE that can be used offline it would be difficult to notify the user of unauthorized attempts. Unless of course the user gets notified right after a correct log in.
 - **Confidentiality and integrity protection:** Partially applicable. This will highly depend on the hardware where the OS is installed; Some storage protection mechanisms will have not much to do with the software application. Unless otherwise decided by the OS manufacturer where a minimum specifications are being delivered to the final product integrator.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Class I Category: Operative systems

- Worst case scenario: here is your scope
 - **Data minimization:** Will apply and the manufacturer will need to decide what user data is being used (i.e.: e-mail to login and use OS integrated services and apps) and for what purposes. Identifying what data could be limited to be used if any.
 - **Availability protection:** Resilience mechanisms that have to do with the availability of the product with digital elements and the protection against Denial-of-Service attacks are usually on the interface level. In this scenario, the OS does not have this physical capability so the approach should be covered at the application level, ensuring that the available (through predefined interfaces worst case scenario) provide sufficient resilience mechanisms.
 - **Minimize impact:** Similarly, as in the availability protection, but from the PDE as being the one disrupting the availability of other products. How this OS connects to network resources or other products.
 - **Attack surface minimization:** Removing the physical of it, the OS shall only provide the needed services by default. Also make sure that these services are only exposing or disclosing needed information for its usage. I.e: web server disclosing library version details through http communication.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Class I Category: Operative systems

- Worst case scenario: here is your scope
 - **Attack surface minimization:** Removing the physical of it, the OS shall only provide the needed services by default. Also make sure that these services are only exposing or disclosing needed information for its usage. I.e: web server disclosing library version details through http communication.
 - **Reduce impact of incident:** One way to approach this requirement is making sure that the functionality of our product cannot be misused. This could be achieved by making sure that the software has been developed using best practices and using code review techniques to remove any unused code. Or also to have some protection flags available on the programs. This could be tested by using some tools such as winchecksec to identify code integrity/signing.
 - **Logging and monitoring controls:** The OS keeps logs of internal activities. This needs to include some user-interactions like access or modification of relevant data. For instance, accessing and changing the user credentials or network configurations.
 - **Secure deletion mechanisms:** The OS will provide a feature to factory reset. This would likely remove any user data and user configuration from the PDE. This needs to be done by an authorized user.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Accessories

- Worst case scenario: here is your scope for e.g. keyboard, mouse, display, simple gadgets except tablets



Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Accessories

- Worst case scenario: here is your scope
 - **Vulnerability assessment:** For sure, different components available and for those a vulnerability assessment must be in place
 - **Secure by Default configuration:** To ensure that the accessory will be initialized securely by default with minimum functionality to operate. If the accessory is basic, so will be the default configuration.
 - **Security updates:** Depending on the accessory capabilities. Most probably supported, software updates to solve any issues with any of the components or to patch the product.
 - **Authorized access:** For a Bluetooth accessory, to ensure that the access control mechanisms used by the Bluetooth stack is aligned with best practices and no external party can eavesdrop the communication or connect to the equipment. Usually for wired accessories there is a physical need to “own” the equipment, for those this may not apply (keyboard, mouse, wired headset, etc....).
 - **Confidentiality and integrity protection:** Partially applicable. For wired products probably the serial communication has the physical-need protection. For the Bluetooth ones, the communication will need to be secured.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Accessories

- Worst case scenario: here is your scope
 - **Data minimization:** Not applicable since accessories usually do not process nor use any user data.
 - **Availability protection:** Accessories with network interfaces usually have only capabilities for a local environment, making them not a threat for DoS/DDoS attacks.
 - **Minimize impact:** Similarly, as in the availability protection, but being the PDE the one impacting other products.
 - **Attack surface minimization:** Applicable, but for sure easy to comply since accessories do not have (usually) lots of interfaces and a big attack surface.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Accessories

- Worst case scenario: here is your scope
 - **Reduce impact of incident:** One way to approach this requirement is making sure that the functionality of our product cannot be misused. This could be achieved by making sure that the software has been developed using best practices and using code review techniques to remove any unused code.
 - **Logging and monitoring controls:** For limited functionality accessories, most probably the logging mechanisms will not be a capability of the product.
 - **Secure deletion mechanisms:** Maybe a factory reset is provided. Most probably, the product will not have any relevant data that would need to be deleted.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Standalone Apps

- Worst case scenario: Here is your scope



It could depend on app to app. i.e.: Maybe for word/ppt/excel there is no need to add a login against the cloud, but there is a functionality to protect the specific archive.

[This Photo](#) by Unknown Author is licensed under [CC BY-SA](#)

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Standalone Apps

- Worst case scenario: Here is your scope
 - **Vulnerability assessment:** For sure, different components available and for those a vulnerability assessment must be in place
 - **Secure by Default configuration:** To ensure that the app will be initialized securely by default with minimum functionality to operate. Its main function will not affect other apps installed on the OS neither the OS itself.
 - **Security updates:** Most probably supported, software updates to solve any issues with any of the components or to patch the product. Most probably to add new functionalities.
 - **Authorized access:** Not entirely sure if for word processing programs the authorization protection relies on the app itself or the files. For online videogames, e-mail apps, the authorization is needed to log-in against the remote data processing (cloud).
 - **Confidentiality and integrity protection:** Probably not applicable for word processing or offline only apps. And applicable for apps with cloud backend communication. To make sure that these apps are using best practices when communicating with the remote data processing (cloud).

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Standalone Apps

- Worst case scenario: Here is your scope
 - **Data minimization:** Applicable. All apps need some sort of license, and some user details could be shared.
 - **Availability protection:** If the app is allowing any kind of internet connection. Ensure that this communication cannot lead to a DoS of any kind.
 - **Minimize impact:** Ensure that the app cannot interfere with other devices or products which it connects.
 - **Attack surface minimization:** Applicable, to ensure that these apps only connect and use the minimum interfaces needed for operation.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

Default Category: Standalone Apps

- Worst case scenario: Here is your scope
 - **Reduce impact of incident:** One way to approach this requirement is making sure that the functionality of our product cannot be misused. This could be achieved by making sure that the software has been developed using best practices and using code review techniques to remove any unused code.
 - **Logging and monitoring controls:** Keep track in the background of the internal activities of the app.
 - **Secure deletion mechanisms:** Restart the factory default values of the apps so they do not have available any kind of user data/configuration.

Vulnerability assessment

Secure by Default Configuration

Security Updates

Authorized Access

Confidentiality Protection

Integrity Protection

Data minimization

Availability Protection

Minimize Negative Impact

Attack Surface Minimization

Reduce the Impact of Incident

Logging and Monitoring Controls

Secure Deletion Mechanisms

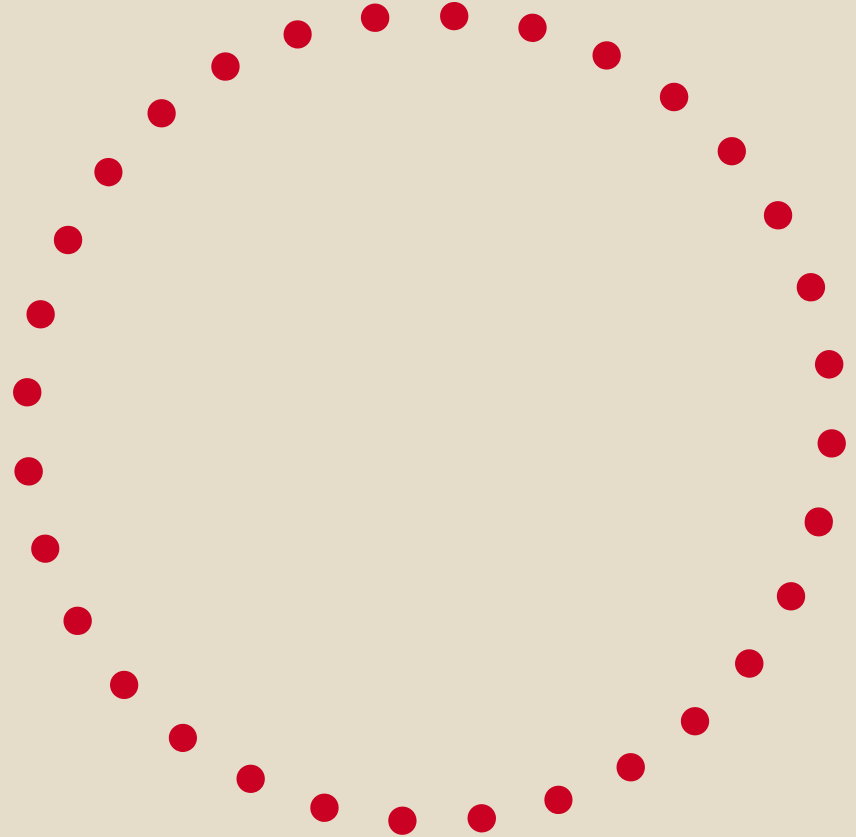
Topics

1. CRA Essential Requirements Applicability
2. **Different Use Cases for CRA**



Different Use Cases for CRA

→ Different IoT and Industrial Security Scenarios



Use Case 1: IoT Security Attack Scenarios

- IoT devices are used in **many applications**
- IoT attacks are taking place using **internet access**
- **Firewalls** are a common protection within the internet routers
- **Multi-layered Gateways** for access control are prepared using encryptions, passwords, keys and certificates based on crypto algorithms
- **Virtual Private Networks** (VPN) are used to control the unauthorized access to confidential assets

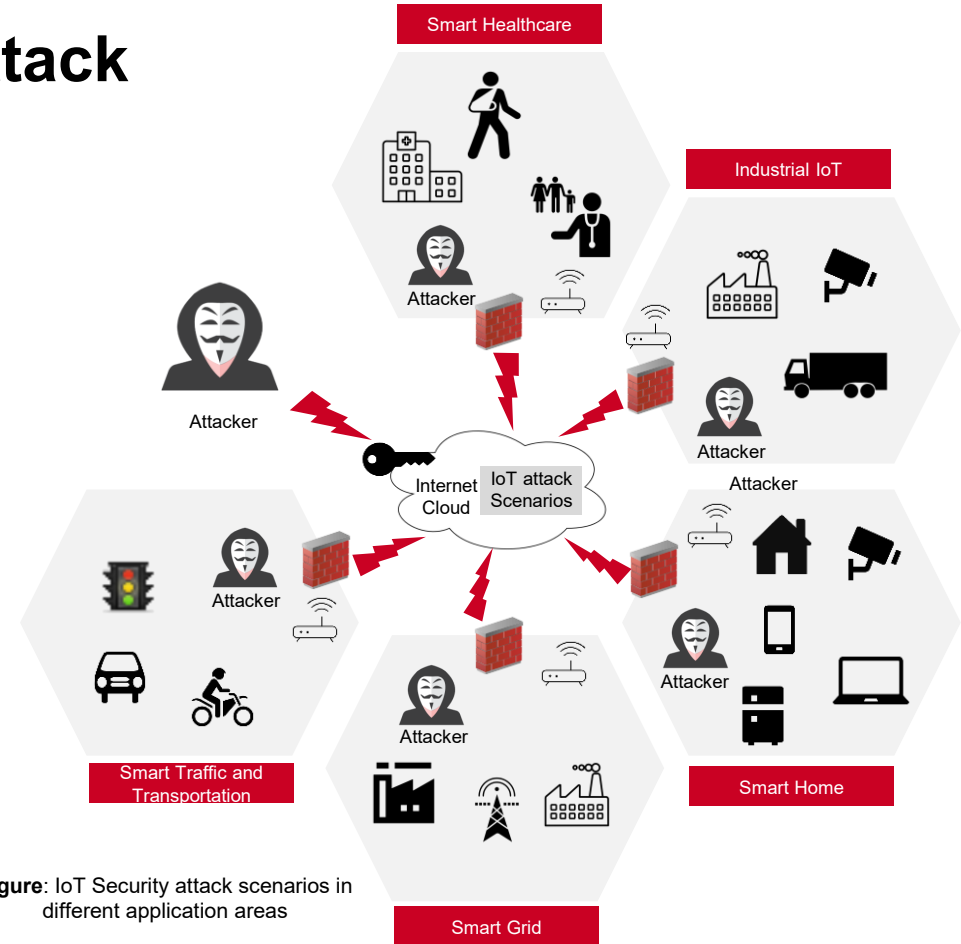


Figure: IoT Security attack scenarios in different application areas

Use Case 1: Different IoT Applications

- Different protocols are used for **secure communication** depending on the application criticality
- Edge devices have **physical, network and application layered architectures** to restrict the access and data transfer with dedicated communication protocols
- **Privacy of personal data** is an issue if the data is not erased from the IoT device memory.

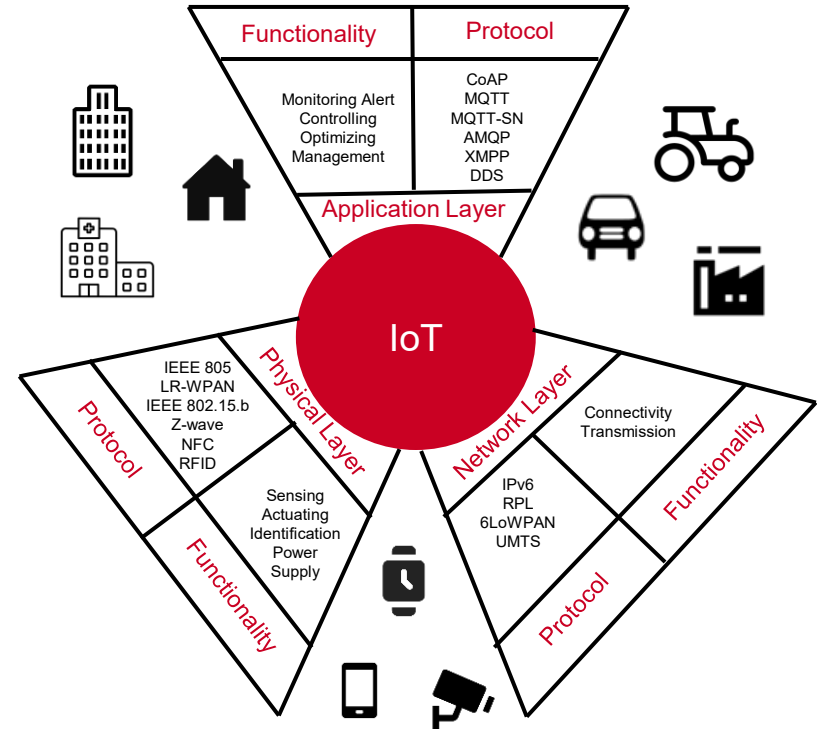


Figure: An overview of IoT, architecture, Functionalities, enabling Technologies and applications

Use Case 2: Industrial Automation Pyramid for layered Network Architecture

- Industrie 4.0 and digitalization of factory and process automation is organized using multi layer networks with digital devices in all levels.
- ERP systems are mostly based on SAP is used for planning, executing the production, collection of manufacturing data for analytics.
- Manufacturing Execution System (MES) is providing the recipes to different processes in the machines and coordinating the entire production with the communication to PLCs in the production line.

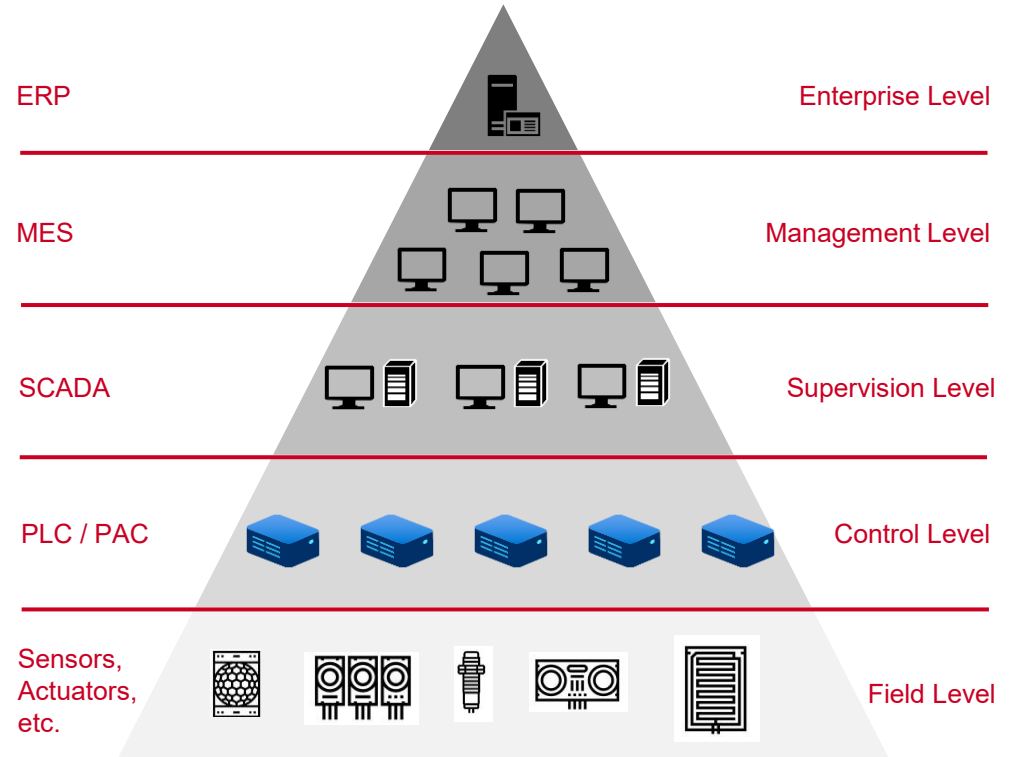


Figure: Automation Pyramid

Use Case 2: Architecture of Industrial Control System

- Factory automation is managed with **field network** (Profinet, EtherCAT, etc.)
- Supervisory systems** are connected to PLC of machines through control network (Ethernet)
- Enterprise Resource planning (ERP) Systems** are connected to machines' PLC and PC systems through enterprise network; these are normally connected to cloud using internet
- The **remote access to PLC and HMI** systems are organized using **VPN**.

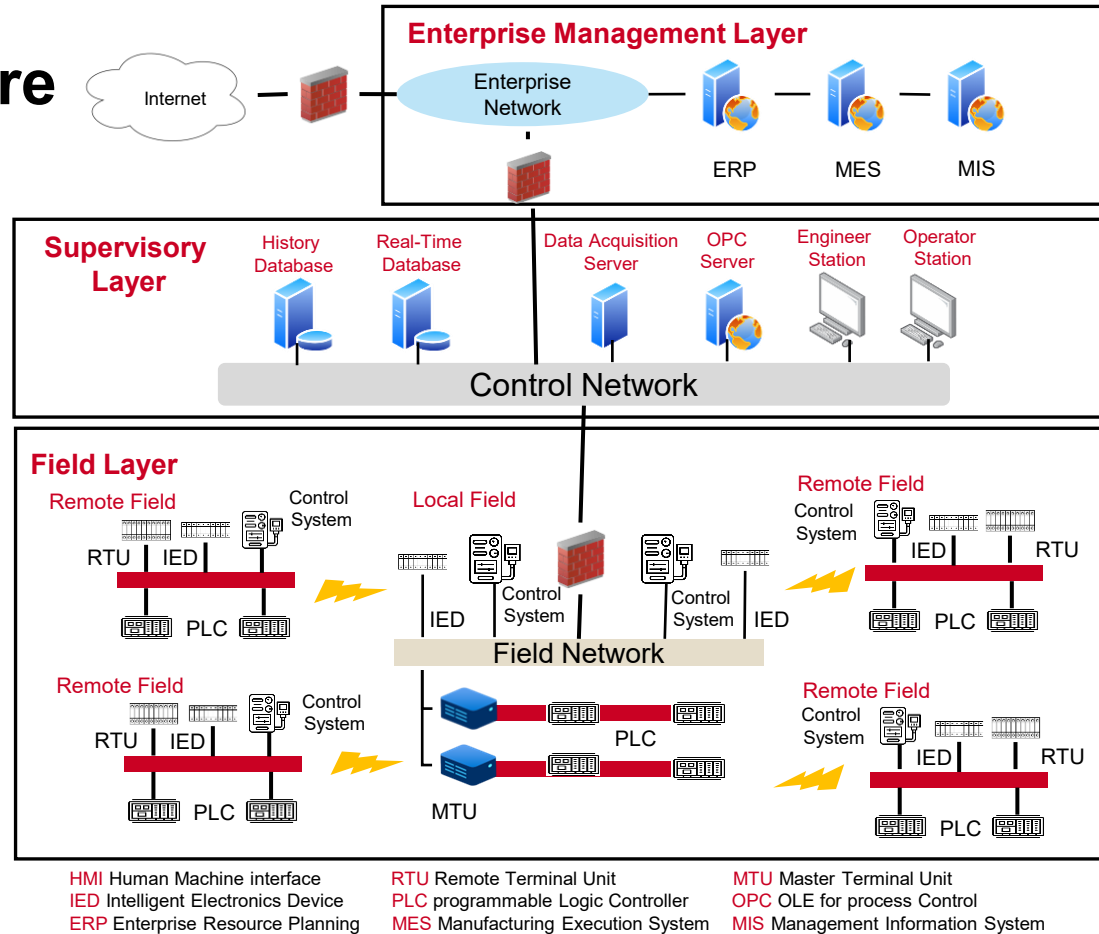
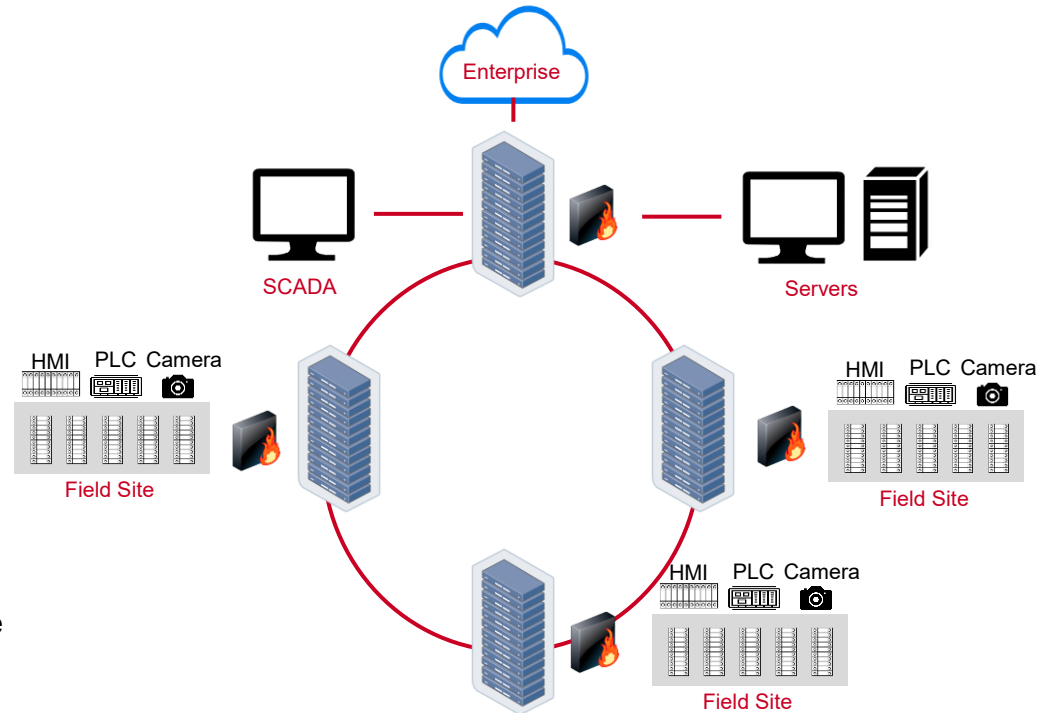


Figure: Architecture of Industrial Control System

Use Case 2: Interconnected Factory Networks

- Interconnected factory networks need proper **network segmentation** to reinforce industrial network security.
- Furthermore, **network redundancy** is also required to ensure the availability of the industrial control system.
- **Firewalls and access control using VPN** are common practices to protect from malicious attacks.
- **Data manipulations** are avoided with multi-factor authentication.
- **Public Key Infrastructure (PKI)** is used to manage digital certificates and public keys to enable secure communication and data exchange.



Key Takeaways

1. Essential Cybersecurity Requirements can be selected depending on **the category and class** of Products with digital elements
2. Products have to be developed with the **Security by design** and **Security by default** considerations to fulfil the requirements
3. **Security controls** are implemented in **Hardware and Software** levels to complement each other and providing the overall security to all assets in the system.
4. **Defense in depth** is practiced to detect the malicious attempts at outer layers and enabling the protection in the lower layers before the critical assets are exploited.





Thank you

UL.com/SIS

Within UL Solutions we provide a broad portfolio of offerings to many industries. This includes certification, testing, inspection, assessment, verification and consulting services. In order to protect and prevent any conflict of interest, perception of conflict of interest and protection of both our brand and our customers brands, UL Solutions has processes in place to identify and manage any potential conflicts of interest and maintain the impartiality of our conformity assessment services.